WFH Attendance & Employee Monitoring System

Product Requirements Document and Technical Specification



Dexa Group Software Engineer Technical Assessment

Author: **Abdurrahman Khairi**

Version 1.1, November 2026

© 2026 Abdurrahman Khairi. All Rights Reserved. Created strictly for Technical Assessment evaluation.

TABLE OF CONTENTS

TABLE OF CONTENTS 2
CHAPTER I DOCUMENT CONTROL AND COPYRIGHT POLICY 9
1.1 Intellectual property policy 9
CHAPTER II ENGINEERING PROLOGUE 10
2.1 Radical honesty and professional integrity 10
2.2 AI collaborative engineering 10
2.3 Research origin: Quora, Reddit and two practitioners 11
CHAPTER III BACKGROUND, PROBLEM STATEMENT, GOALS AND NON GOALS 12
3.1 Background and problem statement 12
3.2 Product and business goals 12
3.3 Non goals 13
CHAPTER IV USER PERSONAS, RBAC AND GLOBAL ASSUMPTIONS 14
4.1 SYSTEM_ADMIN: platform custodian 14
4.2 HR_ADMIN: workforce administrator 14
4.3 MANAGER: department head 14
4.4 EMPLOYEE: staff 15
4.5 Global assumptions 15
4.6 RBAC enforcement 15
4.7 RBAC permission matrix 16
CHAPTER V ARCHITECTURAL TOPOLOGY AND TECH STACK 17
5.1 Frontend presentation tier 18
5.2 API gateway and ingress tier 18
5.3 Internal TCP microservices tier 19
5.4 AI biometrics and infrastructure tier 19

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER VI FEATURE SPECIFICATIONS AND THE 12 END TO END FLOWS.....21
6.1 Where the brief and the code differ 21
6.2 Master feature summary 22
6.3 Feature 1: Authentication, RBAC and 6 Digit Email OTP.....23
6.3.1 Feature analysis and business goals.....23
6.3.2 User and operational assumptions 23
6.3.3 Codebase function and module breakdown 23
6.3.4 End to end technical flow 24
6.3.5 Scope and current technical limitations 25
6.3.6 Future improvements 26
6.4 Feature 2: Biometric Face Enrollment with ArcFace Embeddings of 512 Dimensions.....26
6.4.1 Feature analysis and business goals.....26
6.4.2 User and operational assumptions 26
6.4.3 Codebase function and module breakdown 26
6.4.4 End to end technical flow 27
6.4.5 Scope and current technical limitations 29
6.4.6 Future improvements 30
6.5 Feature 3: Daily WFH Notice, Upward Escalation and Biometric Clock In.....30
6.5.1 Feature analysis and business goals.....30
6.5.2 User and operational assumptions 30
6.5.3 Codebase function and module breakdown 31
6.5.4 End to end technical flow 31
6.5.5 Scope and current technical limitations 34
6.5.6 Future improvements 34
6.6 Feature 4: Authoritative Server Timestamp and Anti Clock Tampering.....34
6.6.1 Feature analysis and business goals.....34

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.6.2 User and operational assumptions 34
6.6.3 Codebase function and module breakdown 35
6.6.4 End to end technical flow 35
6.6.5 Scope and current technical limitations 37
6.6.6 Future improvements 37
6.7 Feature 5: Clock Out, Working Duration, Punctuality and 1/173 Overtime 37
6.7.1 Feature analysis and business goals 37
6.7.2 User and operational assumptions 37
6.7.3 Codebase function and module breakdown 38
6.7.4 End to end technical flow 38
6.7.5 Scope and current technical limitations 40
6.7.6 Future improvements 40
6.7.7 Formulas used by the code 40
6.8 Feature 6: Leave, Sick, Overtime and Correction Requests with Direct Links 40
6.8.1 Feature analysis and business goals 40
6.8.2 User and operational assumptions 41
6.8.3 Codebase function and module breakdown 41
6.8.4 End to end technical flow 41
6.8.5 Scope and current technical limitations 42
6.8.6 Future improvements 43
6.9 Feature 7: Master Employee Management, Mandatory NIP and Soft Delete 43
6.9.1 Feature analysis and business goals 43
6.9.2 User and operational assumptions 43
6.9.3 Codebase function and module breakdown 43
6.9.4 End to end technical flow 43
6.9.5 Scope and current technical limitations 45
6.9.6 Future improvements 46

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.10 Feature 8: Dual Dashboards and the Photo Lightbox 46
6.10.1 Feature analysis and business goals 46
6.10.2 User and operational assumptions 46
6.10.3 Codebase function and module breakdown 46
6.10.4 End to end technical flow 46
6.10.5 Scope and current technical limitations 49
6.10.6 Future improvements 49
6.11 Feature 9: XLSX, CSV and Printable Export 49
6.11.1 Feature analysis and business goals 49
6.11.2 User and operational assumptions 49
6.11.3 Codebase function and module breakdown 49
6.11.4 End to end technical flow 50
6.11.5 Scope and current technical limitations 51
6.11.6 Future improvements 51
6.12 Feature 10: Hierarchical File Storage 52
6.12.1 Feature analysis and business goals 52
6.12.2 User and operational assumptions 52
6.12.3 Codebase function and module breakdown 52
6.12.4 End to end technical flow 52
6.12.5 Scope and current technical limitations 53
6.12.6 Future improvements 53
6.13 Feature 11: Database Studio 53
6.13.1 Feature analysis and business goals 53
6.13.2 User and operational assumptions 53
6.13.3 Codebase function and module breakdown 54
6.13.4 End to end technical flow 54
6.13.5 Scope and current technical limitations 55

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.13.6 Future improvements 56
6.14 Feature 12: Developer Support with Targeted SMTP Routing 56
6.14.1 Feature analysis and business goals 56
6.14.2 User and operational assumptions 56
6.14.3 Codebase function and module breakdown 56
6.14.4 End to end technical flow 57
6.14.5 Scope and current technical limitations 59
6.14.6 Future improvements 59
CHAPTER VII DATA ARCHITECTURE AND DATABASE SCHEMA 60
7.1 users 62
7.2 employees 62
7.3 departments 63
7.4 attendances 63
7.5 attendance_requests 65
7.6 Other tables 66
CHAPTER VIII REST API AND INTERNAL MESSAGE CONTRACTS 67
8.1 Authentication and onboarding (employee service) 67
8.2 Employees, biometrics and access requests 67
8.3 Attendance and requests (attendance service) 68
8.4 System, policy, support and Database Studio 69
8.5 Biometric service (FastAPI, internal) 70
CHAPTER IX NON FUNCTIONAL REQUIREMENTS, SECURITY AND LIMITATIONS 72
9.1 Performance targets 72
9.2 Security safeguards in place 72
9.3 Core system limitations 73
9.4 Known defects found during this review 73

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER X DEPLOYMENT ARCHITECTURE AND ROADMAP 76
10.1 Current scope: local execution only 76
10.2 Evaluation entry points 76
10.3 Seeded evaluation accounts 77
10.4 Future deployment roadmap 77
CHAPTER XI LOCAL INSTALLATION WALKTHROUGH 79
11.1 Scope and Architecture 79
11.1.1 Local Assessment Scope 79
11.1.2 The Six Components and Their Ports 79
11.2 Prerequisites and a Zero State Check 81
11.2.1 Step 1: Check Tool Versions 81
11.2.2 Step 2: Look at the project folder 82
11.2.3 Step 3: Make sure the ports are free 83
11.3 Environment Files 85
11.3.1 Copy the Templates 85
11.3.2 Environment Variable Reference 87
11.3.3 SMTP Email Options 90
11.3.4 Emails the System Sends 91
11.4 Method A, Docker Compose (Recommended) 93
11.4.1 Before Start: The Face Model 93
11.4.2 Step 1: Build and Start All Containers 93
11.4.3 Step 2: Check the Containers and their Ports 94
11.4.4 Step 3: Watch the Face Model Load 95
11.4.5 Step 4: Database Tables and Seed Accounts 95
11.5 Method B, Manual Local Installation 97
11.5.1 Step 1: Start MySQL Only 97
11.5.2 Step 2: Python Environment and The Face Engine 98

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.5.3 Step 3: Install and Start the NestJS Backend 100
11.5.4 Step 4: Install and Start the React Frontend 101
11.6 Check the Installation in the Browser 103
11.6.1 Step 1: Biometric Engine Swagger Page 103
11.6.2 Step 1.5: One to One Face Check Against the Engine 103
11.6.3 Step 2: API Gateway and The Microservice Links 105
11.6.4 Step 3: Real Email Delivery 106
11.6.5 Step 4: The Portal Sign In Page 106
11.6.6 Step 5: First sign in with a seeded account 106
11.6.7 Step 6: The Uploads Folder on Disk 108
11.7 Troubleshooting and Maintenance 109
11.7.1 The Camera Does Not Open 109
11.7.2 The Face Model is Slow or Missing 109
11.7.3 Duplicate Face Prevention and Sibling Exemption 109
11.7.4 Real Email Does Not Arrive 110
11.7.5 Face Enrollment Returns 409 Conflict 111
11.7.6 A Port is Already Taken 112
11.7.7 Useful reset and maintenance commands 112

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER I
DOCUMENT CONTROL AND COPYRIGHT POLICY

Field	Value
Project	WFH Attendance & Employee Monitoring System (Dexa Group Fullstack Technical Assessment)
Author	Abdurrahman Khairi
Document type	Product Requirements Document and technical specification
Status	Final. Describes the code in the repository as of 10 November 2026.
Repository layout	frontend/ (React 18), backend/ (NestJS monorepo with three apps), biometric-service/ (Python FastAPI), docker-compose.yml
Companion documents	Installation Guide WFH System Dexa Group_Abdurrahman Khairi.docx and User Manual WFH System Dexa Group_Abdurrahman Khairi.docx in the repository root. Chapter XI of this document repeats the installation walkthrough.
Copyright	© 2026 Abdurrahman Khairi. All Rights Reserved. Created strictly for Technical Assessment evaluation.

dexa group

1.1 Intellectual property policy

- **All Rights Reserved.** The software is not open source. No MIT, Apache, GPL or other license is granted. Both backend/package.json and frontend/package.json declare "license": "UNLICENSED" and "author": "Abdurrahman Khairi".
- **Source watermark.** Every .ts, .tsx and .css source file opens with a five line copyright header that forbids commercial use, modification and distribution.
- **Visible watermark.** Every screen in the portal, including the sign in pages, modals and the print view, shows the footer: "© 2026 Abdurrahman Khairi, Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited".
- **Photo watermark.** Every attendance photo carries a copyright line burned into its pixels by the browser before upload.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER II
ENGINEERING PROLOGUE

2.1 Radical honesty and professional integrity

This project is presented as what it is: a working enterprise prototype built for a demanding technical assessment. It is not dressed up as a finished commercial product, and it does not pretend to be flawless. Every feature described here runs in the repository today, and every gap that exists is written down in this document next to the feature it affects.

That choice is deliberate. A reviewer gains more from a system whose limits are mapped honestly than from one whose limits are hidden. Section 9.4 lists seventeen defects found while this PRD was checked against the code, one of which has since been fixed, from a guard that lets HR admins open the Database Studio to a date box that files a morning WFH notice for the wrong day. Each one names the file where it lives. An engineer who can find, explain and own the weak points of their own system is an engineer a team can trust with production code.

dexa group

2.2 AI collaborative engineering

Abdurrahman Khairi acted as lead architect and systems engineer on this project. The author chose the architecture (an HTTP gateway in front of two TCP microservices and a Python biometric sidecar), set the business rules, defined the acceptance criteria, tested edge cases by hand and decided what shipped.

The author built the system in close partnership with two AI engineering agents, **Antigravity** and **Claude Code**. The agents worked as fast, well read collaborators: they drafted code to the specification the author set, proposed alternatives, reviewed diffs, chased down bugs and helped write documentation. They did not replace engineering judgment. Decisions about trade offs, such as running face matching inside the attendance service instead of the Python service, keeping the official clock on the server, and routing a manager's own requests upward to HR, were made by the author after discussing the options.

This document itself was produced the same way. The agents read the actual source files and cross checked every endpoint, column, constant and formula, and the author reviewed the result. Where the original brief and the code disagreed, the code was treated as the source of truth.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

2.3 Research origin: Quora, Reddit, Senior R&D and Corporate Staff Interviews

Coding started only after a research phase. The author studied real discussions about remote work on **Quora** and **Reddit**, looking for the ways attendance systems fail in practice. Four patterns came up again and again:

- **Buddy punching and photo reuse.** Colleagues clocking in for each other, or one good selfie reused for weeks.
- **Device clock manipulation.** Staff moving the laptop clock back a few minutes to turn a late arrival into an on time one.
- **Approval fatigue.** Managers buried in emails, hunting through tables to find the one request they are meant to approve.
- **Managers approving themselves.** Department heads whose own WFH days nobody above them ever sees.

The author then tested these findings in direct conversations with **a Senior R&D Engineer and a regular corporate staff member**. They provided practical, on-the-ground insights into how employees actually experience working from home, morning WFH reporting, task accountability, attendance correction disputes, and the Indonesian 1/173 overtime convention. Their input shaped specific features:

dexa group

Finding from research	Feature it produced
People change the device clock	Official clock in and clock out times come only from new Date() on the server (Feature 4)
Old photos get reused	EXIF capture time checks for uploads, plus SHA-256 and perceptual hash duplicate rejection (Features 3 and 4)
Managers approve their own WFH	Upward escalation: a manager's request goes to HR, with the System Admin in copy (Feature 3)
Approvers cannot find the request	Every request email carries a direct link that opens the exact request in the approval page (Feature 6)
Payroll needs overtime pay, not raw minutes	Automatic overtime pay using the 1/173 hourly rate with 1.5x and 2x multipliers (Feature 5)

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER III
BACKGROUND, PROBLEM STATEMENT, GOALS AND NON GOALS

3.1 Background and problem statement

Working from home creates verification and administrative problems that office attendance never had. The system was built around five of them:

#	Problem	How the system answers it
P1	Unverified remote presence: people log attendance with no proof that they are who they say they are.	1:1 face verification against an enrolled ArcFace embedding of 512 dimensions, browser liveness challenges (blink, turn left, turn right, hold front) and duplicate photo rejection.
P2	Client clock manipulation: users move the laptop clock to hide a late arrival.	clock_in_time and clock_out_time are set only by the server (new Date() in attendance.service.ts).
P3	The morning work plan and the attendance record live in different places.	Clock in requires an approved WFH request for the day and a written daily plan. Clock out requires a written daily accomplishment.
P4	Slow approvals: managers search tables by hand to find leave, sick and correction requests.	One attendance_requests pipeline, email routing to the right approver, a direct link to the request, and automatic attendance updates on approval.
P5	Photo proofs pile up on disk with random names, which slows HR audits.	Every file lands in uploads/<year>/<department>/<role>/<person>/<MM-month>/ with a readable name.

dexa group

3.2 Product and business goals

ID	Goal	Status in the code
G1	1:1 facial verification with InsightFace ArcFace embeddings of 512 dimensions.	Implemented. The match threshold in the code is a similarity of **0.45**.
G2	Server authoritative timestamps and permanent Canvas watermarks.	Implemented.
G3	Automatic work duration, punctuality and 1/173 overtime pay.	Implemented. Overtime starts after 540 minutes of work, with no break deduction.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

G4	One click approvals from email for managers and HR.	Implemented as a link to /manager/approvals?requestId=<uuid> that needs a normal sign in.
G5	Meet the assessment stack: NestJS, MySQL 8.0 and TCP microservices; React 18 with custom components, dynamic filters and exports; Python FastAPI biometrics.	Implemented.

3.3 Non goals

- Live cloud production deployment. The system runs locally for assessment (Section 10).
- Multi shift or 24 hour rotating schedules. One corporate shift is assumed.
- 3D infrared liveness hardware. Liveness here is a 2D browser heuristic.
- Full payroll processing (PPh 21 income tax, BPJS contributions, payslips). The system produces payroll ready data only.
- Push channels (WebSockets), caches (Redis), message brokers and object storage. None of these are part of this version.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER IV
USER PERSONAS, RBAC AND GLOBAL ASSUMPTIONS

The UserRole enum in libs/common/src/constants/enums.ts defines four roles. The role sits on users.role, and each user links to at most one employees row.

4.1 SYSTEM_ADMIN: platform custodian

- Seed account sysadmin@dexagroup.com (Abdurrahman Khairi, NIP DEXA-SYS-001).
- Owns the Database Studio (/system/database), company policy, and receives every support ticket as the To recipient. Can also open the HR dashboards, monitoring, employee records and approvals, because RolesGuard lets this role through every role check.
- **Separation of duties.** The System Admin cannot clock in or clock out: the gateway returns 403 on both routes, and the frontend sends this role away from /employee/*, /dashboard and /auth/enroll-face with a "Separation of Duties" message. The person who can edit any database row should not also be producing attendance records that feed payroll. That is why the role skips face enrollment too.
- Assumption: technically literate and comfortable editing raw rows.

dexa group

4.2 HR_ADMIN: workforce administrator

- Seed account admin.hrd@dexagroup.com (HR Admin One, DEXA-2026-001).
- Runs employee records with soft delete and restore, reviews onboarding requests, uses the HRD dashboard, the monitoring page with the photo lightbox, exports, approvals for every department and company policy. Receives support tickets in Cc.
- Has an employee record, so HR admins enroll a face and clock in like any other staff member.
- Assumption: needs fast visual audits and spreadsheet exports for payroll cut offs.

4.3 MANAGER: department head

- Seed accounts manager.it@dexagroup.com (Manager One, IT & Digital Innovation) and manager.finance@dexagroup.com (Manager Two, Finance & Accounting). Both are created on the second start of the employee service.
- Reviews requests from their own department at /manager/approvals. The backend filters manager queries to the manager's department.
- Their own requests escalate upward: To the HR PIC, Cc the System Admin, the HR PIC and the manager.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- Assumption: a busy approver prefers a link in an email to hunting through menus.

4.4 EMPLOYEE: staff

- Seed accounts employee.one to employee.four@dexagroup.com. Employee Four starts unverified to show the first sign in flow.
- Enrolls a face once, sends WFH notices, clocks in and out with a live photo, reads a personal dashboard and history, submits leave, sick, overtime and correction requests, and contacts the developer.
- Assumption: a laptop or desktop browser with a webcam, or a phone photo with intact EXIF data for the upload fallback.

4.5 Global assumptions

1. Everyone works in Asia/Jakarta time (WIB, UTC+7). APP_TIMEZONE = 'Asia/Jakarta' drives every date calculation.
2. One attendance record per employee per WIB calendar day, enforced by the unique index UQ_attendance_employee_date.
3. The company default is work from office with a WFH quota (1 day a week by default). WFH must be requested or noticed for each day.
4. Department routing uses the department name stored on the employee, plus the manager and HR emails stored on departments.

dexa group

4.6 RBAC enforcement

Layer	Mechanism	Behaviour
Gateway authentication	JwtAuthGuard	Verifies the Bearer token (HMAC HS256 through @nestjs/jwt), requires tokenType === 'access' and fills req.user.
Gateway authorization	RolesGuard with @Roles(...)	Passes when no roles are listed, when the role is listed, or when the user is SYSTEM_ADMIN or HR_ADMIN. The last rule is the cause of defect D1.
Service scoping	attendance-service	Manager queries for lists, summaries, exports and reviews are filtered to the manager's department.
Frontend routing	ProtectedRoute.tsx	Sends guests to /login, forces face enrollment, keeps the System Admin out of employee pages, and lets admins pass allowedRoles.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

4.7 RBAC permission matrix

Capability	SYSTEM_ADMIN	HR_ADMIN	MANAGER	EMPLOYEE
Sign in, profile, change password	Yes	Yes	Yes	Yes
Face enrollment, clock in, clock out	No (blocked)	Yes	Yes	Yes
Submit WFH, leave, sick, overtime and correction requests	Yes (API)	Yes	Yes	Yes
Review requests	All	All	Own department	No
HRD dashboard, audit log, export	Yes	Yes	Own department (API)	No
Employee CRUD and onboarding review	Yes	Yes	No	No
Sibling biometric exemption	Yes	Yes	No	No
Company policy update	Yes	Yes	No	No
Database Studio	Yes	Reachable (defect D1)	No	No
Contact Developer	Yes	Yes	Yes	Yes
Resolve support tickets	Yes	Yes	No	No

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER V
ARCHITECTURAL TOPOLOGY AND TECH STACK

The system has four tiers and six containers. The browser talks only to nginx. nginx forwards API calls and photo URLs to the gateway. The gateway is the only HTTP entry to the backend: it calls the two microservices over NestJS TCP transport and the face engine over HTTP. Email leaves the system through an external SMTP provider, Gmail or Outlook, which is not a container.

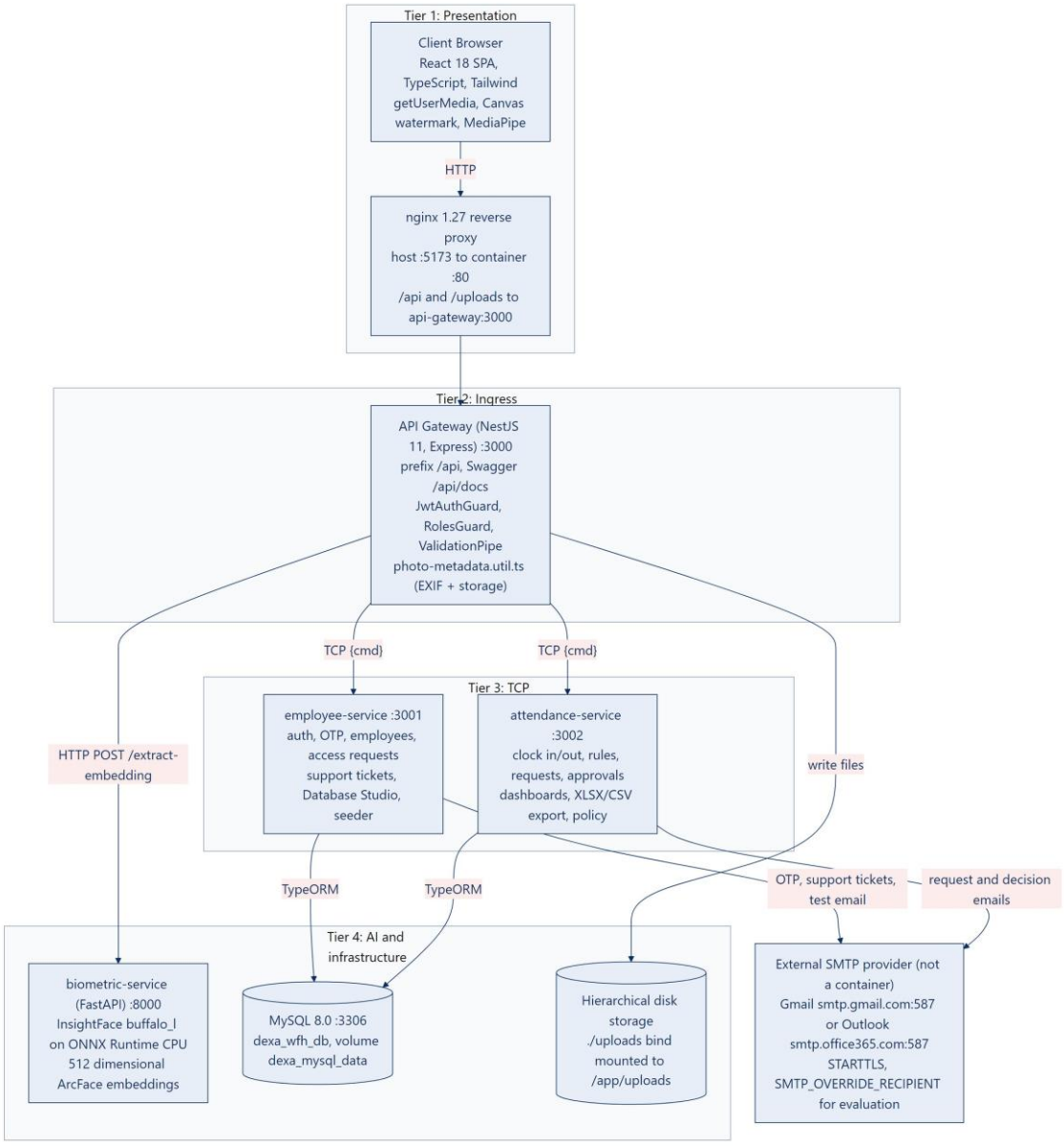


Figure 5.1: *System architecture topology: four tiers, six containers, the external SMTP provider and the disk store.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

5.1 Frontend presentation tier

Concern	Implementation
Framework	React 18.3, TypeScript 5.6, Vite 5.4, React Router 6. Only six runtime libraries: react, react-dom, react-router-dom, axios, lucide-react, @mediapipe/tasks-vision. Charts are built by hand from div elements.
Serving	A multi stage Dockerfile builds with Node 22 and serves with nginx:1.27-alpine on port 5173. nginx.conf proxies /api/ and /uploads/ to api-gateway:3000 and falls back to index.html. In development, vite.config.ts proxies the same paths.
Theme	Tailwind CSS 3.4 with class based dark mode. Corporate navy #0A2D62 for the sidebar and dark surfaces, Dexa red #D32F2F for accents in the white light theme. The choice is saved in localStorage (dexa_wfh_theme).
Typography	**IBM Plex Sans** for text, IBM Plex Mono for code. tabular-nums on the live clock, timestamps, NIP badges, Rupiah amounts and OTP boxes so digits do not jump.
HTTP client	src/api/client.ts: Axios with a 20 second timeout. A request interceptor adds the Bearer token. On a 401 the response interceptor calls POST /auth/refresh once, stores the new token pair and replays the request.
Notifications	Two channels for every action. A toast in the bottom right corner (green, red or blue, at most four at once), and the same message in the header Notification Center (kept in localStorage, capped at 40, with unread state). Every message has a where, what and why part, written without square brackets.
Hardware APIs	navigator.mediaDevices.getUserMedia (1280x720 ideal), Canvas 2D watermarking, MediaPipe FaceLandmarker served locally from /mediapipe/, optional geolocation.

5.2 API gateway and ingress tier

- NestJS 11 on Express, port 3000, global prefix /api, Swagger at /api/docs, global ValidationPipe with whitelist and transform, static serving of /uploads.
- Controllers: AuthController, EmployeesController, AttendanceController, SupportController, SystemController, DatabaseManagementController.
- JwtAuthGuard and RolesGuard protect routes. Tokens are HMAC HS256 signed.
- rpc.util.ts sends { cmd } patterns through two TCP ClientProxy instances with a 15 second timeout and maps transport failures to 502.
- BiometricClientService posts images to FastAPI POST /extract-embedding with a 10 second timeout.
- storage/photo-metadata.util.ts checks the file type (JPEG, PNG, WebP) and size (8 MB at most), reads EXIF dates with exif-parser, and writes the file into the folder tree described in Feature

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

10. Uploads stay in memory until the gateway writes them; only the resulting URL travels over TCP.

5.3 Internal TCP microservices tier

Service	Port	Responsibilities	Schema sync
employee-service	3001 (TCP)	Sign in, token issue and refresh, 6 digit OTP for account verification and password reset, onboarding requests, employee CRUD with soft delete and restore, department directory, face embedding storage, support tickets and SMTP, Database Studio, and the seeder.	Owner. Creates tables when DB_SYNCHRONIZE=true.
attendance-service	3002 (TCP)	Clock in and clock out (face similarity, duplicate photo checks, liveness gate, geofence, timestamp check), status and duration rules, 1/173 overtime pay, personal dashboard and history, HRD summary and audit log, XLSX and CSV export, company policy, and the request workflow with email routing and attendance sync.	Off, to avoid two services altering the schema at once.

dexa group

5.4 AI biometrics and infrastructure tier

Component	Details
biometric-service	Python 3.10, FastAPI and Uvicorn on port 8000. InsightFace FaceAnalysis(name="buffalo_l") with det_size=(320,320) and det_thresh=0.55 (a face detection threshold), on ONNX Runtime CPU. The recognition model is ArcFace w600k_r50 (ResNet 50). It returns an L2 normalized vector of 512 floats, a SHA-256 image hash and a 64 bit average hash. The model loads at startup from the host folder ~/.insightface, mounted read only.
Where similarity is computed	Not in Python. The attendance service takes the dot product of the new vector and employees.face_embedding. Both vectors are L2 normalized, so the dot product is the cosine similarity. A match needs **0.45 or higher**. The FastAPI /verify-face route exists with the same default but the backend does not call it.
dexa-wfh-mysql	MySQL 8.0 with TZ=Asia/Jakarta, database dexa_wfh_db, named volume dexa_mysql_data. TypeORM 0.3 with mysql2. Foreign keys use RESTRICT, SET NULL or CASCADE as listed in Section 7. The unique composite index (employee_id, attendance_date) guards one record per day. Employee creation runs in a database transaction.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

External SMTP provider	Not a container. Both NestJS services send through Gmail (smtp.gmail.com:587) or Outlook (smtp.office365.com:587) with STARTTLS, signing in with SMTP_USER and SMTP_PASS. For Microsoft hosts the employee and attendance services also force STARTTLS and set a compatible cipher list. SMTP_OVERRIDE_RECIPIENT forwards every email meant for the @dexagroup.com demo accounts to one evaluation inbox and adds a banner naming the intended recipient.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER VI
FEATURE SPECIFICATIONS AND THE 12 END TO END FLOWS

6.1 Where the brief and the code differ

The brief for this PRD described several behaviours that the code implements differently. The feature sections below follow the code. This table lists every difference in one place so a reviewer can see them at a glance.

Brief said	**The code does**
Cosine similarity of at least 0.55, computed in Python	Dot product of L2 normalized vectors in attendance-service, threshold **0.45**. (0.55 is the face detection threshold in Python.)
FastAPI route /extract-face	The route is POST /extract-embedding.
Enrollment page /enroll-face	The page is /auth/enroll-face.
POST /api/attendances/wfh-notice	No such route. A WFH notice is an attendance request of type WFH_APPROVAL sent to POST /api/attendance-requests.
Manager notice goes to HR, Cc the manager	To the HR PIC, Cc sysadmin@dexagroup.com, the HR PIC and the manager.
Access token 15 minutes	Access token **8 hours**, refresh token 7 days (both configurable).
60 minute break deduction	**No break deduction.** Duration is clock out minus clock in.
Overtime after 17:30 WIB	Overtime is duration minus **540 minutes**, counted only if it reaches 30 minutes.
COMPLETED at 480 minutes or more, HALF_DAY below 480	HALF_DAY below **240 minutes**, otherwise COMPLETED.
Signed deep link /requests/review?token=...	Plain link /manager/approvals?requestId=<uuid> protected by the normal sign in and a department check.
Lightbox shows the ArcFace similarity score and EXIF status	The lightbox shows photos, server and capture times, the timestamp verification banner, notes, IP and device. The similarity score is stored but not shown there.
Excel export with overtime totals	22 columns with overtime per row. There is no totals row.
Database Studio shows storage size and runs custom SQL with a timeout	Row counts and column metadata for 9 whitelisted tables, plus row level create, read, update and delete. No SQL runner and no size metrics.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

Support modal pre filled with name, email, NIP and department	The modal shows the sender name and email read only. NIP and role are looked up on the server and added to the email body.
MySQL JSON storage of the face vector	Correct: employees.face_embedding is a JSON column.

6.2 Master feature summary

#	Feature	Main entry points	Owner service
1	Authentication, RBAC and 6 digit email OTP	/login, /verify-account, /request-access	employee
2	Biometric face enrollment (ArcFace, 512 dimensions)	/auth/enroll-face	gateway, biometric, employee
3	Daily WFH notice, upward escalation and biometric clock in	/employee/attendance	attendance, biometric
4	Authoritative server time and anti clock tampering	every clock in and clock out	attendance, gateway
5	Clock out, duration, punctuality and 1/173 overtime	/employee/attendance	attendance
6	Leave, sick, overtime and correction requests with direct links	/manager/approvals	attendance
7	Master employee CRUD, mandatory NIP and soft delete	/hrd/employees	employee
8	Dual dashboards and the photo lightbox	/hrd/dashboard, /hrd/monitoring, /employee/dashboard	attendance
9	XLSX, CSV and printable export	/hrd/monitoring	attendance
10	Hierarchical file storage	uploads/	gateway
11	Database Studio	/system/database	employee
12	Developer support with targeted SMTP routing	header Support button	employee

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.3 Feature 1: Authentication, RBAC and 6 Digit Email OTP

6.3.1 Feature analysis and business goals

Daily sign in uses email and password and returns JWTs. Email OTP is used only twice in an account's life: to verify a new account and to reset a forgotten password. Because HR creates every account (directly or by approving an onboarding request), the first OTP proves the person owns the mailbox and is the moment they choose their own password.

6.3.2 User and operational assumptions

- The user can read their mailbox. In an evaluation setup every email is forwarded to the inbox in SMTP_OVERRIDE_RECIPIENT, because the demo accounts use @dexagroup.com addresses that cannot receive mail.
- There is no anonymous self registration that grants access. A public onboarding request only asks HR for an account.
- Seeded accounts are verified except Employee Four, whose first OTP (123456) is issued once at seed time and expires after 15 minutes like any other code.

6.3.3 Codebase function and module breakdown

dexa group

Layer	Function, route or pattern	File
Gateway	AuthController: login, refresh, me, changePassword, requestAccess, verifyAccount, resendVerification, forgotPassword, resetPassword	api-gateway/src/auth/auth.controller.ts
Guards	JwtAuthGuard, RolesGuard, @Roles()	api-gateway/src/auth/
TCP patterns	auth.login, auth.refresh, auth.me, auth.change_password, auth.request_access, auth.verify_account, auth.resend_verification, auth.forgot_password, auth.reset_password	libs/common/src/constants/message-patterns.ts
Service	AuthService.login, issueTokens, verifyAccount; OtpService.issue and verify	employee-service/src/auth/
Frontend	LoginPage, VerifyAccountPage, ForgotPasswordPage, RequestAccessPage, OtpInputGroup, AuthContext	frontend/src/pages/auth/

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.3.4 End to end technical flow

1. The user submits email and password at /login. The SPA calls POST /api/auth/login, and the gateway sends TCP auth.login.
2. AuthService.login loads the user by lower cased email with the employee and department. Unknown email gives 401. An inactive user or employee gives 403.
3. If is_verified is false, the service invalidates older codes, stores a new 6 digit code as a bcrypt hash with a 15 minute expiry, emails it, and returns 200 with requiresVerification: true. The password is not checked on this branch. The SPA moves to /verify-account.
4. POST /api/auth/verify-account takes the email, the code and a new password that must pass the strong password rule. After five wrong attempts the code is locked. On success the password is hashed with bcrypt (cost 10), is_verified becomes true and a token pair is returned.
5. For a verified account, bcrypt.compare checks the password. A mismatch gives 401. A match updates last_login_at and returns an access token (8 hours by default) and a refresh token (7 days), both carrying sub, email, role, employeeId, fullName, department and tokenType.
6. When an access token expires, Axios calls POST /api/auth/refresh once and replays the failed request.
7. Forgot password follows the same OTP path through /auth/forgot-password and /auth/reset-password.
8. A new hire can file /request-access. HR approves through PATCH /api/access-requests/:id/approve, which creates the user and employee in one transaction and emails a verification code.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

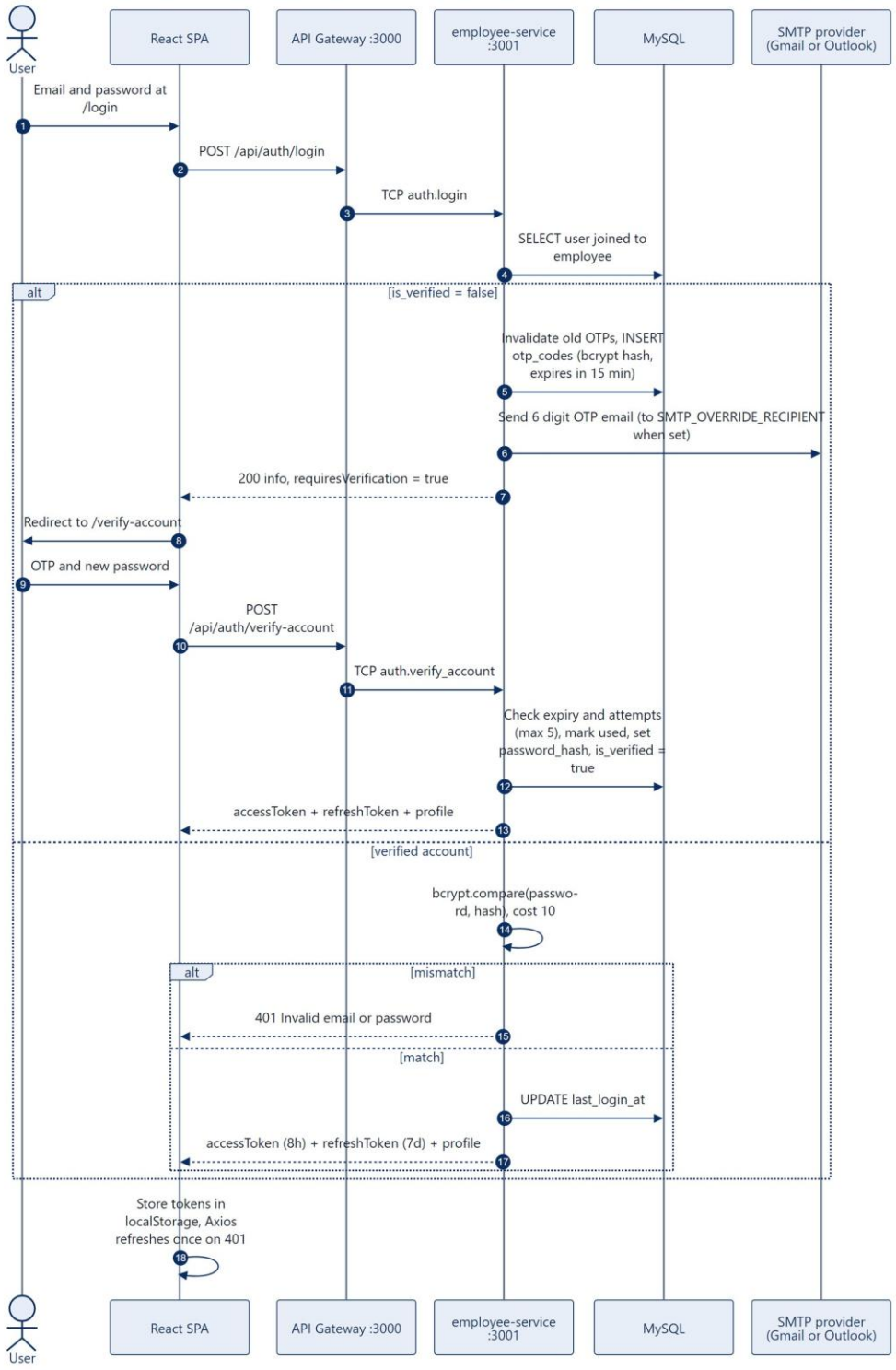


Figure 6.1: *Sign in, first time verification with a 6 digit OTP, and token issue.*

6.3.5 Scope and current technical limitations

- The unverified branch sends a new OTP on every sign in attempt without checking the password, and sign in reveals whether an email exists (defect D9).
- No rate limit on sign in, OTP issue or refresh beyond the 5 attempt cap per code.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- Refresh tokens are stateless. Signing out cannot revoke them.
- Tokens live in localStorage, readable by any script on the origin.
- The onboarding approve and reject buttons call a route the gateway does not expose, so they return 404 (defect D2).

6.3.6 Future improvements

- Rate limiting and a short cool down on OTP issue, with a generic "check your inbox" reply that does not reveal whether an account exists.
- Refresh token rotation with a server side store so sign out and password change revoke old tokens.
- Move tokens to secure, HTTP only cookies with CSRF protection.
- Fix the onboarding buttons to call /approve and /reject.
- Single sign on through the company identity provider (OIDC).

6.4 Feature 2: Biometric Face Enrollment with ArcFace Embeddings of 512 Dimensions

dexa group

6.4.1 Feature analysis and business goals

Each operational user records one reference face. Every later clock in and clock out photo is compared 1:1 with that reference, which stops one person from clocking in for another.

6.4.2 User and operational assumptions

- A working webcam, even front lighting and exactly one face in frame.
- The buffalo_l model files exist in the host folder ~/.insightface, which the container mounts read only.
- The System Admin never enrolls (separation of duties).
- Two active employees must not share one face. A face that resembles another active employee is refused unless HR has granted that employee a sibling exemption.

6.4.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	FaceEnrollmentPage (route /auth/enroll-face), redirect in ProtectedRoute when isFaceEnrolled is false	frontend/src/pages/auth/FaceEnrollmentPage .tsx

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

Frontend	Conflict card on FaceEnrollmentPage for HTTP 409; Sibling Biometric Exemption switch in the edit form of MasterEmployeesPage	frontend/src/pages/auth/, pages/hrd/MasterEmployeesPage.tsx
Gateway	EmployeesController.enrollMyFace on POST /api/employees/me/enroll-face; BiometricClientService.extractEmbedding; persistAvatarFile	api-gateway/src/employee/, api-gateway/src/biometric/
Gateway	EmployeesController.toggleSiblingExemption on PATCH /api/employees/:id/sibling-exemption (HR_ADMIN)	api-gateway/src/employee/employees.controller.ts
FastAPI	POST /extract-embedding, FaceBiometricService.extract	biometric-service/main.py, service.py
TCP	employee.enroll_face	employee-service/src/employees/employees.service.ts
Service	EmployeesService.enrollFace, checkDuplicateFace (three tiers), toggleSiblingExemption	employee-service/src/employees/employees.service.ts
Database	employees.face_embedding (JSON), face_enrolled_at, face_enrolled_photo_url, is_sibling_exempt, sibling_exempt_reason, sibling_exempt_approved_by	libs/common/src/entities/employee.entity.ts

dexa group

6.4.4 End to end technical flow

1. After sign in, ProtectedRoute sends any user with an employee record and no face (except the System Admin) to /auth/enroll-face. isFaceEnrolled is true only when face_embedding is an array of 512 numbers.
2. The page streams the webcam inside an oval guide, captures a JPEG at quality 0.95 and posts it as the multipart field photo.
3. The gateway calls POST /extract-embedding. Anything other than SUCCESS with exactly one face returns 422 with a where, what and why message.
4. The gateway saves the photo as avatar_<person>_<date>_<time>.jpg in the folder tree and sends TCP employee.enroll_face with the vector and the photo URL.
5. The employee service checks that the vector holds 512 numbers, then runs checkDuplicateFace against the stored vector of every other active employee and keeps the closest match.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6. Below a cosine similarity of 0.50 the face counts as unique.
7. From 0.50 up to 0.90 the face counts as a possible sibling or twin. Without an exemption the service returns 409 Biometric conflict detected, naming the closest employee, their NIP and the percentage. When HR has set is_sibling_exempt, the service logs SIBLING_EXEMPTION_APPLIED with the approver and continues.
8. At 0.90 or above the service returns 409 Duplicate face registration blocked, whatever the exemption says, because it treats the capture as the same face registered twice.
9. A face that passes is stored in employees.face_embedding with the enrollment time and photo URL.
10. The SPA refreshes the profile and opens /employee/attendance.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

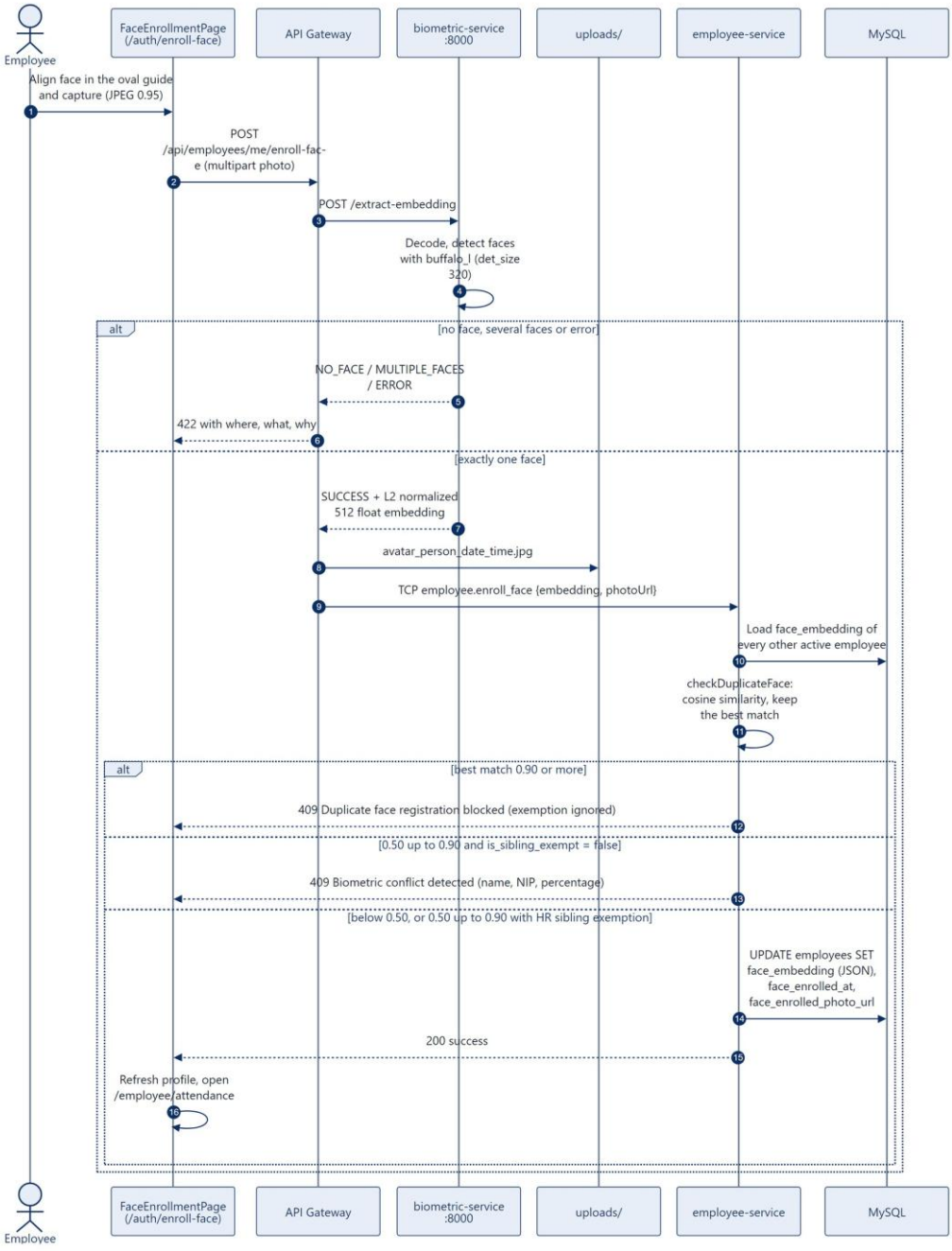


Figure 6.2: *Face enrollment from webcam capture to the JSON vector in MySQL.*

6.4.5 Scope and current technical limitations

- One reference image. No multi angle enrollment or template averaging.
- There is no liveness challenge on the enrollment page.
- Enrolling again is self service and overwrites the old vector without HR approval.
- The duplicate check loops over every active employee in Node. That suits a few thousand staff, not a very large workforce.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- The thresholds 0.50 and 0.90 are constants in the code. Deactivated employees are left out of the comparison, so reactivating one can create a pair of matching faces.
- The vector is plain JSON in MySQL, not encrypted at rest.
- On a cold start the model load can exceed the gateway's 10 second timeout, so the very first request after boot may fail and succeed on retry.

6.4.6 Future improvements

- Capture three angles and average the vectors for a steadier reference.
- Require liveness during enrollment and HR approval for any later change.
- Encrypt face_embedding at rest with a key held outside the database.
- Add a readiness endpoint on the biometric service so the gateway waits for the model instead of timing out.
- Move the one to many search into a vector index (for example pgvector or FAISS) and make both thresholds configurable per company.

6.5 Feature 3: Daily WFH Notice, Upward Escalation and Biometric Clock In

dexa group

6.5.1 Feature analysis and business goals

Remote attendance is tied to an explicit WFH arrangement for the day that the approver can see. Only then does the system check identity and record the start of work with server time and a watermarked photo.

Upward escalation answers a gap found in research: managers whose own WFH days nobody above them reviews. A manager's request goes to HR, with the System Admin in copy.

6.5.2 User and operational assumptions

- The company default is work from office. WFH is an exception limited by a weekly quota (1 day by default, configurable 1 to 5).
- Each department has a manager email and an HR PIC email in departments. Defaults are used when they are missing.
- The user has enrolled a face.
- Policy mode is either STRICT_APPROVAL (a reviewer must approve) or NOTICE_ONLY (the request is approved at once).

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.5.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	EmployeeAttendancePage, LeaveAndCorrectionModal, CameraPhotoUpload (liveness, watermark)	frontend/src/pages/employee/, components/custom/
Gateway	AttendanceController.createRequest, verifyFacePreview, clockIn; persistPhotoProof	api-gateway/src/attendance/attendance.controller.ts
TCP	attendance_request.create, attendance.verify_face_preview, attendance.clock_in	attendance-service/src/attendance-service.controller.ts
Service	AttendanceRequestsService.create (quota, routing, email), AttendanceService.clockIn, evaluateClockIn	attendance-service/src/requests/, attendance/, libs/common/src/utils/attendance-rules.ts
Location	ProfilePage handleSetHomeFromDeviceGps with PATCH /api/employees/me/profile; calculateHaversineDistanceMeters; reverseGeocodeCoordinates (OpenStreetMap Nominatim)	frontend/src/pages/ProfilePage.tsx, libs/common/src/utils/attendance-rules.ts, reverse-geocoding.util.ts

dexa group

6.5.4 End to end technical flow

1. The user opens the WFH form. The SPA posts requestType: WFH_APPROVAL to POST /api/attendance-requests.
2. The attendance service rejects a second pending or approved WFH request for the same date, and rejects the request if the ISO week (Monday to Sunday) already holds max_wfh_days_per_week requests.
3. The request is saved as PENDING, or as APPROVED in NOTICE_ONLY mode.
4. Email routing: from an EMPLOYEE or HR_ADMIN, To the department manager, Cc the HR PIC and the sender. From a MANAGER or SYSTEM_ADMIN, To the HR PIC (admin.hrd@dexagroup.com), Cc sysadmin@dexagroup.com, the HR PIC and the sender. Reply To is the submitter. With SMTP_OVERRIDE_RECIPIENT set, the To address becomes the evaluation inbox, the Cc list is dropped and a banner names the intended recipients.
5. Once the request is approved, the attendance page unlocks. MediaPipe FaceLandmarker runs the liveness steps: align, identify, blink, turn left (yaw at most minus 14 degrees), turn right (yaw at least 14 degrees), hold front for 7 frames. It then captures automatically.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6. A preview frame goes to POST /api/attendances/verify-face-preview, and the service answers whether the face is recognized (similarity of 0.45 or more).
7. The Canvas burns a watermark into the pixels: a red DEXA GROUP WFH badge, a green biometric badge for live photos, the time in WIB, the NIP, name and department, and the copyright line.
8. The user writes the daily plan and submits POST /api/attendances/clock-in with the photo and metadata.
9. The gateway blocks the System Admin (403), extracts the vector, saves the photo with persistPhotoProof and sends TCP attendance.clock_in with the IP and user agent.
10. The service sets serverNow = new Date(), rejects a second clock in today (409), checks for an approved WFH request (403 otherwise), rejects duplicate photos, compares faces (422 below 0.45), applies the liveness gate (422 below 0.85 on the live method), records the timestamp result, and saves ON_TIME or LATE.
11. If the browser sent a location, the service measures the Haversine distance to the home location saved on the profile page, stores the distance and the street address from OpenStreetMap, and tags the session IN_HOME_RADIUS (100 meters or less) or OUT_OF_HOME_RADIUS. Without GPS or without a saved home location it tags LOCATION_UNAVAILABLE. Clock out records its own location the same way. The tag never blocks the request.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

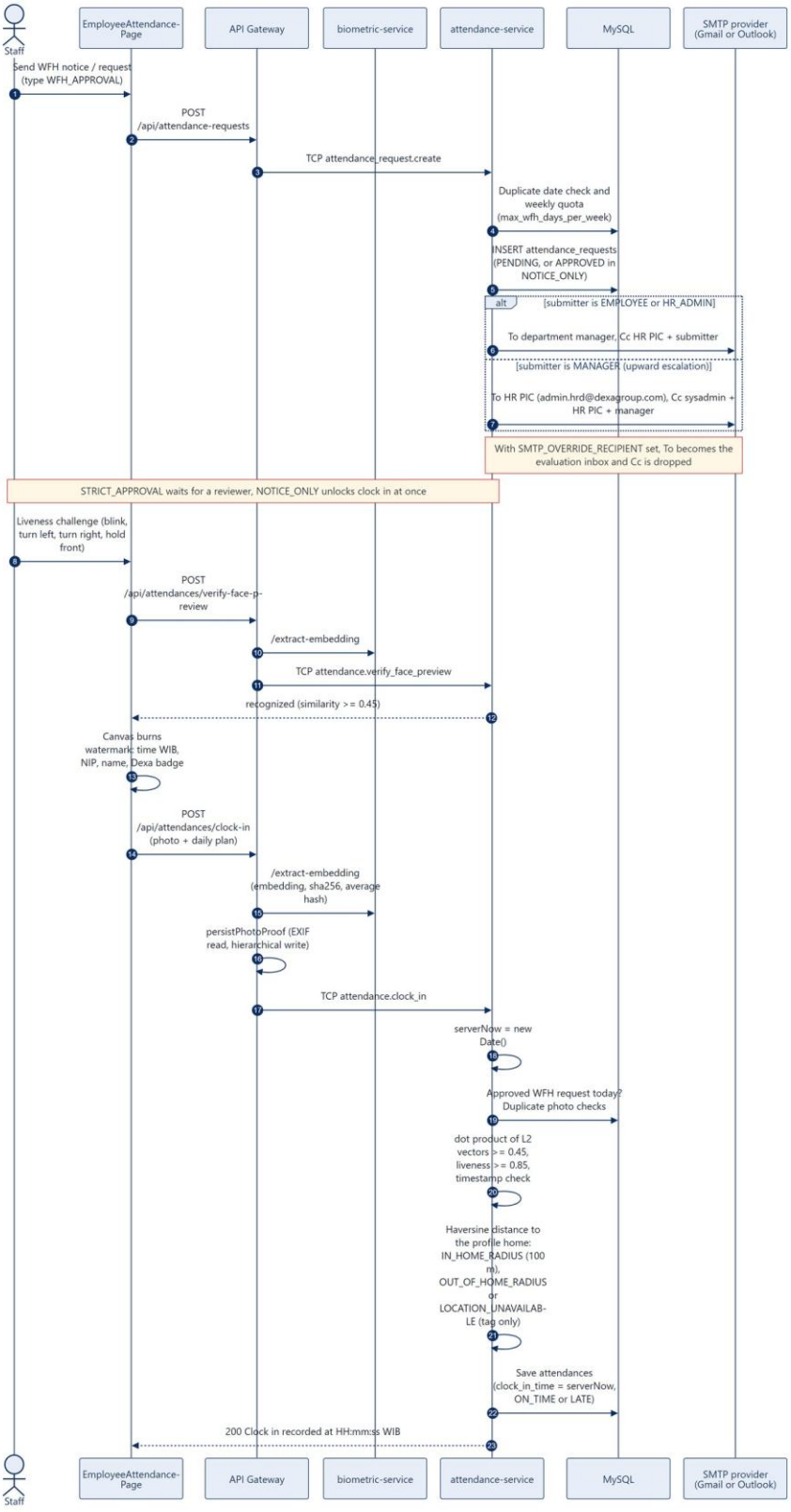


Figure 6.3: *WFH notice with upward escalation, liveness, watermarking and the biometric clock in.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.5.5 Scope and current technical limitations

- Liveness runs in the browser. The client currently sends livenessScore: 0.99 for every capture, so the server gate at 0.85 is not independent (defect D5).
- If the biometric service returns ERROR, clock in stores a default similarity of 0.92 without a comparison (defect D3).
- The daily plan is required in the form but optional in the backend DTO.
- The 100 meter home radius is informational. A clock in outside it is saved and tagged OUT_OF_HOME_RADIUS, although the profile page calls the rule strictly enforced (defect D14). The home location is whatever the employee saved from their own device.
- The date box in the notice form is filled with the UTC date, so between 00:00 and 07:00 WIB it suggests yesterday. A notice sent then is filed for the wrong day, uses the weekly quota and leaves clock in locked (defect D13).
- The watermark uses the device clock because of a field name mismatch in LiveServerClock (defect D6). The database time is still the server time.

6.5.6 Future improvements

- Server side liveness on a short video burst, so the score cannot be supplied by the client.
- Fail closed when the biometric service is unavailable, with a clear retry message.
- Use the server offset for the watermark by reading serverEpochMs.
- Let HR approve home locations and decide per department whether the radius should block a clock in.

dexa group

6.6 Feature 4: Authoritative Server Timestamp and Anti Clock Tampering

6.6.1 Feature analysis and business goals

The official attendance time must not depend on the user's device, so moving the laptop clock cannot turn a late arrival into an on time one. Photo times are still recorded, but only to judge whether the photo is fresh.

6.6.2 User and operational assumptions

- The server clock is synchronized with NTP. Services use WIB conversion explicitly and MySQL runs with TZ=Asia/Jakarta.
- Uploaded photos come from phones or cameras that write EXIF DateTimeOriginal.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.6.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Service	AttendanceService.clockIn and clockOut: const serverNow = new Date()	attendance-service/src/attendance/attendance.service.ts
Service	verifyPhotoTimestamp	attendance-service/src/attendance/attendance.service.ts
Gateway	persistPhotoProof, extractExifTimestamp (exif-parser)	api-gateway/src/storage/photo-metadata.util.ts
Gateway	GET /api/system/time (server clock for display)	api-gateway/src/system/system.controller.ts

6.6.4 End to end technical flow

1. clock_in_time and clock_out_time are set only from serverNow inside the attendance service. No client value is ever written to them.
2. The gateway resolves the photo time in order: EXIF DateTimeOriginal, then CreateDate, then ModifyDate, then the client's photoCapturedAt, then the server time. It is stored separately in clock_in_photo_captured_at or clock_out_photo_captured_at.
3. For a live webcam photo, the timestamp is verified when it is within 5 minutes of server time.
4. For an uploaded photo, it must be from the same WIB day, no more than 5 minutes in the future and no older than 12 hours.
5. The result goes to is_timestamp_verified (or is_clock_out_timestamp_verified). HR sees it in the lightbox and can filter the audit log with verified=true or false.
6. GET /api/system/time returns the server time, epoch and WIB strings for the header clock.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

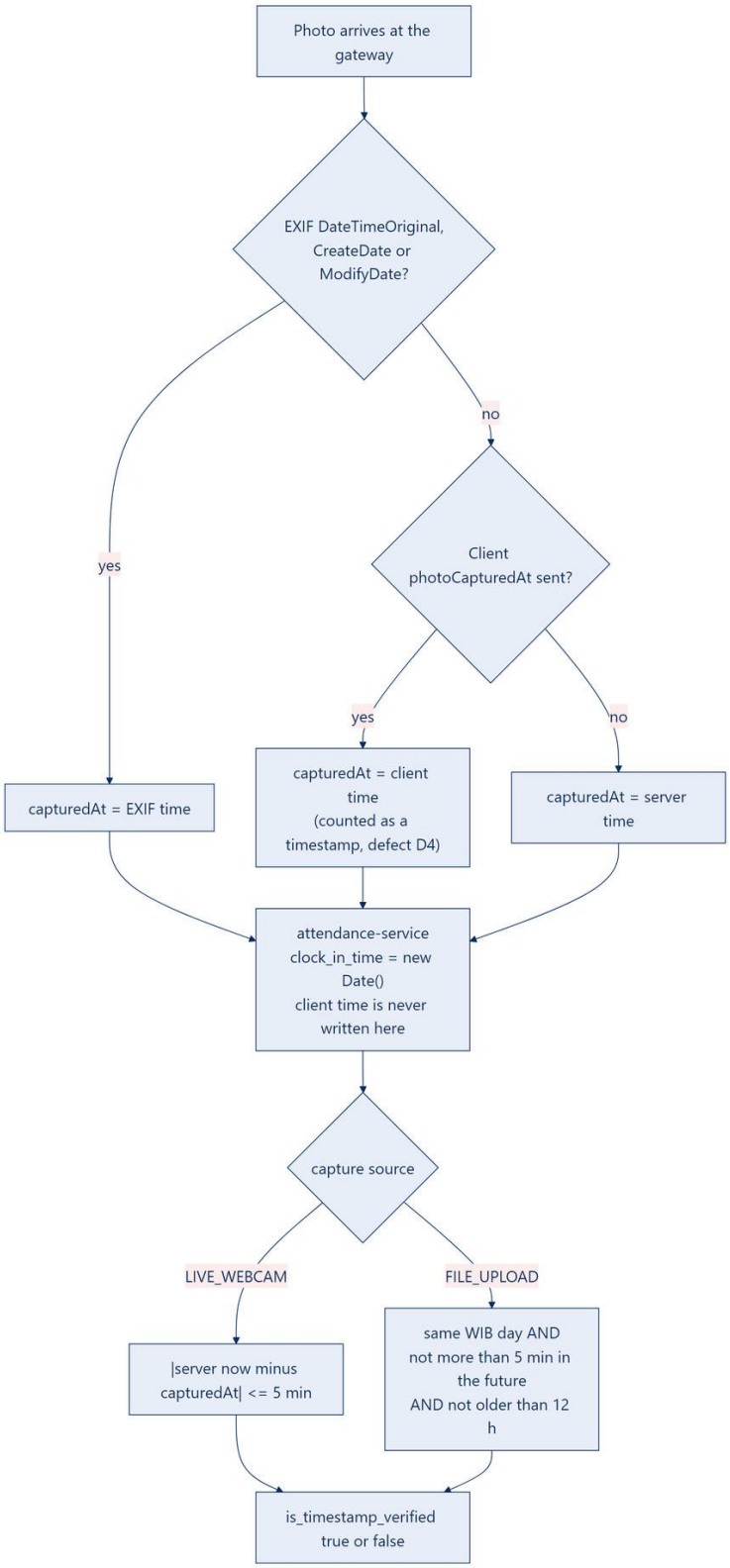


Figure 6.4: *Server time is always the official time. EXIF and client times only decide the verification flag.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.6.5 Scope and current technical limitations

- Request arrival is the official time, so a slow upload can record a time a few seconds after the user pressed capture.
- When the client sends photoCapturedAt, the gateway treats it as a timestamp even without EXIF data, so an upload can pass with a client supplied time (defect D4). In practice the portal always redraws the photo on a canvas, which removes the EXIF data, so uploads from the portal are judged on the time the browser sends (the file's last modified time).
- The header clock shows device time because of defect D6.

6.6.6 Future improvements

- Count only real EXIF data as a timestamp for uploads.
- Fix the header clock to apply the server offset.
- Record the time the capture button was pressed, signed by a short lived server nonce, to measure upload delay.

dexa group

6.7 Feature 5: Clock Out, Working Duration, Punctuality and 1/173 Overtime

6.7.1 Feature analysis and business goals

Each day closes with a written accomplishment and a proof photo. The system then computes everything payroll needs (duration, status, overtime minutes and overtime pay) the same way every time.

6.7.2 User and operational assumptions

- One standard schedule: start 08:30 WIB with a 15 minute grace period and a 9 hour span (540 minutes).
- Overtime pay follows the Indonesian 1/173 hourly rate (PP No. 35/2021): 1.5x for the first hour and 2x after that.
- HR keeps base_salary current (default IDR 12,000,000).
- Overtime is on when the company policy enable_overtime is true.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.7.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Gateway	AttendanceController.clockOut on POST /api/attendances/clock-out	api-gateway/src/attendance/attendance.controller.ts
TCP	attendance.clock_out	attendance-service/src/attendance-service.controller.ts
Rules	evaluateClockIn, evaluateClockOut, calculateOvertimeAndPay	libs/common/src/utils/attendance-rules.ts
DTO	ClockOutDto (dailyAccomplishment at least 10 characters)	libs/common/src/dto/attendance.dto.ts

6.7.4 End to end technical flow

1. The employee writes the daily accomplishment, captures a photo and submits POST /api/attendances/clock-out.
2. The gateway blocks the System Admin, extracts the vector, saves the photo with the clock-out prefix and sends TCP attendance.clock_out.
3. The service needs today's record with a clock in (400 otherwise) and no earlier clock out (409).
4. clock_out_time is set to new Date(). The face must match at 0.45 or more (422 otherwise).
5. Duration is the whole minutes between clock in and clock out. There is no break deduction. Below 240 minutes the status is HALF_DAY, otherwise COMPLETED.
6. Overtime minutes are duration minus 540, kept only if 30 or more. If overtime is enabled, the service computes the pay and keeps the larger of this value and any value set by an approved overtime request.
7. The response reads "Clock Out recorded at HH:mm:ss WIB" with hours worked and any overtime pay in Rupiah.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

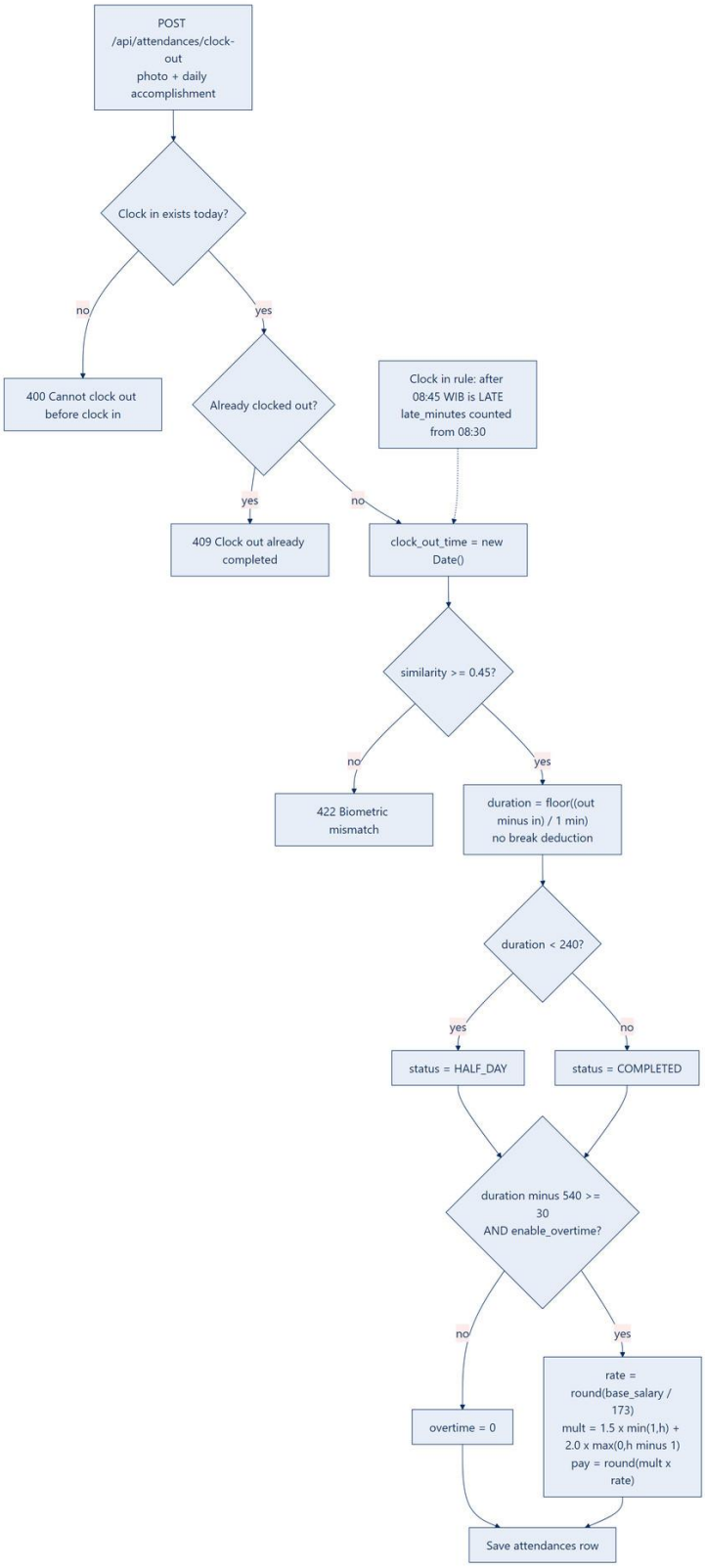


Figure 6.5: *Clock out checks, duration, status and the 1/173 overtime calculation.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.7.5 Scope and current technical limitations

- Overtime starts after 540 minutes of work, not at 17:30 on the wall clock. A late starter must stay later before overtime counts.
- Clock out replaces ON_TIME or LATE with COMPLETED or HALF_DAY. Lateness stays visible in late_minutes.
- No weekend or public holiday multipliers.
- Missing clock outs are marked MISSING_CLOCK_OUT only when data is next read. There is no scheduler.

6.7.6 Future improvements

- Shift templates per department so start time, span and break rules can differ.
- Holiday calendar with the rest day multipliers from PP No. 35/2021.
- A nightly job that closes missing clock outs and notifies the employee.
- An optional break deduction setting for companies that need it.

6.7.7 Formulas used by the code

```
is_late       = clock_in_minutes > 08:30 + grace (15)
late_minutes  = is_late ? clock_in_minutes - 08:30 : 0
duration      = floor((clock_out - clock_in) / 60 000 ms)
status        = duration < 240 ? HALF_DAY : COMPLETED
overtime_min  = (duration - 540) >= 30 ? duration - 540 : 0
hourly_rate   = round(base_salary / 173)
mult_hours    = 1.5 * min(1, h) + 2.0 * max(0, h - 1)     where h = overtime_min / 60
overtime_pay  = round(mult_hours * hourly_rate)
```

Worked example: base salary IDR 12,000,000, clock in 08:30, clock out 20:00. Duration is 690 minutes, overtime is 150 minutes, the hourly rate is IDR 69,364, the multiplier hours are 1.5 + 2.0 x 1.5 = 4.5, and the overtime pay is **IDR 312,138**. With the defaults, a clock in at 08:45 is on time and one at 08:46 is late by 16 minutes, because late minutes count from 08:30.

6.8 Feature 6: Leave, Sick, Overtime and Correction Requests with Direct Links

6.8.1 Feature analysis and business goals

One request pipeline replaces scattered emails and spreadsheets. Every request is auditable, and an approval updates the official attendance record automatically.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.8.2 User and operational assumptions

- The approver has a portal account. The email link relies on the normal sign in, not on an anonymous token.
- A supporting document is optional (a doctor's note, a VPN log).

6.8.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	LeaveAndCorrectionModal, ManagerApprovalsPage (reads ?requestId=)	frontend/src/components/custom/, pages/manager/
Gateway	createRequest, myRequests, findRequests, reviewRequest; persistAttachmentFile	api-gateway/src/attendance/attendance.controller.ts
TCP	attendance_request.create, .my, .find_all, .review	attendance-service/src/attendance-service.controller.ts
Service	AttendanceRequestsService.create, review, syncApprovedRequestToAttendance	attendance-service/src/requests/attendance-requests.service.ts

dexa group

6.8.4 End to end technical flow

1. The employee picks a type (WFH_APPROVAL, OVERTIME, CORRECTION, LEAVE or SICK), a date, a reason and an optional attachment (image or PDF, 8 MB at most) and submits POST /api/attendance-requests.
2. The service checks the reason (at least 10 characters). A correction needs at least one time and a clock out after the clock in. Overtime needs the policy enabled and gets an estimated pay.
3. The request is saved as PENDING with the resolved manager email and Cc list.
4. The email carries a button to http://localhost:5173/manager/approvals?requestId=<uuid>.
5. With SMTP_OVERRIDE_RECIPIENT set, the attendance service sends the email to that inbox instead, drops the Cc list and adds a banner naming the intended recipients.
6. The approver clicks it, signs in if needed, and the approval page opens that request in a review modal. Approve or reject sends PATCH /api/attendance-requests/:id/review. A note is required to reject.
7. A manager can only review their own department (403 otherwise), and only pending requests can be reviewed (400 otherwise).
8. On approval the service upserts attendances for the employee and date. WFH sets wfh_approved. Leave sets ON_LEAVE. Sick sets SICK. Overtime recomputes overtime

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

pay. A correction sets the requested times and recomputes status, late minutes, duration and overtime with the same rules as a live clock in and clock out.

9. A decision email goes to the employee, with the manager and HR in copy.

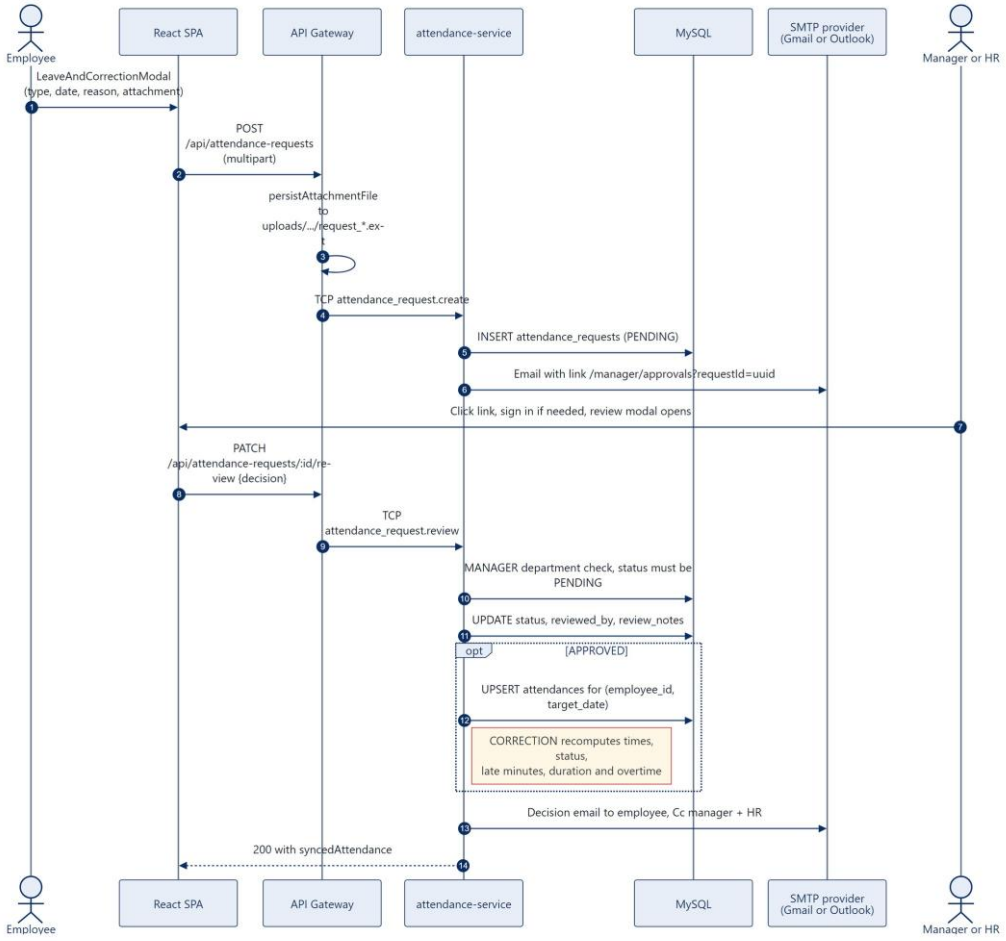


Figure 6.6: *Request submission, the direct review link and the automatic attendance update.*

6.8.5 Scope and current technical limitations

- The link is not signed. It carries the request ID, and security comes from the sign in and the department check. The host is fixed to http://localhost:5173.
- There is no leave balance ledger.
- email_dispatched now records the real result of the send. When SMTP_FROM carries a display name, the sender of request emails reads "Name (via Dexa WFH)>" with a stray bracket (defect D16).
- An approved correction marks the timestamp as verified, even though the times were typed by the employee.
- The request form fills its date with the UTC date, so before 07:00 WIB it suggests yesterday (defect D13).

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.8.6 Future improvements

- Signed, single use review links with an expiry, for one click approval from a phone.
- A leave entitlement ledger that debits approved leave days.
- Retry failed sends from a queue.
- Read the portal host from configuration.

6.9 Feature 7: Master Employee Management, Mandatory NIP and Soft Delete

6.9.1 Feature analysis and business goals

HR keeps one authoritative staff directory. Removing someone must never destroy the attendance history that payroll and audits rely on, so deletion is always a soft delete.

6.9.2 User and operational assumptions

- HR assigns NIPs, and each NIP is unique in the company.
- A deactivated employee must not sign in or clock in, but their records must stay searchable and exportable.

dexa group

6.9.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	MasterEmployeesPage (route /hrd/employees)	frontend/src/pages/hrd/MasterEmployeesPage.tsx
Gateway	EmployeesController: findAll, findOne, create, update, softDelete, restore, resendOtp	api-gateway/src/employee/employees.controller.ts
TCP	employee.find_all, .create, .update, .soft_delete, .restore, .resend_verification	employee-service/src/employee-service.controller.ts
Service	EmployeesService.create (transaction), softDelete, restore	employee-service/src/employees/employees.service.ts
DTO	CreateEmployeeDto (NIP pattern ^[A-Z0-9-]{3,50}$)	libs/common/src/dto/employee.dto.ts

6.9.4 End to end technical flow

1. HR opens /hrd/employees, which loads GET /api/employees?limit=100 with search, department, status, role and includeInactive filters.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

2. Create: the NIP is required in the form, checked by the DTO pattern, rejected with 400 when empty and 409 when taken (unique index UQ_employees_code). The email must also be unique. The phone field starts at +62 and the base salary at IDR 12,000,000.
3. The user and employee rows are created in one transaction, and a verification OTP is emailed.
4. Update PATCH /api/employees/:id changes profile, salary, status (ACTIVE or ON_LEAVE) and role, which is copied to users.role.
5. Soft delete DELETE /api/employees/:id sets employees.is_active = false, status = INACTIVE, deleted_at = NOW() and users.is_active = false. No SQL DELETE runs. HR cannot deactivate their own account.
6. Restore PATCH /api/employees/:id/restore reverses every field.
7. History stays intact because attendances and attendance_requests reference employees with ON DELETE RESTRICT, and audit queries use withDeleted.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

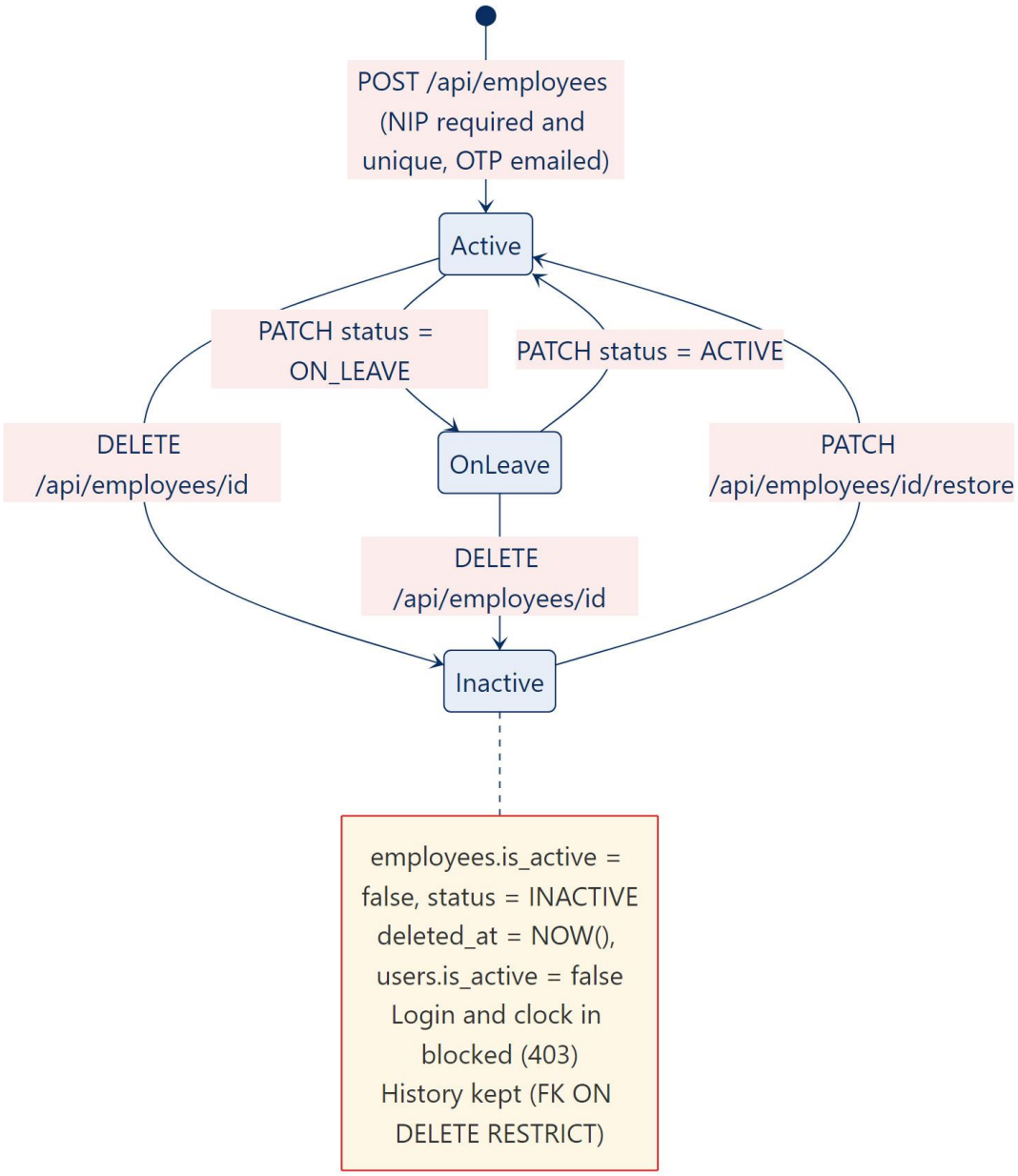


Figure 6.7: *Employee life cycle with soft delete and restore.*

6.9.5 Scope and current technical limitations

- The Database Studio can hard delete rows and bypass soft delete (foreign keys still block employees with attendance).
- No bulk import.
- The department is stored as a name on the employee, so renaming a department means updating employees.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.9.6 Future improvements

- CSV or XLSX bulk import with a dry run report.
- Use department_id as the single source for routing and reporting.
- An audit trail of who changed which employee field and when.

6.10 Feature 8: Dual Dashboards and the Photo Lightbox

6.10.1 Feature analysis and business goals

HR gets a company wide picture of the day with a path down to each photo. Each employee gets a personal view of their own punctuality and hours.

6.10.2 User and operational assumptions

- "Real time" means fresh data on page load and refresh. There is no push channel.
- An employee counts as present when they have a clock in and are not on leave or sick.

6.10.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	HrdDashboardPage, AttendanceMonitoringPage, PhotoLightboxModal, EmployeeDashboardPage	frontend/src/pages/hrd/, pages/employee/
Frontend	AttendanceLocationMapModal (Leaflet with OpenStreetMap tiles, clock in, clock out and home pins, 100 meter circle) opened from the Map button of each audit row	frontend/src/components/custom/AttendanceLocationMapModal.tsx
Gateway	GET /api/attendances/summary, GET /api/attendances, GET /api/attendances/my-dashboard	api-gateway/src/attendance/attendance.controller.ts
TCP	attendance.summary, attendance.find_all, attendance.my_dashboard	attendance-service/src/attendance-service.controller.ts
Service	getSummary, buildFilteredQuery, getMyDashboard	attendance-service/src/attendance/attendance.service.ts

dexa group

6.10.4 End to end technical flow

1. HRD dashboard: GET /api/attendances/summary?date= loads active employees and the day's rows and aggregates them in the service. Six KPI cards (active employees, present, on

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

time, late, on leave or sick, timestamp audit), a department breakdown, a 7 day trend and a recent photo feed. Managers see only their department.

2. Monitoring and audit log: GET /api/attendances with date range, department, status, verified flag and search (name, NIP, email, plan, accomplishment). It uses a TypeORM QueryBuilder with a left join on the employee, bound parameters and pagination.
3. Clicking a thumbnail opens the lightbox: clock in and clock out photos with their burned in watermarks, server time and capture time for each, the timestamp verification banner, daily plan, accomplishment, duration, late minutes, IP and device.
4. Employee dashboard: GET /api/attendances/my-dashboard returns the punctuality score, average hours against the 8.0 hour target, overtime pay and minutes, weekly WFH quota, today's status, a 14 day duration bar chart built from div bars with a dashed 8.0 hour line, the punctuality split and recent sessions and requests.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

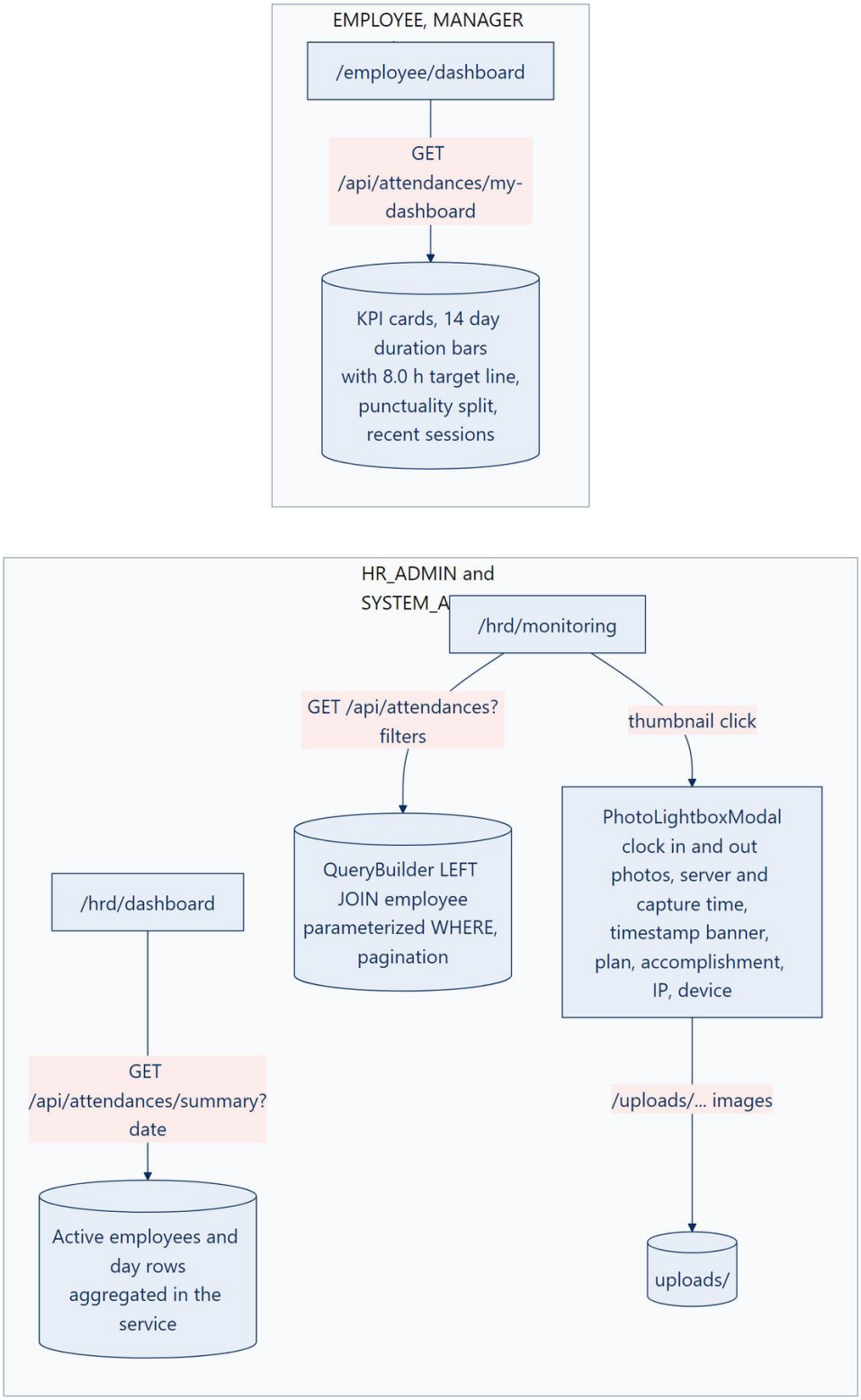


Figure 6.8: *HR monitoring with the lightbox, next to the personal employee dashboard.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.10.5 Scope and current technical limitations

- Aggregation happens in Node memory, not with SQL GROUP BY. Fine at assessment scale, not for very large data.
- The lightbox does not show the similarity score, liveness score or perceptual hash, although all are stored. Location has its own map window.
- Without a saved home location the map window says No Clock In GPS submitted, even when coordinates were saved (defect D15).
- The audit page fetches up to 100 rows per page.

6.10.6 Future improvements

- Move the summary aggregation into SQL or a daily summary table.
- Show similarity and liveness scores in the lightbox for HR.
- Live updates through server sent events during the morning clock in window.

6.11 Feature 9: XLSX, CSV and Printable Export

6.11.1 Feature analysis and business goals

HR and payroll get the same filtered data they see on screen, in formats their tools already read, including overtime pay, with no retyping.

dexa group

6.11.2 User and operational assumptions

- Exports stay below 5,000 rows.
- Excel, Google Sheets and payroll importers are the consumers.

6.11.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	Export .XLSX, Export .CSV and Print / PDF buttons on AttendanceMonitoringPage	frontend/src/pages/hrd/AttendanceMonitoringPage.tsx
Gateway	GET /api/attendances/export (sets Content-Disposition and X-Export-Row-Count)	api-gateway/src/attendance/attendance.controller.ts
TCP	attendance.export	attendance-service/src/attendance-service.controller.ts
Service	ExportService.export with ExcelJS	attendance-service/src/export/export.service.ts

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.11.4 End to end technical flow

1. HR sets filters and clicks Excel or CSV. The SPA calls GET /api/attendances/export?format=xlsx|csv with the same filters (HR_ADMIN, MANAGER or SYSTEM_ADMIN; managers limited to their department).
2. The service reuses buildFilteredQuery with take(5000) and builds an ExcelJS workbook, sheet "WFH Attendance & Payroll Recap", with 22 columns from NIP and name through duration, overtime minutes, multiplier hours, overtime pay, late minutes, status, photo source, timestamp check, plan and accomplishment. The header row is bold white on blue, and a copyright row closes the sheet.
3. CSV comes from the same workbook through the ExcelJS CSV writer.
4. The file is base64 encoded and returned over TCP. The gateway decodes it and sends Dexa_WFH_Attendance_Payroll_Report_<date>.<ext>.
5. For PDF, the page calls window.print(). The print stylesheet hides navigation, and the browser saves the view as a PDF.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

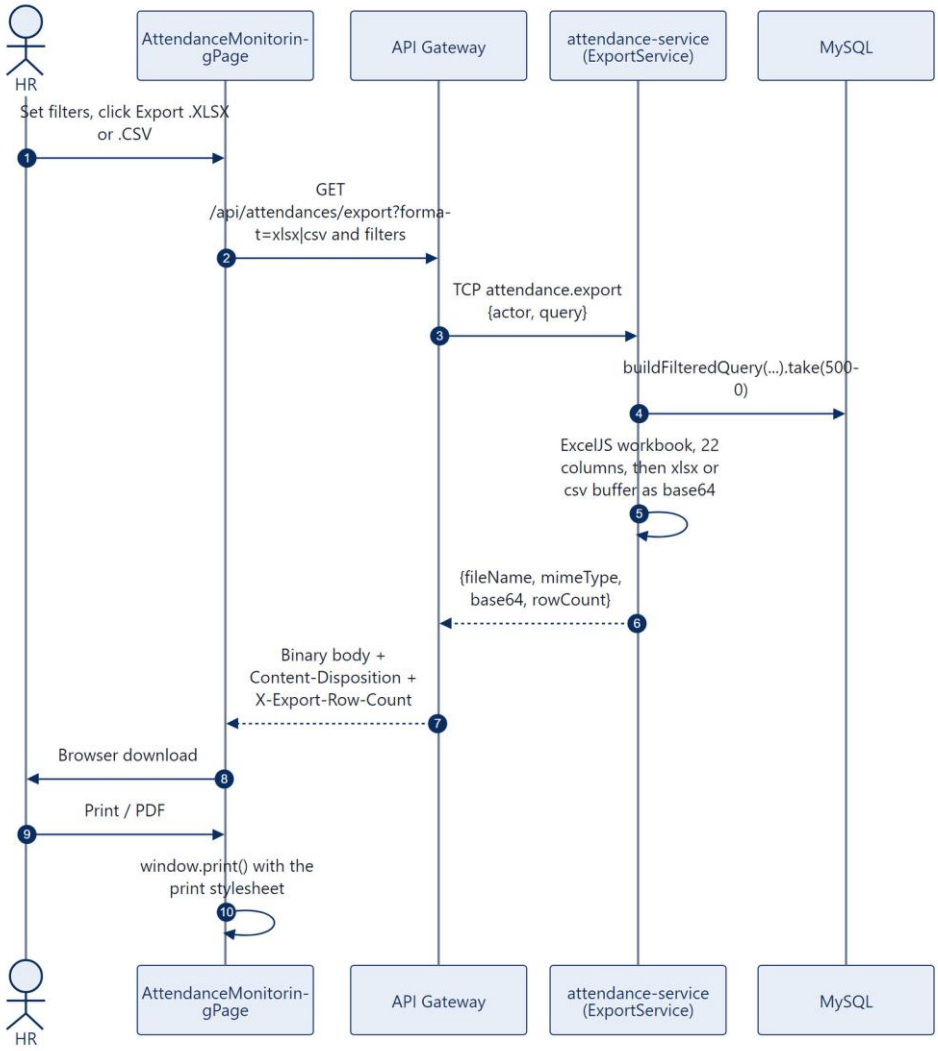


Figure 6.9: *One filtered dataset exported as XLSX, CSV or a printable page.*

6.11.5 Scope and current technical limitations

- Not a true stream: the file is built in memory and travels as base64 over TCP (about a third larger).
- Capped at 5,000 rows. No totals row or per employee subtotals.
- PDF depends on the browser print engine.

6.11.6 Future improvements

- Stream large exports from the gateway with ExcelJS streaming writers.
- Add a totals sheet per employee for payroll cut off.
- Server generated PDF with a fixed layout and signature block.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.12 Feature 10: Hierarchical File Storage

6.12.1 Feature analysis and business goals

Evidence files should be easy for a person to browse and for an auditor to trace, instead of one flat folder of random names.

6.12.2 User and operational assumptions

- One node with a local or bind mounted disk (./uploads to /app/uploads).

6.12.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Gateway	buildOrganizedDirectory, buildOrganizedFilename, resolveRoleFolder, slugify	api-gateway/src/storage/photo-metadata.util.ts
Gateway	persistPhotoProof, persistAttachmentFile, persistAvatarFile	same file
Gateway	Static serving of /uploads	api-gateway/src/main.ts

dexa group

6.12.4 End to end technical flow

1. Uploads arrive in memory (Multer memoryStorage).
2. The department and full name are turned into slugs: lower case, accents removed, other characters replaced.
3. resolveRoleFolder returns manager for MANAGER, HR_ADMIN and SYSTEM_ADMIN, and employee for everyone else.
4. The folder is uploads/<year>/<department>/<role folder>/<person>/<MM-monthname>/.
5. The name is <prefix>_<person>_<YYYY-MM-DD>_<HH-mm-ss>.<ext> with the prefix clock-in, clock-out, request or avatar. A clash in the same second adds a random 3 digit suffix.
6. The file is written, and the URL /uploads/... is stored in the database and served by the gateway through nginx.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

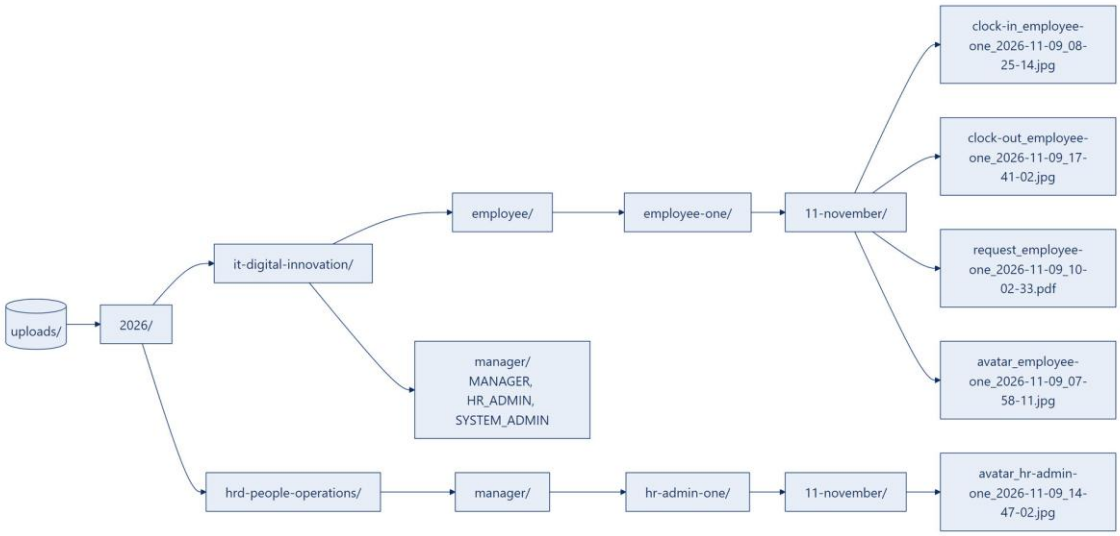


Figure 6.10: *The storage tree, with the real enrollment file from the installation test run.*

6.12.5 Scope and current technical limitations

- Year, month and time in the path come from the container clock (UTC in Docker), so names can read 7 hours behind WIB (defect D11).
- /uploads is served without authentication. Anyone with a URL can open the image (defect D10).
- Local disk only. No retention policy.

dexa group

6.12.6 Future improvements

- An S3 compatible adapter (S3, GCS or MinIO) that keeps the same key hierarchy and serves files through pre signed URLs.
- Build folder and file names from WIB.
- Retention rules per file type, for example deleting raw photos after the payroll period closes.

6.13 Feature 11: Database Studio

6.13.1 Feature analysis and business goals

The platform custodian can inspect and repair data during evaluation inside the portal, without opening a separate SQL client.

6.13.2 User and operational assumptions

- The operator understands the schema and what deleting a row means.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- Only the nine application tables are in scope.

6.13.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	SystemDatabaseManagementPage (route /system/database)	frontend/src/pages/system/
Gateway	DatabaseManagementController: tables, rows, row, insert, update, delete	api-gateway/src/database-management/
TCP	database.get_tables, .get_rows, .get_row, .insert_row, .update_row, .delete_row	employee-service/src/database-management/

6.13.4 End to end technical flow

1. GET /api/system/database/tables returns, for each whitelisted table (users, employees, departments, attendances, attendance_requests, access_requests, otp_codes, support_tickets, system_settings), its display name, primary key, live row count and column metadata.
2. GET /api/system/database/:table pages through rows (limit at most 100) with search across text columns and sorting on known columns. password_hash comes back masked.
3. Insert, update and delete work on one row at a time. A new users row hashes its password with bcrypt. Primary keys cannot change.
4. Delete is a hard delete. A foreign key violation returns 409.
5. The page can export the current table view to CSV in the browser.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

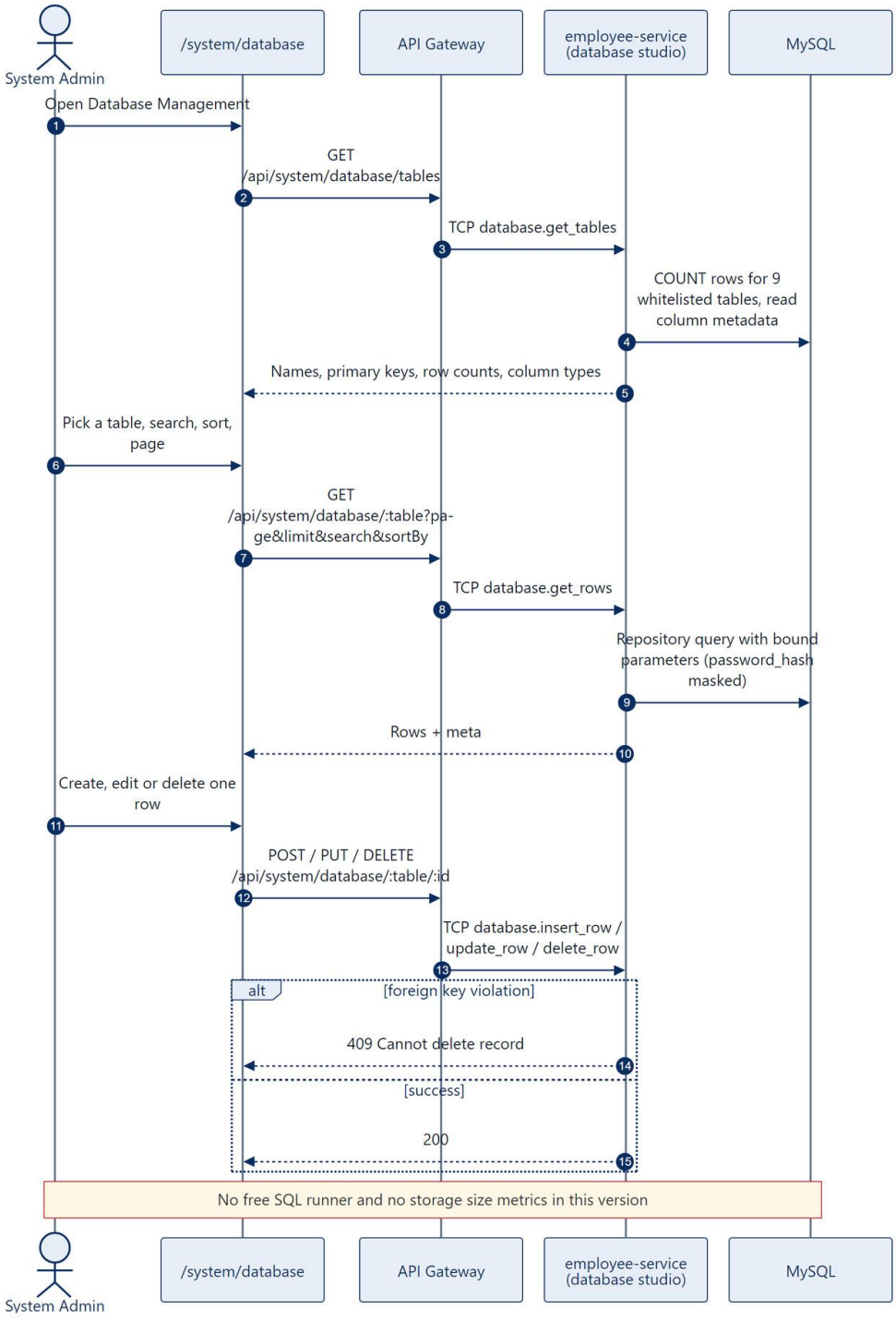


Figure 6.11: *Database Studio requests from the browser to the whitelisted repositories.*

6.13.5 Scope and current technical limitations

- There is **no free SQL runner and no storage size metric**. Every operation goes through TypeORM repositories with bound parameters.
- No log of who changed which row.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- HR admins can reach the page and the API because of defect D1.

6.13.6 Future improvements

- Enforce SYSTEM_ADMIN only access in both RolesGuard and ProtectedRoute.
- A read only SQL console with a statement timeout and an allow list, if custom queries are really needed.
- Table size and index size from information_schema.
- An audit log of every write.

6.14 Feature 12: Developer Support with Targeted SMTP Routing

6.14.1 Feature analysis and business goals

Anyone can report a problem from any page. The report reaches the people who can fix it, and replies go straight back to the reporter.

6.14.2 User and operational assumptions

- At least one active System Admin exists. A fallback address is used if not.

dexa group

6.14.3 Codebase function and module breakdown

Layer	Function, route or pattern	File
Frontend	ContactDeveloperModal, opened from the header Support button	frontend/src/components/custom/ContactDeveloperModal.tsx
Gateway	SupportController: contactDeveloper, findTickets, resolve, sendTestEmail (POST /api/support/test-email, HR_ADMIN and SYSTEM_ADMIN)	api-gateway/src/support/
TCP	support.contact_developer, support.find_tickets, support.resolve, support.test_email	employee-service/src/support/
Mail	MailService.sendContactDeveloperEmail, sendOtpEmail, sendTestEmail, safeSend (override routing, Gmail and Outlook STARTTLS settings)	employee-service/src/mail/mail.service.ts

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.14.4 End to end technical flow

1. The Support button opens the modal. The sender shows read only as name and email. The user picks a category (ATTENDANCE_ISSUE by default, ACCOUNT_ACCESS, BUG, OTHER), a module, a subject (5 to 200 characters) and a message (10 to 4,000 characters).
2. The SPA posts POST /api/support/contact-developer, and the gateway sends TCP support.contact_developer.
3. The service saves a support_tickets row as OPEN.
4. Recipients: To every active SYSTEM_ADMIN (fallback sysadmin@dexagroup.com), Cc every active HR_ADMIN and the sender. When SMTP_FROM is set the email goes out From that address, with Reply To set to the user; otherwise From is the user. The body adds the role and NIP looked up on the server, and the ticket ID.
5. With SMTP_OVERRIDE_RECIPIENT set, the To address becomes the evaluation inbox and a banner names the intended recipient. The Cc list stays, so real SMTP reports the @dexagroup.com copies as undeliverable (defect D17).
6. After a successful send, email_delivered becomes true.
7. Admins see all tickets (latest 50) and others see their own through GET /api/support/tickets. HR resolves with PATCH /api/support/tickets/:id/resolve.
8. HR and System Admin can call POST /api/support/test-email to send a diagnostic email that reports the SMTP host, port, sender and final recipient.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

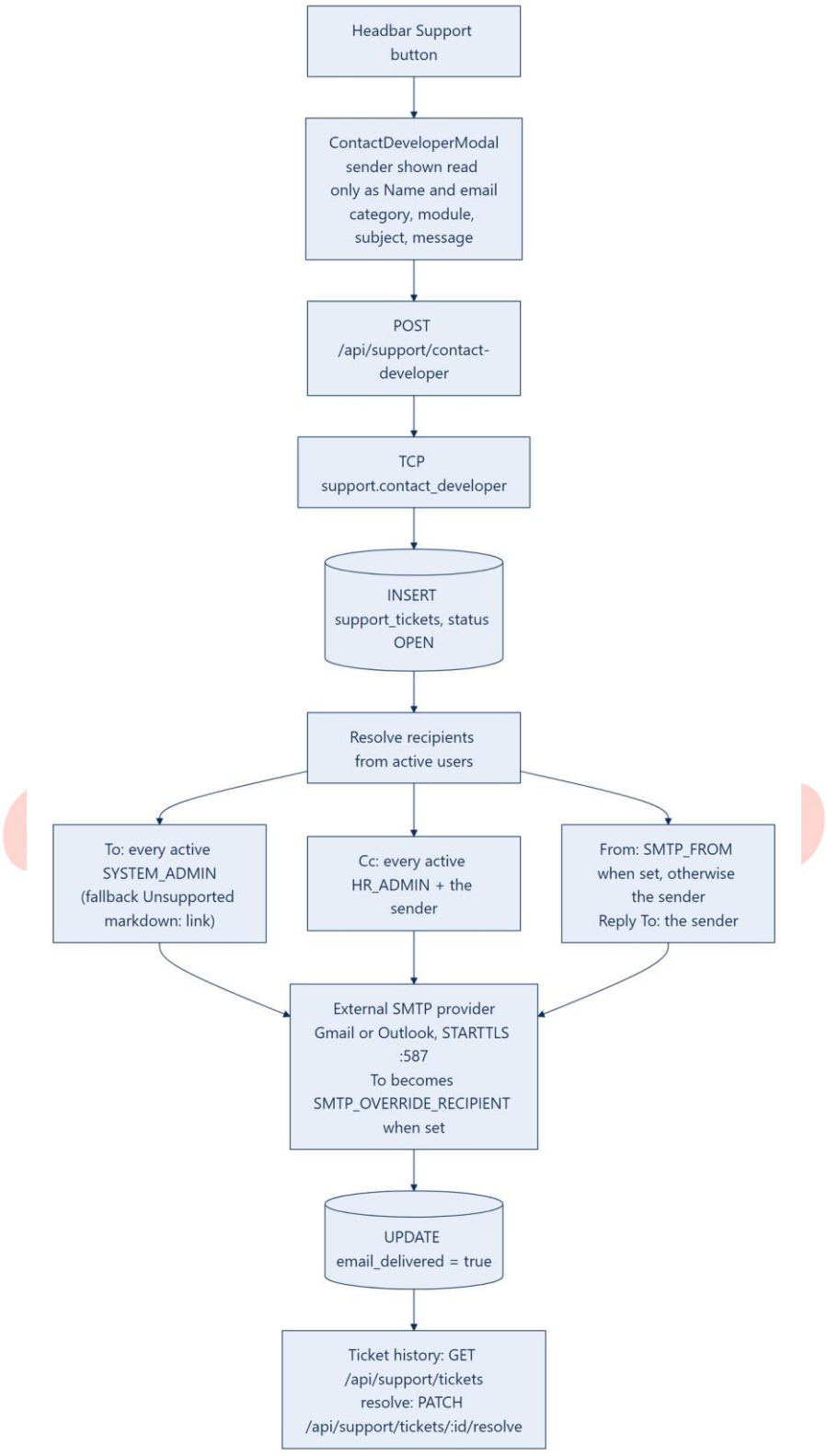


Figure 6.12: *Support ticket routing to System Admins, HR Admins and the sender.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

6.14.5 Scope and current technical limitations

- Gmail and Outlook rewrite or refuse a From address that is not the signed in SMTP account, so SMTP_FROM should use the account address.
- No threaded replies inside the app.
- DEVELOPER_SUPPORT_EMAIL is not used by the routing.

6.14.6 Future improvements

- OAuth2 sign in for Gmail and Microsoft 365 instead of app passwords.
- Ticket comments and status history inside the portal.
- Attach a screenshot and the last browser console errors automatically.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER VII
DATA ARCHITECTURE AND DATABASE SCHEMA

Nine TypeORM entities in libs/common/src/entities/ make up the schema. Every primary key is a UUID except system_settings, which holds one row with the ID DEFAULT.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

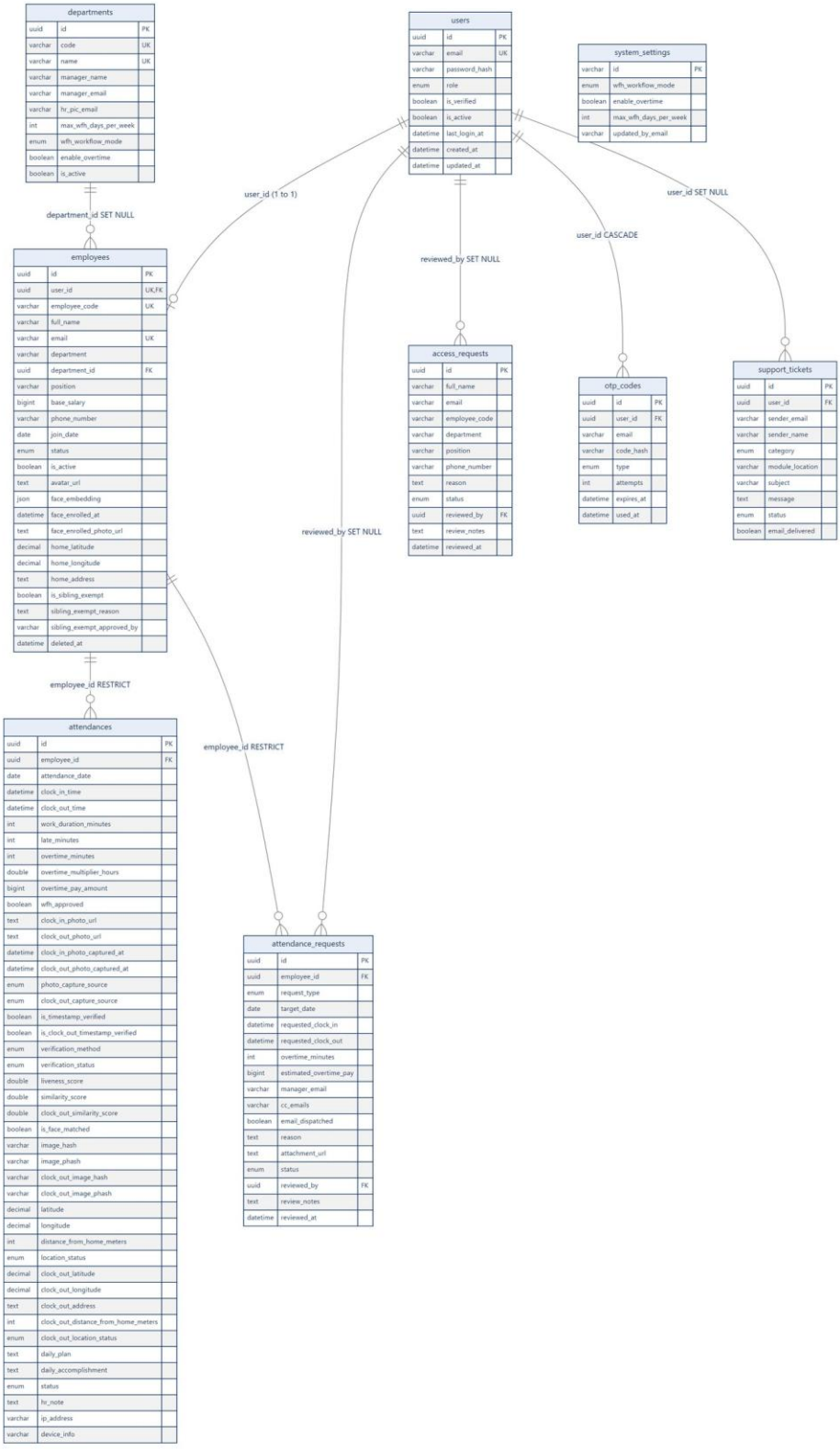


Figure 7.1: *Entity relationship diagram with every table, column, key and foreign key rule.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

7.1 users

Column	Type	Constraints and default
id	uuid	PK
email	varchar(150)	UNIQUE UQ_users_email
password_hash	varchar(255)	bcrypt, excluded from default selects
role	enum SYSTEM_ADMIN, HR_ADMIN, MANAGER, EMPLOYEE	default EMPLOYEE
is_verified	boolean	default false
is_active	boolean	default true
last_login_at	datetime	nullable
created_at, updated_at	datetime	automatic

7.2 employees

Column	Type	Constraints and default
id	uuid	PK
user_id	uuid	UNIQUE, FK to users.id (RESTRICT)
employee_code (NIP)	varchar(50)	UNIQUE UQ_employees_code, required
full_name	varchar(150)	
email	varchar(150)	UNIQUE UQ_employees_email
department	varchar(100)	index IDX_employees_department
department_id	uuid	nullable FK to departments.id (SET NULL)
position	varchar(100)	
base_salary	bigint	default 12,000,000
phone_number	varchar(30)	nullable
join_date	date	
status	enum ACTIVE, INACTIVE, ON_LEAVE	default ACTIVE, indexed

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

is_active	boolean	default true (soft delete flag)
avatar_url, face_enrolled_photo_url	text	nullable
face_embedding	json	nullable, 512 floats
face_enrolled_at	datetime	nullable
home_latitude, home_longitude, home_address	decimal(10,8), decimal(11,8), text	nullable
is_sibling_exempt, sibling_exempt_reason, sibling_exempt_approved_by	boolean, text, varchar(150)	default false; set by HR through the sibling exemption
created_at, updated_at	datetime	automatic
deleted_at	datetime	nullable, TypeORM @DeleteDateColumn

7.3 departments

dexa group

Column	Type	Constraints and default
id	uuid	PK
code	varchar(30)	UNIQUE (for example DEPT-IT)
name	varchar(100)	UNIQUE
manager_name, manager_email	varchar(150)	approval routing
hr_pic_email	varchar(150)	default admin.hrd@dexagroup.com
max_wfh_days_per_week	int	default 1
wfh_workflow_mode	enum STRICT_APPROVAL, NOTICE_ONLY	default STRICT_APPROVAL
enable_overtime, is_active	boolean	default true

7.4 attendances

Indexes: **`UQ_attendance_employee_date` UNIQUE on (`employee_id`, `attendance_date`)**, IDX_attendance_date, IDX_attendance_status, IDX_attendances_phash (employee_id, image_phash) and IDX_attendances_out_phash (employee_id, clock_out_image_phash).

Column	Type	Notes

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

id	uuid	PK
employee_id	uuid	FK to employees.id (RESTRICT)
attendance_date	date	WIB calendar day
clock_in_time, clock_out_time	datetime	set by the server only
work_duration_minutes, late_minutes, overtime_minutes	int	computed by the rules in Feature 5
overtime_multiplier_hours	double	default 0
overtime_pay_amount	bigint	IDR
wfh_approved	boolean	set by an approved WFH request
clock_in_photo_url, clock_out_photo_url	text	/uploads/...
clock_in_photo_captured_at, clock_out_photo_captured_at	datetime	EXIF or client capture time
photo_capture_source, clock_out_capture_source	enum LIVE_WEBCAM, FILE_UPLOAD	
is_timestamp_verified, is_clock_out_timestamp_verified	boolean	Feature 4 result
verification_method	enum LIVE_CAMERA_LIVENESS, MANUAL_FILE_UPLOAD	
verification_status	enum (5 values)	only VERIFIED_LIVE_BIOMETRIC and MANUAL_FACE_MATCHED_PENDING_REVIEW are written
liveness_score, similarity_score, clock_out_similarity_score	double	scores
is_face_matched, is_clock_out_face_matched	boolean	
image_hash, clock_out_image_hash	varchar(64)	SHA-256
image_phash, clock_out_image_phash	varchar(64)	average hash, 16 hex characters
latitude, longitude, address, distance_from_home_meters	decimal, text, int	optional browser location

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

location_status	enum IN_HOME_RADIUS, OUT_OF_HOME_RADIUS, LOCATION_UNAVAILABLE	informational
clock_out_latitude, clock_out_longitude, clock_out_address, clock_out_distance_from_home_meters, clock_out_location_status	decimal, text, int, enum	clock out location, same rules as clock in
daily_plan, daily_accomplishment, hr_note	text	
status	enum ON_TIME, LATE, HALF_DAY, COMPLETED, MISSING_CLOCK_OUT, ON_LEAVE, SICK	
ip_address, device_info	varchar(64), varchar(255)	
exif_captured_at, exif_metadata, fallback_reason, liveness_challenge_type	various	defined but not written today

dexa group

7.5 attendance_requests

Indexes: IDX_att_req_employee_date (employee_id, target_date) and IDX_att_req_status.

Column	Type	Notes
id	uuid	PK
employee_id	uuid	FK to employees.id (RESTRICT)
request_type	enum WFH_APPROVAL, OVERTIME, LEAVE, SICK, CORRECTION	
target_date	date	
requested_clock_in, requested_clock_out	datetime	corrections only
overtime_minutes, estimated_overtime_pay	int, bigint	overtime only
manager_email, cc_emails	varchar	resolved routing
email_dispatched	boolean	default false

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

reason	text	at least 10 characters
attachment_url	text	nullable
status	enum PENDING, APPROVED, REJECTED	default PENDING
reviewed_by	uuid	FK to users.id (SET NULL)
review_notes, reviewed_at	text, datetime	

7.6 Other tables

Table	Columns and rules
access_requests	id PK, full_name, email (indexed with status), employee_code, department, position, phone_number, reason, status (PENDING, APPROVED, REJECTED), reviewed_by FK to users (SET NULL), review_notes, reviewed_at, created_at.
otp_codes	id PK, user_id FK to users (CASCADE), email (indexed with type), code_hash (bcrypt, never plain), type (ACCOUNT_VERIFICATION, FORGOT_PASSWORD), attempts, expires_at, used_at, created_at.
support_tickets	id PK, user_id FK to users (SET NULL), sender_email, sender_name, category (BUG, ACCOUNT_ACCESS, ATTENDANCE_ISSUE, OTHER), module_location, subject, message, status (OPEN, RESOLVED, indexed), email_delivered, created_at.
system_settings	One row with id = DEFAULT: wfh_workflow_mode, enable_overtime, max_wfh_days_per_week, updated_by_email, timestamps. Created on first read. Saving it also copies the values to every department, and it takes precedence over department values.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER VIII
REST API AND INTERNAL MESSAGE CONTRACTS

Every gateway path starts with /api. "JWT" means JwtAuthGuard. SYSTEM_ADMIN and HR_ADMIN pass every role check (defect D1). JSON replies use the envelope { statusCode, type, where, what, why, data, meta }.

8.1 Authentication and onboarding (employee service)

Method	Gateway path	TCP pattern	Roles	Request	Response
POST	/auth/login	auth.login	Public	{email, password}	200 tokens, 200 requiresVerification, 401, 403
POST	/auth/refresh	auth.refresh	Public	{refreshToken}	200, 401
GET	/auth/me	auth.me	JWT	none	200 profile
PATCH	/auth/change-password	auth.change_password	JWT	{currentPassword, newPassword}	200, 400
GET	/auth/departments	employee.department_directory	Public	none	200
POST	/auth/request-access	auth.request_access	Public	RequestAccessDto	200, 409
POST	/auth/verify-account	auth.verify_account	Public	{email, otp, newPassword}	200 tokens, 400, 429
POST	/auth/resend-verification	auth.resend_verification	Public	{email}	200, 400, 404
POST	/auth/forgot-password	auth.forgot_password	Public	{email}	200, 404
POST	/auth/reset-password	auth.reset_password	Public	{email, otp, newPassword}	200, 400, 429

8.2 Employees, biometrics and access requests

Method	Gateway path	TCP pattern or FastAPI	Roles	Request	Response
POST	/employees/me/enroll-face	FastAPI /extract-embedding, then employee.enroll_face	JWT	multipart photo	200, 400, 409, 422
GET	/employees/departments	employee.departments	JWT	none	200
GET	/employees/department-directory	employee.department_directory	JWT	none	200

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

PATCH	/employees/me/profile	employee.update_profile	JWT	fullName, phoneNumber, homeAddress, homeLatitude, homeLongitude	200, 400
GET	/employees	employee.find_all	HR_ADMIN	page, limit, search, department, status, role, includeInactive	200
GET	/employees/:id	employee.find_one	HR_ADMIN	none	200, 404
POST	/employees	employee.create	HR_ADMIN	CreateEmployeeDto	200, 400, 409
PATCH	/employees/:id	employee.update	HR_ADMIN	UpdateEmployeeDto	200, 404, 409
DELETE	/employees/:id	employee.soft_delete	HR_ADMIN	none	200, 400, 404
PATCH	/employees/:id/restore	employee.restore	HR_ADMIN	none	200, 404
PATCH	/employees/:id/sibling-exemption	employee.toggle_sibling_exemption	HR_ADMIN	{isSiblingExempt, reason}	200, 404
POST	/employees/:id/resend-otp	employee.resend_verification	HR_ADMIN	none	200, 400, 404
GET	/access-requests	access_request.find_all	HR_ADMIN	?status	200
PATCH	/access-requests/:id/approve	access_request.approve	HR_ADMIN	{role, joinDate, reviewNotes}	200, 400, 404
PATCH	/access-requests/:id/reject	access_request.reject	HR_ADMIN	{reviewNotes}	200, 400, 404

8.3 Attendance and requests (attendance service)

Method	Gateway path	TCP pattern or FastAPI	Roles	Request	Response

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

POST	/attendances/verify-face-preview	FastAPI, then attendance.verify_face_preview	JWT	multipart photo	200
POST	/attendances/clock-in	FastAPI, then attendance.clock_in	JWT (not SYSTEM_ADMIN)	photo + ClockInDto	200, 400, 403, 409, 422
POST	/attendances/clock-out	FastAPI, then attendance.clock_out	JWT (not SYSTEM_ADMIN)	photo + ClockOutDto	200, 400, 409, 422
GET	/attendances/today	attendance.today	JWT	none	200
GET	/attendances/my-history	attendance.my_history	JWT	page, limit, dates	200
GET	/attendances/my-dashboard	attendance.my_dashboard	JWT	none	200
GET	/attendances/summary	attendance.summary	HR_ADMIN, MANAGER	?date	200
GET	/attendances/export	attendance.export	HR_ADMIN, MANAGER	format + filters	200 file
GET	/attendances	attendance.find_all	HR_ADMIN, MANAGER	filters, page, limit	200
GET	/attendances/:id	attendance.find_one	JWT	none	200, 404
POST	/attendance-requests	attendance_request.create	JWT	multipart attachment + DTO	200, 400, 409
GET	/attendance-requests/my	attendance_request.my	JWT	none	200
GET	/attendance-requests	attendance_request.find_all	HR_ADMIN, MANAGER	status, type, search, page	200
PATCH	/attendance-requests/:id/review	attendance_request.review	HR_ADMIN, MANAGER	{decision, reviewNotes}	200, 400, 403, 404

8.4 System, policy, support and Database Studio

Method	Gateway path	TCP pattern	Roles	Request	Response
GET	/system/time	gateway only	Public	none	200
GET	/system/health	gateway only	Public	none	200
GET	/system/policy	attendance.get_policy	Public	none	200

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

PATCH	/system/policy	attendance.update_policy	HR_ADMIN, SYSTEM_ADMIN	UpdatePolicyDto	200, 403
POST	/support/contact-developer	support.contact_developer	JWT	ContactDeveloperDto	200
GET	/support/tickets	support.find_tickets	JWT	none	200
PATCH	/support/tickets/:id/resolve	support.resolve	HR_ADMIN	none	200, 404
POST	/support/test-email	support.test_email	HR_ADMIN, SYSTEM_ADMIN	{targetEmail}	200
GET	/system/database/tables	database.get_tables	SYSTEM_ADMIN	none	200
GET	/system/database/:table	database.get_rows	SYSTEM_ADMIN	page, limit, search, sort	200, 400
GET	/system/database/:table/:id	database.get_row	SYSTEM_ADMIN	none	200, 404
POST	/system/database/:table	database.insert_row	SYSTEM_ADMIN	JSON row	200, 400
PUT	/system/database/:table/:id	database.update_row	SYSTEM_ADMIN	JSON fields	200, 400, 404
DELETE	/system/database/:table/:id	database.delete_row	SYSTEM_ADMIN	none	200, 404, 409

8.5 Biometric service (FastAPI, internal)

Method	Path	Called by	Request	Response
GET	/health	Docker health check	none	{status: HEALTHY, model, embedding_dimensions: 512}
POST	/extract-embedding	BiometricClientService.extractEmbedding	multipart file	status, face count, embedding of 512, bbox, detection score, image_hash, image_phash
POST	/verify-face	not called	file, reference_embedding, threshold (0.45)	{is_match, similarity, threshold}

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER IX
NON FUNCTIONAL REQUIREMENTS, SECURITY AND LIMITATIONS

9.1 Performance targets

Area	Target and current behaviour
Biometric inference	Target of about 200 ms per frame on CPU with det_size 320x320. This was not formally benchmarked. The gateway allows 10 seconds per call.
Face comparison	A dot product of 512 numbers, well under a millisecond.
Gateway to microservice	15 second timeout per TCP call, 502 on transport failure.
Lists	At most 100 rows per page.
Export	At most 5,000 rows, built in memory, base64 over TCP. Not yet a true stream.
Uploads	8 MB per image or attachment (nginx allows a 15 MB body).

9.2 Security safeguards in place

dexa group

Safeguard	Implementation
SQL injection	TypeORM repositories and QueryBuilder with bound parameters everywhere. The Database Studio limits table names to a whitelist and sort columns to entity metadata.
XSS	React escapes rendered values. (Email templates insert user reasons without escaping, which matters only to mail clients.)
Passwords	bcrypt with cost 10. password_hash is excluded from default selects and masked in the Database Studio.
OTP	Codes stored as bcrypt hashes, 15 minute expiry, 5 attempt lock, older codes invalidated on reissue.
Tokens	HMAC HS256 signed access and refresh tokens with separate secrets and a tokenType claim.
Input validation	Global ValidationPipe with whitelist and class validator DTOs (NIP, phone, OTP, HH:mm and strong password patterns).
Time	Official times come from the server only.
Photo reuse	SHA-256 exact match and average hash near match rejection per employee.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

Duplicate faces	One to many cosine check at enrollment against every active employee. A sibling exemption must be granted by HR and never covers a match of 0.90 or more.
Separation of duties	The System Admin is blocked from attendance at the gateway and in the UI.
Error hygiene	Structured where, what and why errors from global filters. No stack traces in responses.

> **Note: About signed tokens**
>
> The brief listed signed review links as a safeguard. The code uses signed JWTs for sessions, but the review link in emails is a plain request ID. See Feature 6.

9.3 Core system limitations

1. **Lighting, shadow and head pose.** ArcFace needs a clear frontal face. Low light, strong back light, masks or a head turned far from the camera (roughly beyond 45 degrees) can drop similarity below 0.45 or produce NO_FACE. The upload fallback still needs a face match, and those records are marked for review.
2. **One shift.** Start time, grace, half day threshold and the 540 minute overtime span assume a single 08:30 to 17:30 WIB schedule. Rotating shifts would need shift templates.
3. **Local disk storage.** Files live in a bind mounted folder on one machine. Scaling across nodes needs object storage.
4. **Server time versus slow uploads.** The official time is when the request arrives. On a slow connection it can be a few seconds after the user pressed capture.

Further constraints: liveness is 2D and runs in the browser; dashboards aggregate in memory; there is no scheduler; email links point to http://localhost:5173; and the demo passwords and default JWT secrets must change before any real use.

9.4 Known defects found during this review

#	Severity	Finding	Where
D1	High	RolesGuard and ProtectedRoute always admit HR_ADMIN, so the System Admin only Database Studio is reachable by HR.	roles.guard.ts, ProtectedRoute.tsx
D2	High	The onboarding review UI calls PATCH /access-requests/:id/review, which does not exist. Approve and reject return 404.	MasterEmployeesPage.tsx

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

D3	Medium	When FastAPI returns ERROR, clock in and clock out store a default similarity of 0.92 with no comparison.	attendance.service.ts
D4	Medium	A client photoCapturedAt counts as a timestamp, so uploads without EXIF can pass verification.	photo-metadata.util.ts
D5	Medium	The client sends livenessScore: 0.99 for every capture, and the preview proceeds as recognized if its call fails.	CameraPhotoUpload.tsx
D6	Medium	LiveServerClock reads serverTimestampMs, but the API returns serverEpochMs, so the header clock and watermark use device time.	LiveServerClock.tsx
D7	Low	Template variable names differ from the code: JWT_ACCESS_SECRET against JWT_SECRET, LATE_GRACE_MINUTES against WORK_GRACE_MINUTES. OTP_EXPIRES_MINUTES and UPLOAD_DIR are unused.	.env.example, docker-compose.yml
D8	Fixed	Fixed after the first review. email_dispatched now records the real result of the send.	attendance-requests.service.ts
D9	Low	Unverified sign in reissues an OTP without a password check, and sign in reveals unregistered emails.	auth.service.ts
D10	Low	GET /attendances/:id has no ownership check, and /uploads is public.	attendance.controller.ts, main.ts
D11	Low	Folder and file names use the container clock, not WIB.	photo-metadata.util.ts
D12	Info	/verify-face and several attendance columns are defined but unused.	various
D13	Medium	The WFH notice and request form fills its date with the UTC date, so between 00:00 and 07:00 WIB it suggests yesterday. A notice sent then is filed for the wrong day and clock in stays locked. Export file names use the UTC date too.	LeaveAndCorrectionModal.tsx
D14	Low	The profile page says the 100 meter home radius is strictly enforced, but clock in and clock out only tag the distance.	ProfilePage.tsx, attendance.service.ts
D15	Low	Without a saved home location the map window says No Clock In GPS submitted, although the coordinates were saved.	AttendanceLocationMapModal.tsx

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

D16	Low	Request emails wrap SMTP_FROM in a second display name, so the sender reads "Name (via Dexa WFH)>". Delivery is not affected.	attendance-requests.service.ts
D17	Info	With SMTP_OVERRIDE_RECIPIENT set, support tickets keep their Cc list, so real SMTP reports the @dexagroup.com copies as undeliverable.	mail.service.ts

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER X
DEPLOYMENT ARCHITECTURE AND ROADMAP

10.1 Current scope: local execution only

This is a Fullstack Technical Assessment. The system runs locally with Docker Compose and is intentionally not deployed to a public cloud server. There is no public URL, no managed database and no production secret store. The goal is that a reviewer can run the whole topology on one machine, deterministically, and inspect every layer, including the stored photo evidence. The only outside account needed is a Gmail or Outlook mailbox for email.

Container	Image or build	Host port	Waits for
dexa-wfh-mysql	mysql:8.0	3306	none
dexa-wfh-biometric-service	./biometric-service (Python 3.10 slim)	8000	none (mounts ~/.insightface read only)
dexa-wfh-employee-service	./backend (Node 22 alpine)	3001	MySQL and biometric healthy
dexa-wfh-attendance-service	./backend	3002	employee service healthy
dexa-wfh-api-gateway	./backend	3000	both microservices healthy (mounts ./uploads)
dexa-wfh-frontend	./frontend (Vite build, nginx 1.27)	5173 (to 80)	gateway healthy

The order is enforced with depends_on and health conditions. MySQL data persists in the volume dexa_mysql_data, and evidence files in the host folder ./uploads. Email goes out through the SMTP account in .env. Chapter XI shows a full run from an empty folder to a signed in session, with real output.

10.2 Evaluation entry points

What	Address
Web portal	http://localhost:5173
API base	http://localhost:3000/api
Swagger	http://localhost:3000/api/docs
Emails	the inbox set in SMTP_OVERRIDE_RECIPIENT
Biometric engine	http://localhost:8000/health and http://localhost:8000/docs

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

10.3 Seeded evaluation accounts

Role	Name	Email	Password
SYSTEM_ADMIN	Abdurrahman Khairi	sysadmin@dexagroup.com	AdminDexa2026!
HR_ADMIN	HR Admin One	admin.hrd@dexagroup.com	AdminDexa2026!
MANAGER	Manager One (IT)	manager.it@dexagroup.com	ManagerDexa2026!
MANAGER	Manager Two (Finance)	manager.finance@dexagroup.com	ManagerDexa2026!
EMPLOYEE	Employee One, Two, Three	employee.one@dexagroup.com and so on	EmployeeDexa2026!
EMPLOYEE (unverified)	Employee Four	employee.four@dexagroup.com	set during OTP verification

> **Note: Manager accounts**
> A fresh database receives six accounts on the first start of the employee service. The two manager accounts are added the next time it starts, so run `docker compose restart employee-service` once after the first boot.

10.4 Future deployment roadmap

The local setup above is the right shape for an assessment. A production rollout for Dexa Group would change it in eight steps:

1. **Container orchestration and auto scaling.** Move from `docker-compose.yml` to managed Kubernetes (EKS or GKE). Give the CPU heavy `biometric-service` a Horizontal Pod Autoscaler tuned for the 08:00 to 08:30 WIB clock in peak, and keep the TCP services behind internal cluster services.
2. **Cloud object storage.** Replace the local `/app/uploads` volume with AWS S3, Google Cloud Storage or an on premise MinIO cluster. Keep the `year/department/role/person/month/` key layout and serve images through short lived pre signed URLs, which also closes defect D10.
3. Production email and queueing. Today the services send through a Gmail or Outlook account with an app password. Production should use a company relay or a provider such as AWS SES or SendGrid on the company domain with SPF, DKIM and DMARC, OAuth2 instead of passwords, and a Redis and BullMQ queue with retries so an email spike never slows an HTTP response.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

4. **Managed database, backups and replicas.** Move to Amazon RDS or Cloud SQL for MySQL with point in time recovery, enforced TLS connections, and a read replica for heavy payroll exports and dashboards.
5. **CI/CD, HTTPS and observability.** GitHub Actions or GitLab CI to run tests, type checks and image builds on every merge. An nginx ingress with TLS certificates. Secrets (JWT keys, database and SMTP credentials) in HashiCorp Vault or Sealed Secrets. Prometheus, Grafana and Loki for metrics, latency and central logs, with an alert on biometric inference time during the morning peak.
6. **Identity and sessions.** Single sign on through the company identity provider (OIDC), refresh token rotation with a server side store so sign out really ends a session, and tokens in HTTP only cookies.
7. **Biometric capacity.** A GPU node pool with ONNX Runtime CUDA or TensorRT for the morning peak, a readiness endpoint so the gateway waits for the model, and a vector index for the one to many duplicate face check.
8. **Data protection and retention.** Face embeddings encrypted at rest with keys held outside the database, evidence served only through signed URLs, retention rules per file type, and restores of the database backups tested on a schedule.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

CHAPTER XI
LOCAL INSTALLATION WALKTHROUGH

This chapter repeats the local installation walkthrough from the companion Installation Guide, so the PRD can be read on its own. The steps, outputs and screenshots come from a real installation of the current code on a clean folder.

11.1 Scope and Architecture

11.1.1 Local Assessment Scope

This project is built for local technical evaluation. You run everything on your own computer. The only outside account you need is a Gmail or Outlook mailbox, which the system uses to send its email.

- **Email** goes out through a real SMTP account, Google Gmail or Microsoft Outlook, set in the root .env. There is no local mail catcher. With SMTP_OVERRIDE_RECIPIENT set, every one time code, approval email and support ticket lands in your own inbox.
- **Photos and attachments** are written to the local disk under uploads/, sorted by year, department, role, person and month.
- **Face recognition** runs on your CPU with InsightFace and ONNX Runtime. The only download it needs is the buffalo_l model, once.

dexa group

11.1.2 The Six Components and Their Ports

#	Component	Technology	Port (host)	What it does
1	Frontend portal	React 18, Vite 5, Tailwind CSS. In Docker it is built and served by nginx.	5173 (container port 80)	The web portal you sign in to. nginx forwards /api and /uploads to the gateway.
2	API Gateway	NestJS 11 on Express, Node 22	3000	The only HTTP entry point. Checks tokens and roles, accepts photo uploads, reads EXIF data, and passes work to the two microservices over TCP. Swagger lives at /api/docs.
3	Employee microservice	NestJS 11 TCP microservice, TypeORM	3001 (TCP, not HTTP)	Sign in, tokens, one time codes, employee records, access requests, support tickets and the Database Studio. It also creates the tables and seeds the demo accounts.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

4	Attendance microservice	NestJS 11 TCP microservice, TypeORM, ExcelJS	3002 (TCP, not HTTP)	Clock in and clock out, face match scoring, status rules, requests and approvals, dashboards, exports and the company WFH policy.
5	Biometric engine	Python 3.10, FastAPI, Uvicorn, InsightFace buffalo_l on ONNX Runtime (CPU)	8000	Turns a face photo into a 512 dimensional ArcFace vector. Swagger lives at /docs.
6	Database	MySQL 8.0	3306	Nine tables, kept in the Docker volume dexa_mysql_data.

Docker Compose starts them in a fixed order and waits for each health check: MySQL and the biometric engine first, then the employee service (which creates the tables), then the attendance service, then the gateway, and the frontend last.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.2 Prerequisites and a Zero State Check

11.2.1 Step 1: Check Tool Versions

Open PowerShell (or any terminal) and check what you have. For the Docker method you only need Docker Desktop with Compose v2. For the manual method you also need Node.js and Python.

Tool	Needed for	Version to use	Version on the test machine
Docker Desktop (or Docker Engine)	Method A and the database in Method B	24 or newer, with WSL 2 on Windows	29.1.3
Docker Compose	Both methods	v2 plugin (`docker compose`, with a space)	v5.0.1
Node.js and npm	Method B	Node 22 LTS (the Dockerfiles use `node:22-alpine`)	Node 22.11.0, npm 10.9.0
Python	Method B	3.10 (the Dockerfile uses `python:3.10-slim`)	3.10.6

dexa group

```
node -v
npm -v
python --version
docker -v
docker compose version
```

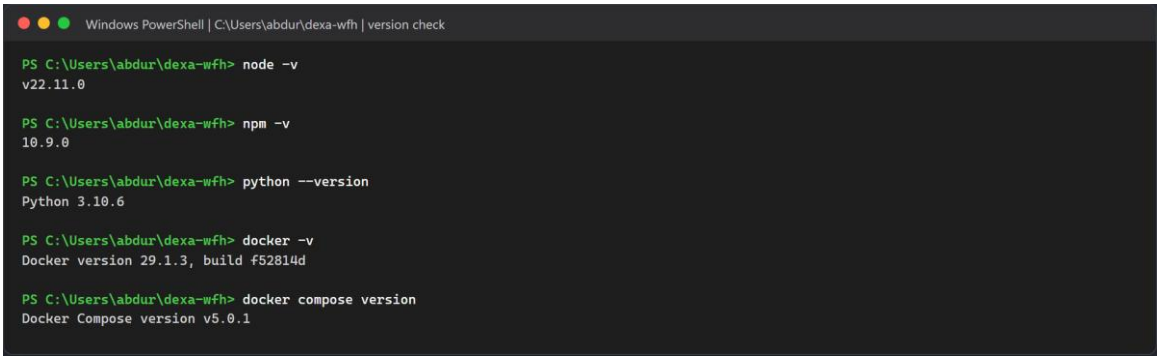


Figure 11.1: *Real version output on the test machine.*

You also want a webcam for the face steps, at least 8 GB of RAM (16 GB is more comfortable with six containers), and about 6 GB of free disk space for the images, the database and

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

the face model. For email you need a Gmail account with two step verification and an App Password, or an Outlook account that allows SMTP sign in.

11.2.2 Step 2: Look at the project folder

The repository is a small monorepo. Each folder maps to one or more of the components above.

Folder	What is inside
backend/	One NestJS workspace with three apps (api-gateway, employee-service, attendance-service) and a shared library in libs/common for entities, DTOs, enums and rules. One Dockerfile builds all three.
biometric-service/	The FastAPI face engine: main.py, service.py, requirements.txt and its Dockerfile.
frontend/	The React app, its Vite config and the nginx config used in Docker.
database/	Optional SQL files. You do not need to run them, because the app creates its own tables.
uploads/	Where Docker mode stores photos. It starts empty apart from .gitkeep.
docker-compose.yml	Defines all six services, their ports, health checks and start order.

dexa group

```
Get-ChildItem -Force -Name
```


© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

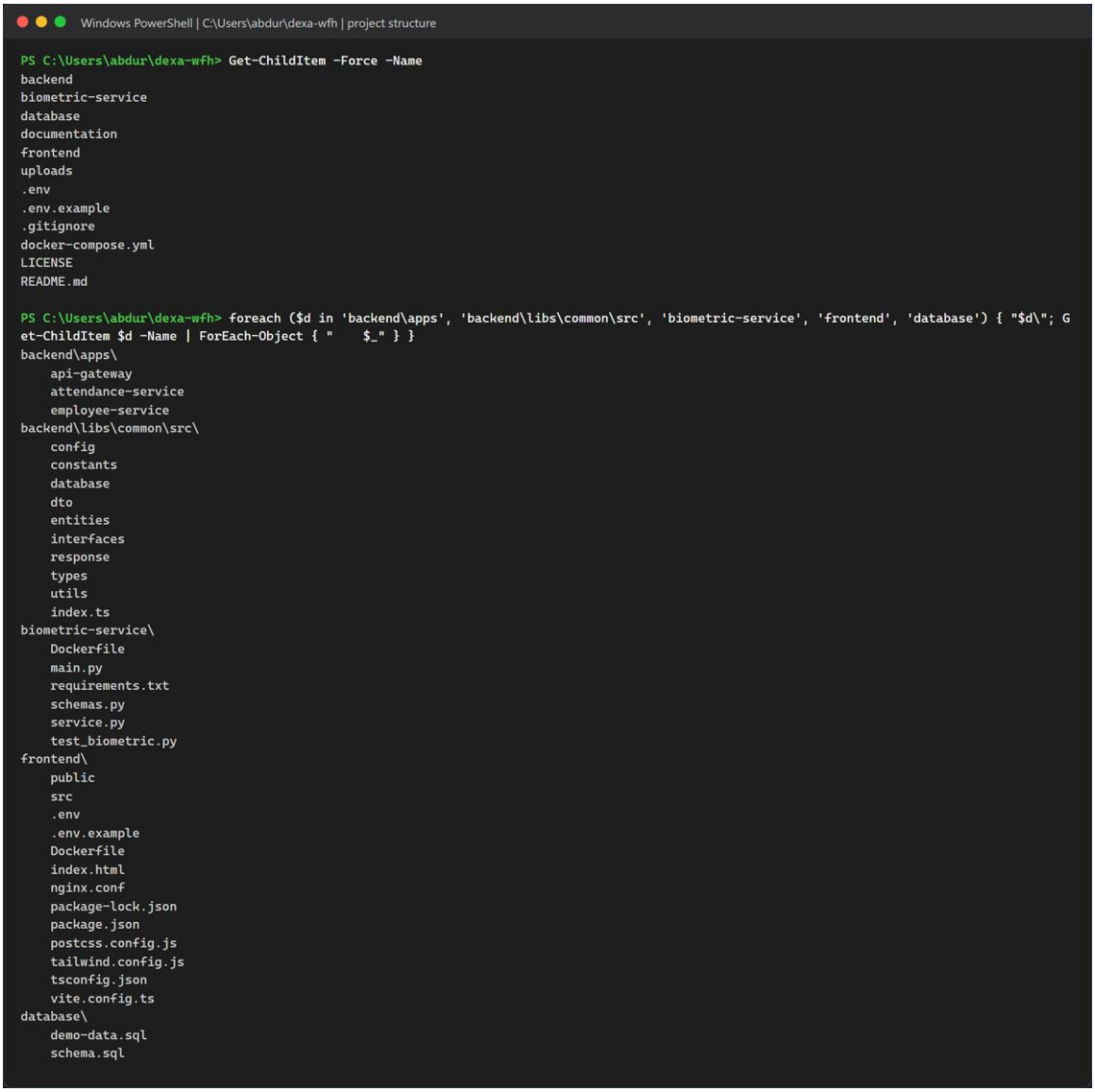


Figure 11.2: *The top level of the clean copy and the main subfolders. The three .env files in this listing were created in section 11.3.*

11.2.3 Step 3: Make sure the ports are free

The stack needs six ports. If another program already holds one of them, the matching container will fail to start. Run this check before you install anything:

```
foreach ($p in 3000,3001,3002,3306,5173,8000) {
  $c = Get-NetTCPConnection -State Listen -LocalPort $p -ErrorAction SilentlyContinue
  "{0,-6} {1}" -f $p, $(if ($c) { 'IN USE by PID ' + $c[0].OwningProcess } else { 'free' })
}
```

On macOS or Linux, `lsof -i :3306` does the same job for one port. On Windows, `netstat -ano | findstr :3306` works too.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

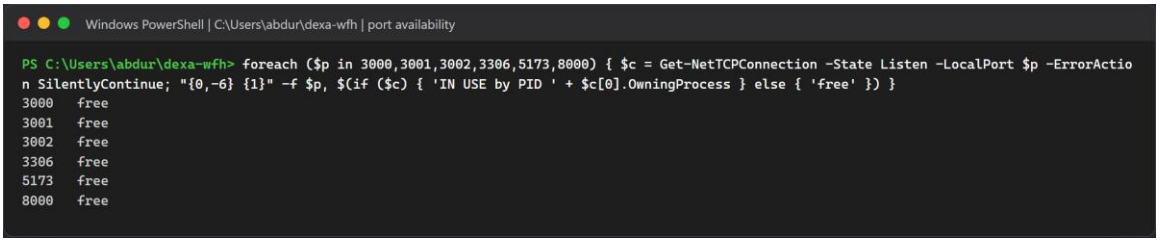


Figure 11.3: *All six ports reported free before the installation started.*

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.3 Environment Files

11.3.1 Copy the Templates

The repository ships three templates. Copy each one to a real .env file:

```
Copy-Item .env.example .env
Copy-Item backend\.env.example backend\.env
Copy-Item frontend\.env.example frontend\.env
```

On macOS, Linux or Git Bash use cp .env.example .env and so on. The biometric service has no .env file at all. It only reads INSIGHTFACE_HOME and FORCE_GPU from the shell.

> **Warning: Fill in your SMTP account before the first start**
>
> The template ships with placeholders: SMTP_USER=your_email@gmail.com, SMTP_PASS=your_16_digit_app_password, and the same address in SMTP_FROM and SMTP_OVERRIDE_RECIPIENT. Replace them with your own values in the root .env before you run Docker. With the placeholders the stack still starts, but every email fails with an authentication error, and Employee Four cannot be activated because the activation code never arrives. Keep the single quotes around the SMTP_FROM value; without them Docker Compose stops with unexpected character "<" in variable name.

Here is what each file is for:

- **Root `.env`**: Docker Compose reads it to fill the ${VAR:-default} placeholders in docker-compose.yml. Every placeholder already has a default, so Docker also works with no .env at all. The NestJS apps read it too when you run them by hand.
- **`backend/.env`**: holds the same keys as the root file. The backend loads backend/.env first and then the root .env, so this copy is only useful for backend specific overrides.
- **`frontend/.env`**: holds VITE_API_BASE_URL=/api and an empty VITE_BACKEND_ORIGIN. Both are the defaults, so the file is optional.

These are the active lines of the root template, with its comment lines left out:

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

```
DB_TYPE=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_USERNAME=dexa_user
DB_PASSWORD=dexa_password_2026
DB_DATABASE=dexa_wfh_db
DB_SYNCHRONIZE=true
DB_LOGGING=false
API_GATEWAY_PORT=3000
EMPLOYEE_SERVICE_HOST=127.0.0.1
EMPLOYEE_SERVICE_PORT=3001
ATTENDANCE_SERVICE_HOST=127.0.0.1
ATTENDANCE_SERVICE_PORT=3002
JWT_ACCESS_SECRET=dexa-wfh-jwt-access-secret-2026-abdurrahman-khairi
JWT_REFRESH_SECRET=dexa-wfh-jwt-refresh-secret-2026-abdurrahman-khairi
JWT_ACCESS_EXPIRES_IN=8h
JWT_REFRESH_EXPIRES_IN=7d
OTP_EXPIRES_MINUTES=10
WORK_START_TIME=08:30
LATE_GRACE_MINUTES=15
HALF_DAY_THRESHOLD_MINUTES=240
SMTP_HOST=smtp.gmail.com
SMTP_PORT=587
SMTP_SECURE=false
SMTP_USER=your_email@gmail.com
SMTP_PASS=your_16_digit_app_password
SMTP_FROM='"Dexa Group WFH Monitoring" <your_email@gmail.com>'
SMTP_OVERRIDE_RECIPIENT=your_email@gmail.com
SYSTEM_NOREPLY_EMAIL=noreply-wfh@dexagroup.com
DEVELOPER_SUPPORT_EMAIL=abdurrahman.khairi@dexagroup.com
UPLOAD_DIR=./uploads
```


© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

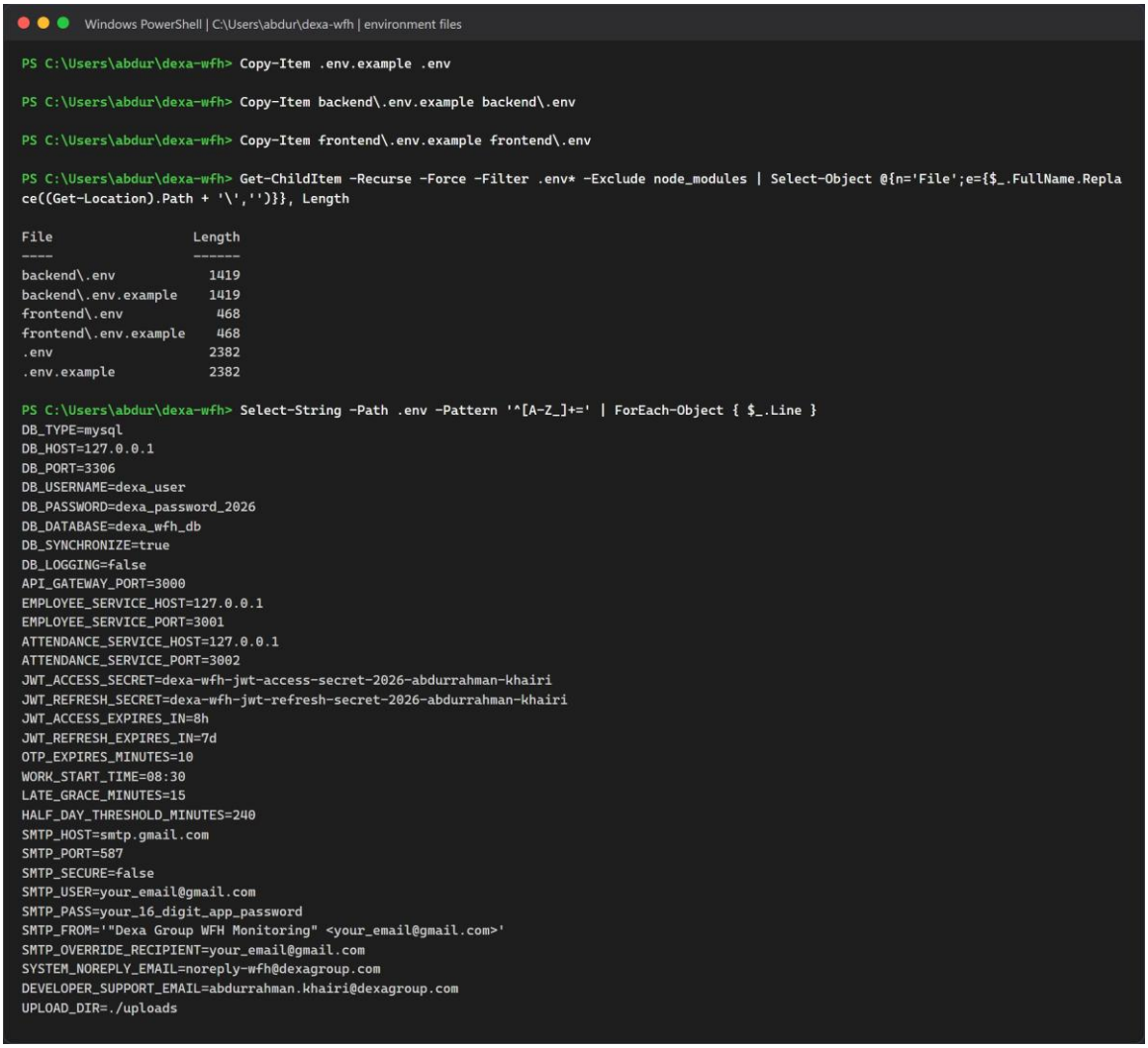


Figure 11.4: *The three .env files created from their templates, and the values inside the root .env.*

11.3.2 Environment Variable Reference

Inside Docker, the containers talk to each other by service name (mysql, biometric-service, employee-service, attendance-service). Those host names are written straight into docker-compose.yml and ignore your .env. When you run the apps by hand on your computer, everything is 127.0.0.1. The SMTP host is the exception: it is a real mail server on the internet in both methods.

Variable	Read by	Value in Docker	Value in Method B	What it controls
DB_HOST	employee and attendance services	mysql	127.0.0.1	Database host.
DB_PORT	employee and attendance services	3306 inside the network	3306	Database port. Setting it in the root .env also

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

				changes the host port Docker publishes.
DB_USERNAME, DB_PASSWORD, DB_DATABASE	both services and the MySQL container	dexa_user, dexa_password_2026, dexa_wfh_db	same	Credentials. The MySQL container creates this user and database on its first start.
DB_SYNCHRONIZE	employee service	true (attendance gets false)	true	Lets TypeORM create the tables. Only the employee service is allowed to.
EMPLOYEE_SERVICE_HOST and _PORT	gateway and employee service	employee-service, 3001	127.0.0.1, 3001	TCP link to the employee service.
ATTENDANCE_SERVICE_HOST and _PORT	gateway and attendance service	attendance-service, 3002	127.0.0.1, 3002	TCP link to the attendance service.
BIOMETRIC_SERVICE_URL	gateway and both services	http://biometric-service:8000	not set, so the code uses http://127.0.0.1:8000	Where the face engine lives.
JWT_SECRET	gateway and employee service	not set, so both use dexa-wfh-secret-2026	same	Secret that signs access tokens. The template calls it JWT_ACCESS_SECRET, but the code reads JWT_SECRET.
JWT_REFRESH_SECRET	employee service	template value	template value	Secret for refresh tokens.
JWT_ACCESS_EXPIRES_IN, JWT_REFRESH_EXPIRES_IN	employee service	8h, 7d	8h, 7d	Token lifetimes.
WORK_START_TIME, HALF_DAY_THRESHOLD_MINUTES	attendance service	08:30, 240	same	Shift start (WIB) and the minimum minutes for a full day.
WORK_GRACE_MINUTES	attendance service	not set, so 15	not set, so 15	Grace period before a clock in counts as late. The template calls it LATE_GRACE_MINUT

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

				ES, which the code does not read.
SMTP_HOST, SMTP_PORT	both services	smtp.gmail.com, 587	smtp.gmail.com, 587	The SMTP server. Gmail is the default; switch to smtp.office365.com for Outlook.
SMTP_SECURE, SMTP_USER, SMTP_PASS	both services	false, your address, your App Password	same, from backend/.env	TLS mode and SMTP sign in. Keep false for port 587; the connection then upgrades with STARTTLS. Port 465 switches to direct TLS on its own. Gmail and Outlook refuse mail without a sign in.
SMTP_FROM	both services	template value	template value	Sender address on every email. When it is empty, the sender becomes SMTP_USER, or the system address when that is empty too.
SMTP_OVERRIDE_RECIPIENT	employee and attendance services	your inbox	your inbox	When set, every email goes to this one address with a yellow banner naming the original recipient. The attendance service also drops the CC list; the employee service keeps it on support tickets.
OTP_EXPIRES_MINUTES	nothing	ignored	ignored	One time codes always expire after 15 minutes. That value is a constant in the code.
UPLOAD_DIR	nothing	ignored	ignored	Photos always go to uploads inside the

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

				folder the gateway runs from: /app/uploads in Docker (mapped to the root uploads/), backend/uploads in Method B.
VITE_API_BASE_URL	frontend build	/api	/api	Base URL for API calls. There is no VITE_API_URL variable in this project.
VITE_API_PROXY_TARGET	Vite dev server	not used	optional, default http://localhost:3000	Where npm run dev forwards /api and /uploads.
NODE_ENV	employee service	production	not set	When it is not production, API responses include the one time code as a hint, which helps local testing.

dexa group

11.3.3 SMTP Email Options

Section 5 of the root .env.example holds two blocks. Option A, Gmail, is active. To use Outlook, comment out the Option A lines and remove the # in front of the six lines of Option B. Fill in your own address and password either way, and keep only one block active.

```
# 5. SMTP Email Configuration (Real-World Gmail & Outlook Auto-Emailing)
# Option A (Active): Google Gmail SMTP (STARTTLS on port 587, 16 character Google App Password)
SMTP_HOST=smtp.gmail.com
SMTP_PORT=587
SMTP_SECURE=false
SMTP_USER=your_email@gmail.com
SMTP_PASS=your_16_digit_app_password
SMTP_FROM='"Dexa Group WFH Monitoring" <your_email@gmail.com>'


# Option B: Microsoft Outlook / Office 365 SMTP (STARTTLS on port 587):
# SMTP_HOST=smtp.office365.com
# SMTP_PORT=587
```


© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

```
# SMTP_SECURE=false
# SMTP_USER=your_email@outlook.com
# SMTP_PASS=your_outlook_password
# SMTP_FROM='"Dexa Group WFH Monitoring" <your_email@outlook.com>'


# Smart Evaluation Forwarding (delivers every email for the @dexagroup.com demo accounts to this inbox):
SMTP_OVERRIDE_RECIPIENT=your_email@gmail.com
```

- **Option A, Gmail.** SMTP_PASS must be a 16 character Google App Password, not your normal Google password. section 11.7 explains how to create one. Gmail sends as the account in SMTP_USER and replaces any other sender address unless it is a verified alias, so use that same Gmail address in SMTP_FROM.
- **Option B, Outlook and Office 365.** Use your full Outlook address as SMTP_USER. When the host contains office365.com or outlook.com, both services force STARTTLS and apply a cipher setting for Microsoft servers. Your account or tenant must still allow SMTP sign in with a password (see section 11.7).
- **SMTP_FROM.** The sender shown on every email. Use the address you sign in with, and keep the single quotes around the whole value.
- **SMTP_OVERRIDE_RECIPIENT.** Your own inbox for evaluation. Leave it set while you test: the demo accounts use @dexagroup.com addresses that cannot receive real mail, so without it the activation codes and approval emails are lost. Method B reads backend/.env first, so put the same SMTP values there too.

Note: Recreate the containers after you edit .env

Docker hands environment values to a container only when it creates it, so docker compose restart keeps the old SMTP settings. Run docker compose up -d instead, which recreates every container whose settings changed. In Method B, stop npm run start:dev with Ctrl+C and start it again.

11.3.4 Emails the System Sends

Every email below goes out through the SMTP account in .env. With SMTP_OVERRIDE_RECIPIENT set, the To address of each one becomes your own inbox.

Email	Sent by	Who receives it, and when
Account activation code (6 digits, valid 15 minutes)	employee service	The account's own address, when an account that is not yet verified signs in, or when HR resends the code.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

Password reset code	employee service	The account's own address, from Forgot Password.
WFH, overtime, leave, sick or correction request	attendance service	To the department manager, CC the department HR contact (admin.hrd@dexagroup.com by default) and the requester. A request from a Manager or System Admin goes up to the HR contact instead, with sysadmin@dexagroup.com added to CC. Under the NOTICE_ONLY policy a WFH request is approved at once and the email is a notice. The review button opens /manager/approvals?requestId=<id>, and the reviewer still has to sign in.
Approval decision	attendance service	To the requester, CC the manager and admin.hrd@dexagroup.com, when a request is approved or rejected.
Support ticket (Contact Developer)	employee service	To every active System Admin, CC every active HR Admin and the sender.
SMTP test email	employee service	The targetEmail address, or the caller's own address. Sent by POST /api/support/test-email, for HR Admin and System Admin only.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.4 Method A, Docker Compose (Recommended)

This is the quickest way to get the whole system running. One command builds five images, pulls MySQL, and starts all six containers in the right order.

11.4.1 Before Start: The Face Model

The biometric container does not download its model. It mounts your own model folder, %USERPROFILE%\.insightface on Windows or ~/.insightface on macOS and Linux, as read only. Make sure models/buffalo_l with its five .onnx files exists there before the first start. The simplest way is to download the release zip and unpack it:

```
New-Item -ItemType Directory -Force "$env:USERPROFILE\.insightface\models\buffalo_l" | Out-Null
Invoke-WebRequest -Uri "https://github.com/deepinsight/insightface/releases/download/v0.7/buffalo_l.zip" `
  -OutFile "$env:USERPROFILE\.insightface\models\buffalo_l.zip"
Expand-Archive "$env:USERPROFILE\.insightface\models\buffalo_l.zip" `
  -DestinationPath "$env:USERPROFILE\.insightface\models\buffalo_l" -Force
```

If unpacking creates a nested buffalo_l\buffalo_l folder, move the five files up one level.

dexa group

11.4.2 Step 1: Build and Start All Containers

```
docker compose up --build -d
```

Here is what gets built:

- **`biometric-service`**: Python 3.10 slim plus build tools, OpenCV, ONNX Runtime and InsightFace.
- **`employee-service`, `attendance-service`, `api-gateway`**: three images from the same backend Dockerfile. Each runs npm install and npm run build on Node 22.
- **`frontend`**: a Node 22 build stage that runs vite build, then an nginx image that serves the result.

MySQL is pulled as a ready made image. With -d, the command returns once the frontend container has started. Before that, it waits for each health check in turn, and you can watch the Healthy lines appear in that order.

On the test machine the command took about three and a half minutes. Docker reused the cached npm install layers from an earlier build, but it ran pip install for the biometric image again

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

(about two and a half minutes of that time) and rebuilt the application code. On a computer that has never built these images, expect it to take longer, because every package has to be downloaded first.

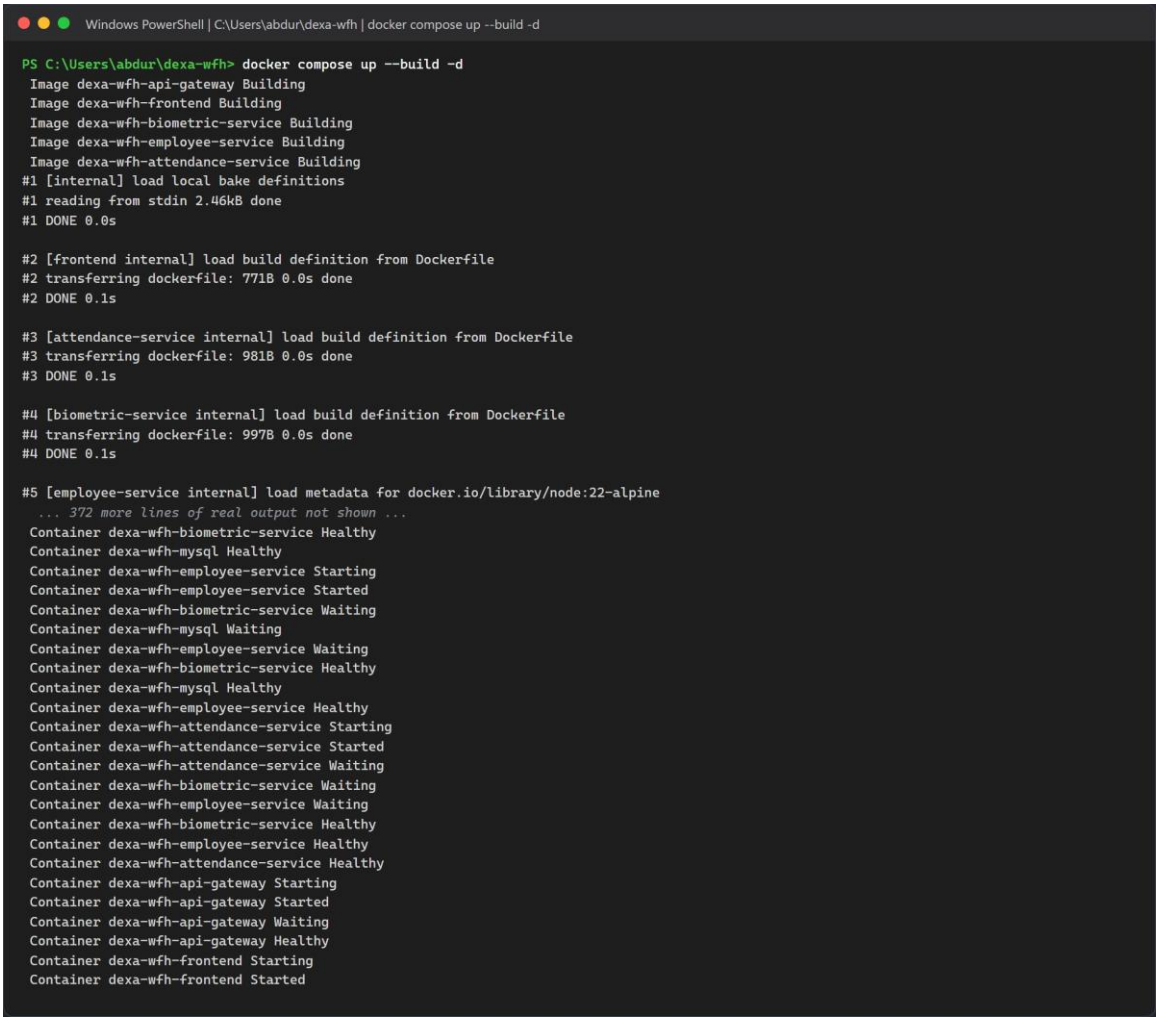


Figure 11.5: *The start and the end of the real build output, ending with every container started.*

11.4.3 Step 2: Check the Containers and their Ports

```
docker compose ps
```

Five containers should report healthy. The frontend has no health check, so it only shows Up. The ports column should match the table in section 11.1.

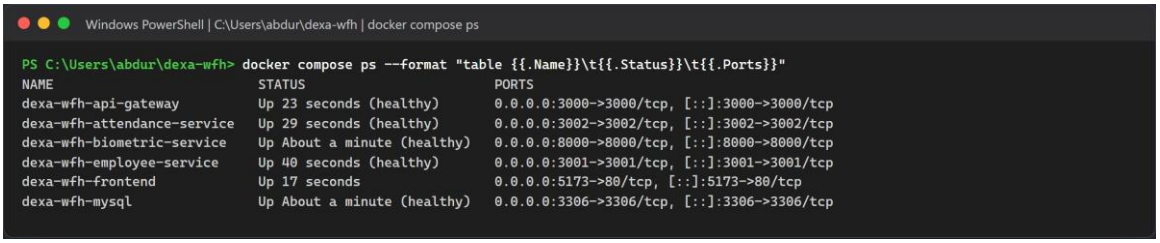


Figure 11.6: *All six containers running, with their host port bindings.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.4.4 Step 3: Watch the Face Model Load

When the biometric container starts, it loads the five buffalo_l ONNX models into memory before it answers any request. On the test machine this took about 28 seconds inside Docker. ArcFace (w600k_r50.onnx, a ResNet 50 network) is the model that produces the 512 dimensional face vectors. ONNX Runtime runs it on the CPU.

To prove the engine works end to end, send it one sample photo and read the log:

```
curl.exe -s http://localhost:8000/health
curl.exe -s -o NUL -w "HTTP %{http_code}\n" -F "file=@sample-face.jpg" http://localhost:8000/extract-embedding
docker compose logs biometric-service
```

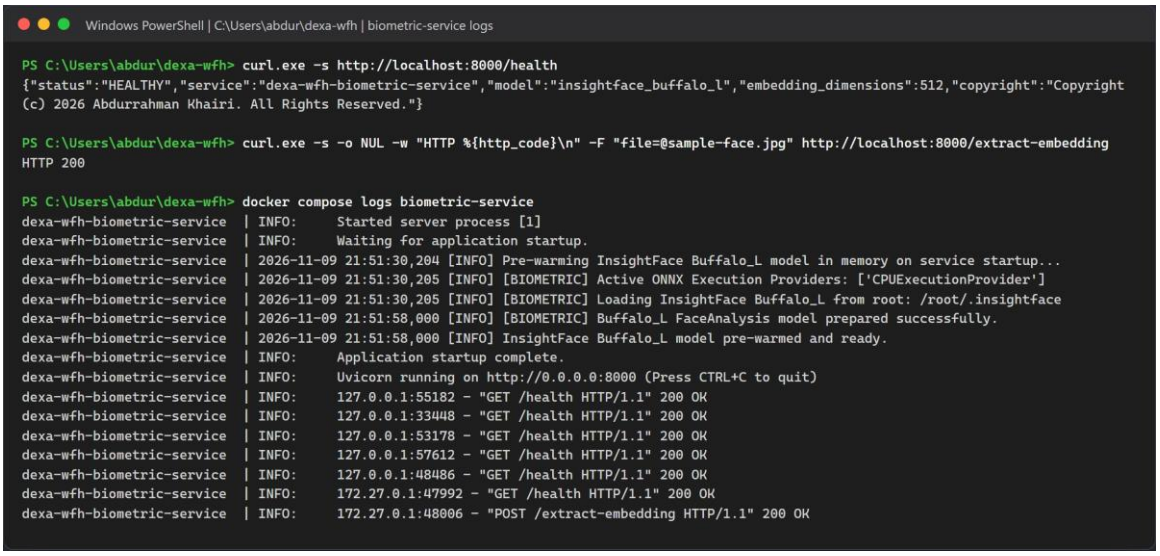


Figure 11.7: *The health response, a successful embedding request, and the log lines showing the CPU provider, the model folder and Uvicorn on port 8000.*

> **Note: If the model folder is missing**
>
> The container still reports healthy, but every face enrollment and clock in will fail. Check that models/buffalo_l exists in your home folder and run docker compose restart biometric-service.

11.4.5 Step 4: Database Tables and Seed Accounts

There is no migration or seed command to type. When the employee service starts, TypeORM creates all nine tables, and the seeder fills an empty database with five departments and six accounts.

The two manager accounts are only added on the next start of the employee service. Run this once after the first boot:

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

```
docker compose logs employee-service | findstr /i "seed provision already listening"
docker compose restart employee-service
docker compose logs --since 1m employee-service | findstr /i "provision already listening"
```

On macOS or Linux, use grep -iE in place of findstr /i. Then list the accounts straight from MySQL:

```
docker compose exec mysql mysql -udexa_user -pdexa_password_2026 dexa_wfh_db -e "SELECT u.email, u.role, u.is_verified, e.employee_code FROM users u LEFT JOIN employees e ON e.user_id = u.id ORDER BY u.role, u.email;"
```

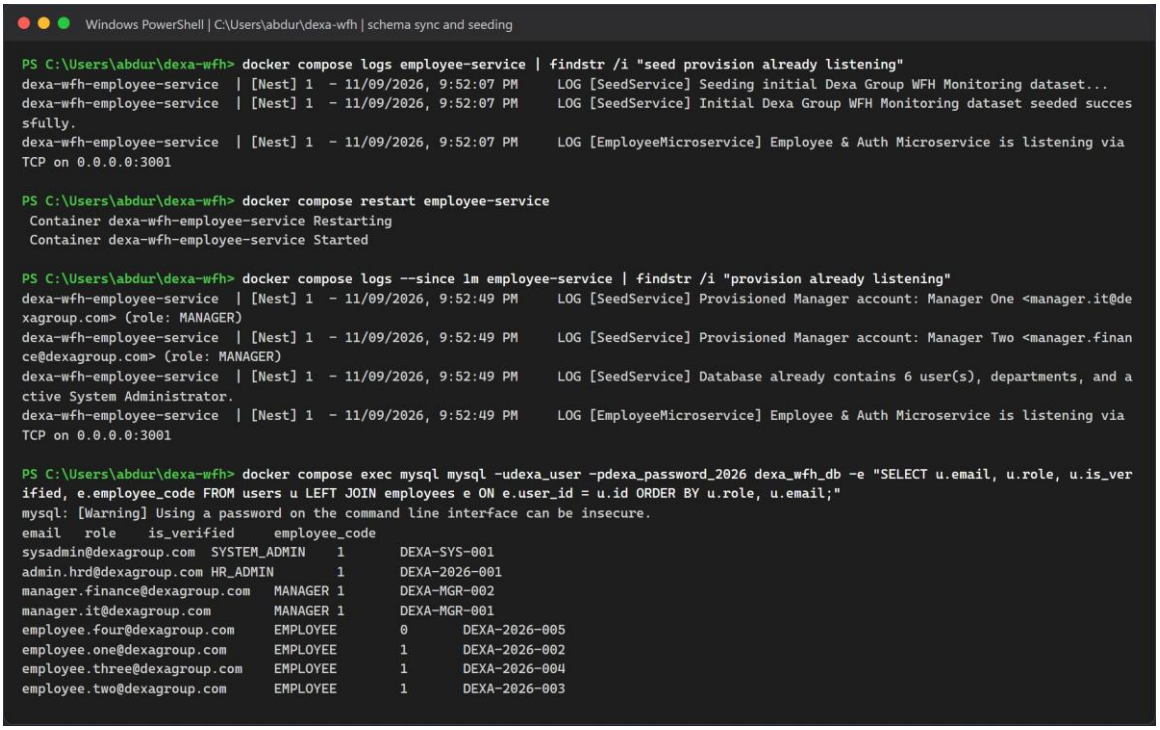


Figure 11.8: *First boot seeds the dataset, the restart adds Manager One and Manager Two, and MySQL lists all eight accounts.*

Warning: Skipping the restart

Without the restart, manager.it@dexagroup.com and manager.finance@dexagroup.com do not exist. Employee requests still email the managers, but nobody can sign in as a manager to approve them.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.5 Method B, Manual Local Installation

Use this method when you want to change code and see it reload. MySQL still runs in Docker. The face engine, the three NestJS apps and the Vite dev server run directly on your computer. Each long running process gets its own terminal.

> **Note: Do not mix the two methods**
>
> If the Method A containers are still running, stop them first with docker compose down. Otherwise ports 3000, 3001, 3002, 5173 and 8000 are already taken.

11.5.1 Step 1: Start MySQL Only

```
docker compose down
docker compose up -d mysql
docker compose ps
docker compose exec mysql mysql -udexa_user -pdexa_password_2026 -e "SHOW DATABASES; SELECT VERSION();"
```

dexa group

Name the service. A bare docker compose up -d would start the whole stack again. docker compose down without -v keeps the database volume, so the accounts seeded in section 11.4 are still there.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

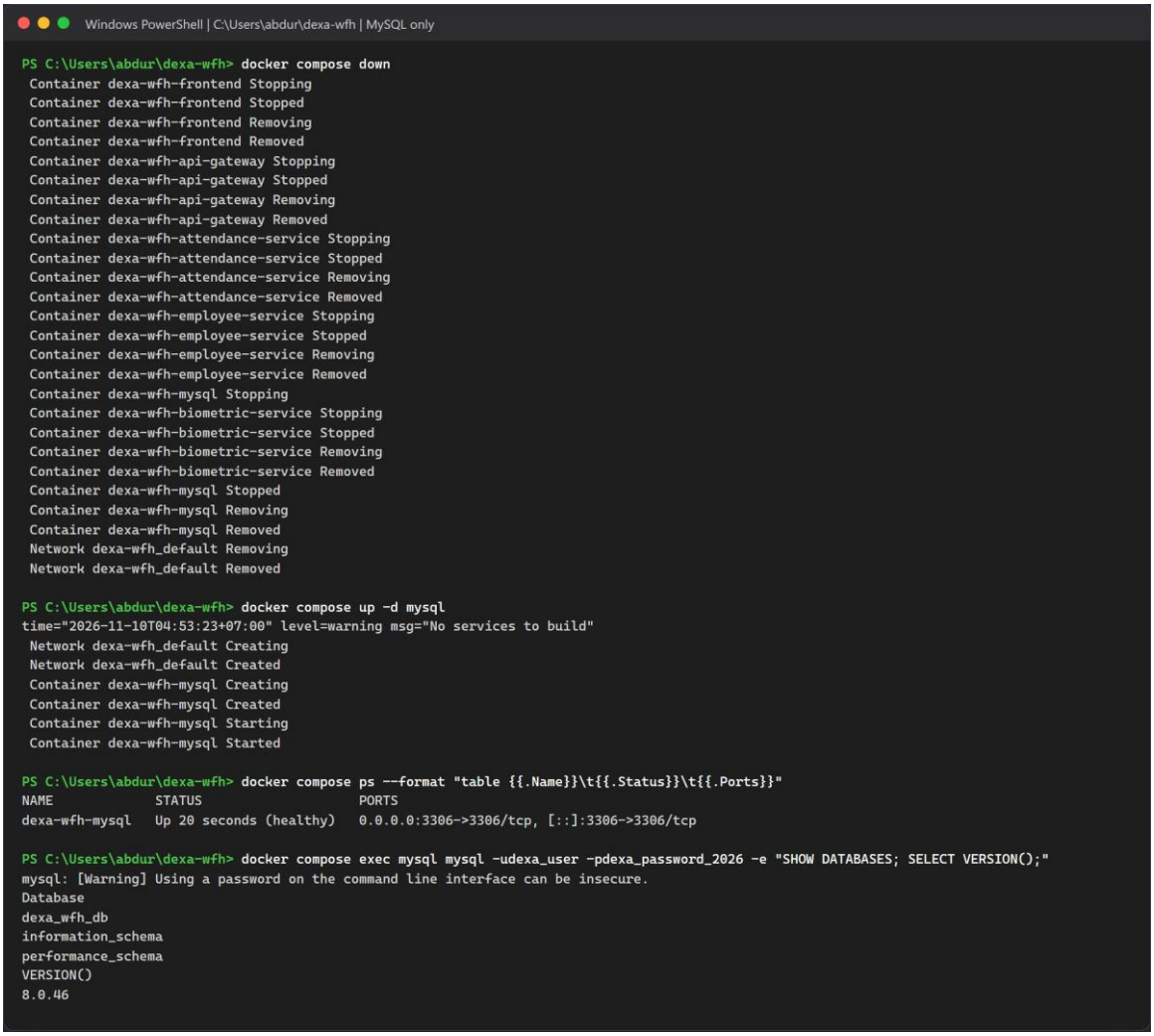


Figure 11.9: *MySQL 8.0 healthy and the dexa_wfh_db database present.*

11.5.2 Step 2: Python Environment and The Face Engine

In a new terminal:

```
cd biometric-service
python -m venv .venv
.\.venv\Scripts\Activate.ps1
pip install -r requirements.txt
```

On macOS or Linux, activate with source .venv/bin/activate. If PowerShell refuses to run the activation script, run Set-ExecutionPolicy -Scope CurrentUser RemoteSigned once.

On the test machine pip took a little under three minutes. It installed InsightFace 2.1, ONNX Runtime 1.23.2, NumPy 2.2.6 and OpenCV headless 5.0.0.93 as ready made wheels, so no C++ compiler was needed. The requirements file only sets minimum versions (>=), so pip picks the newest release on the day you install. Your versions may differ from these.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

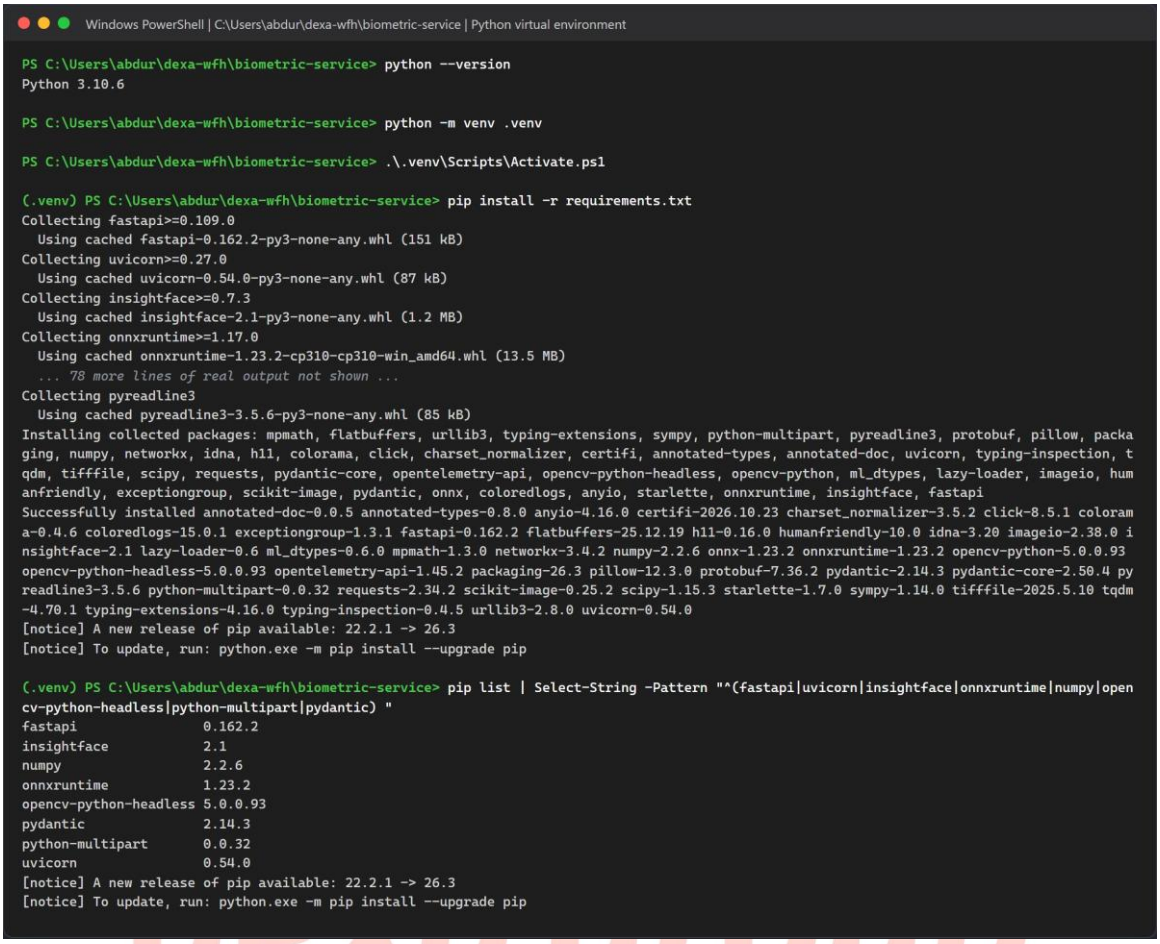


Figure 11.10: *Creating the virtual environment, the start and end of pip install, and the key packages it installed.*

Now start the engine:

```
uvicorn main:app --host 0.0.0.0 --port 8000 --reload
```

It reads the model from your own ~/.insightface folder. If buffalo_l is missing there, InsightFace downloads it the first time it loads. python main.py also works if you do not want auto reload.

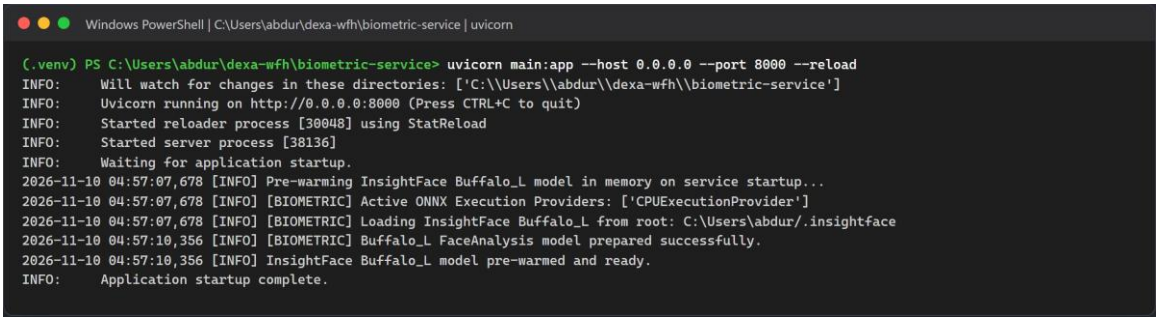


Figure 11.11: *Uvicorn listening on port 8000, with the model loaded from the local .insightface folder in under three seconds.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.5.3 Step 3: Install and Start the NestJS Backend

In another terminal:

```
cd backend
npm install
npm run start:dev
```

On the test machine npm install added 598 packages in 45 seconds. The deprecation and audit warnings come from third party packages and do not stop the install.

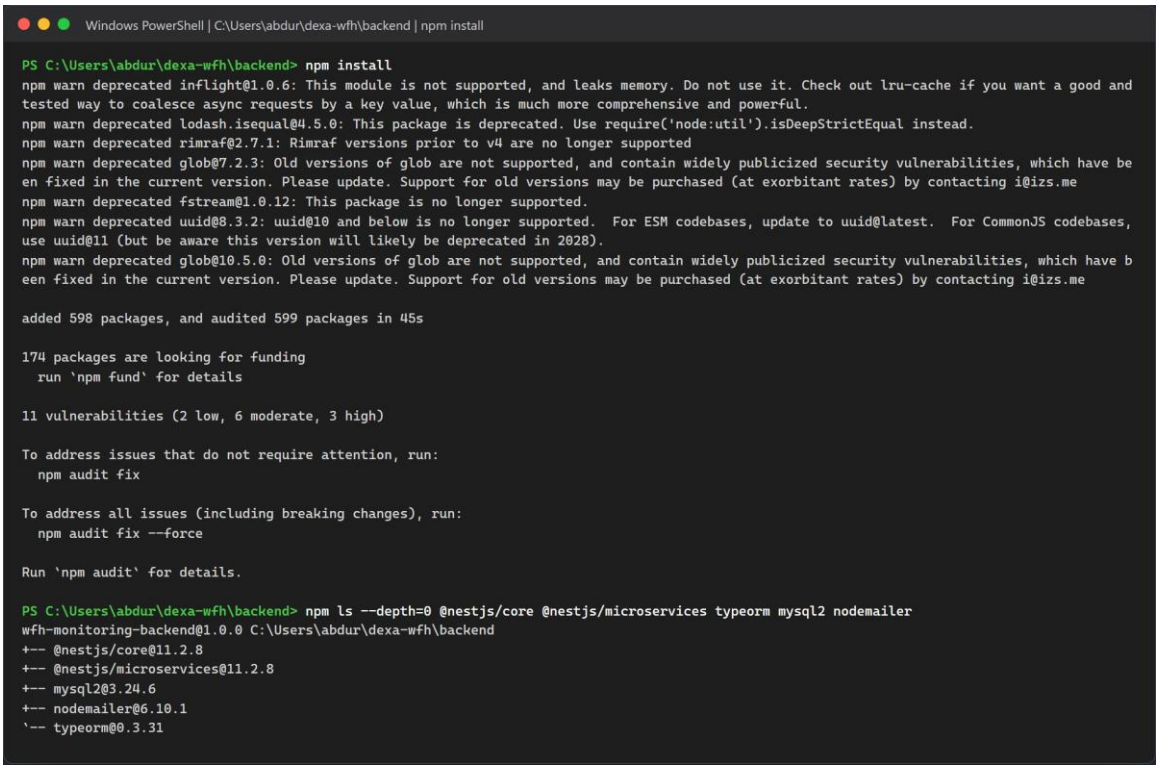


Figure 11.12: *npm install finished in the backend folder, with the main NestJS, TypeORM, MySQL and mail packages confirmed.*

npm run start:dev uses concurrently to run all three apps in watch mode. Each log line is tagged EMP, ATT or GW. There is no separate seed script here either. The employee service creates any missing tables and runs the seeder when it starts. On a fresh, empty database, start npm run start:employee first and let it finish before you start the other two.

In this mode the gateway saves uploaded photos to backend/uploads, because it uses the folder it was started from.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

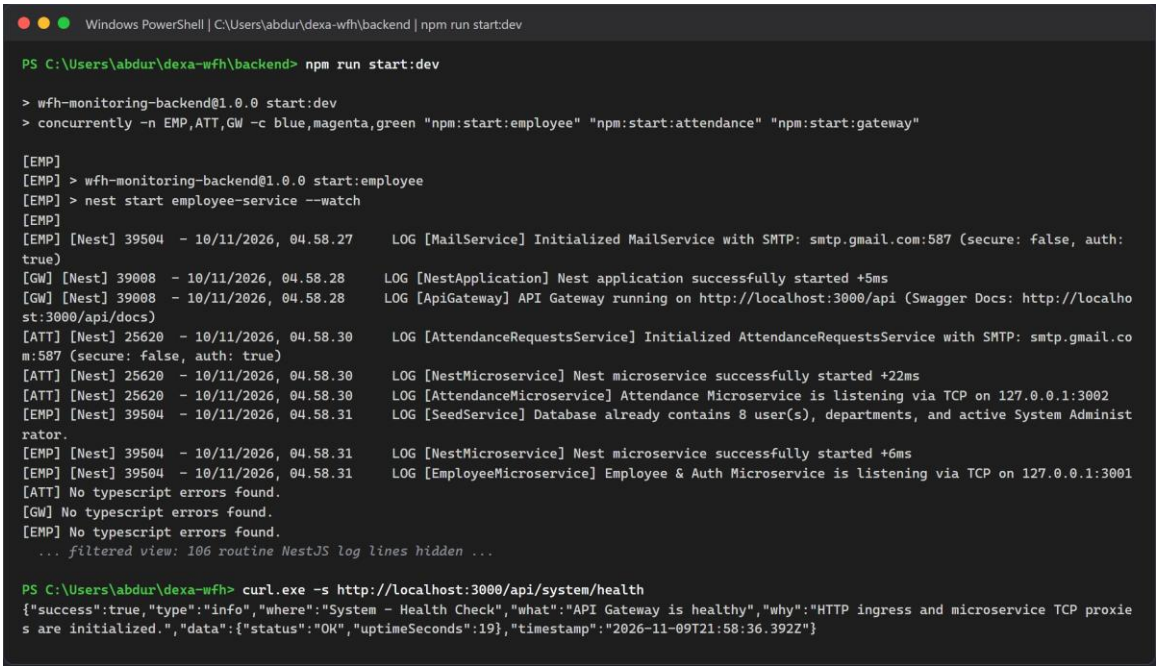


Figure 11.13: *The employee service on TCP 3001, the attendance service on TCP 3002 and the gateway on HTTP 3000, followed by a health check. Routine route mapping lines are hidden.*

11.5.4 Step 4: Install and Start the React Frontend

In a fourth terminal:

```
cd frontend
npm install
npm run dev
```

The dev server listens on port 5173 and forwards /api and /uploads to http://localhost:3000. You do not need a frontend .env for this.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

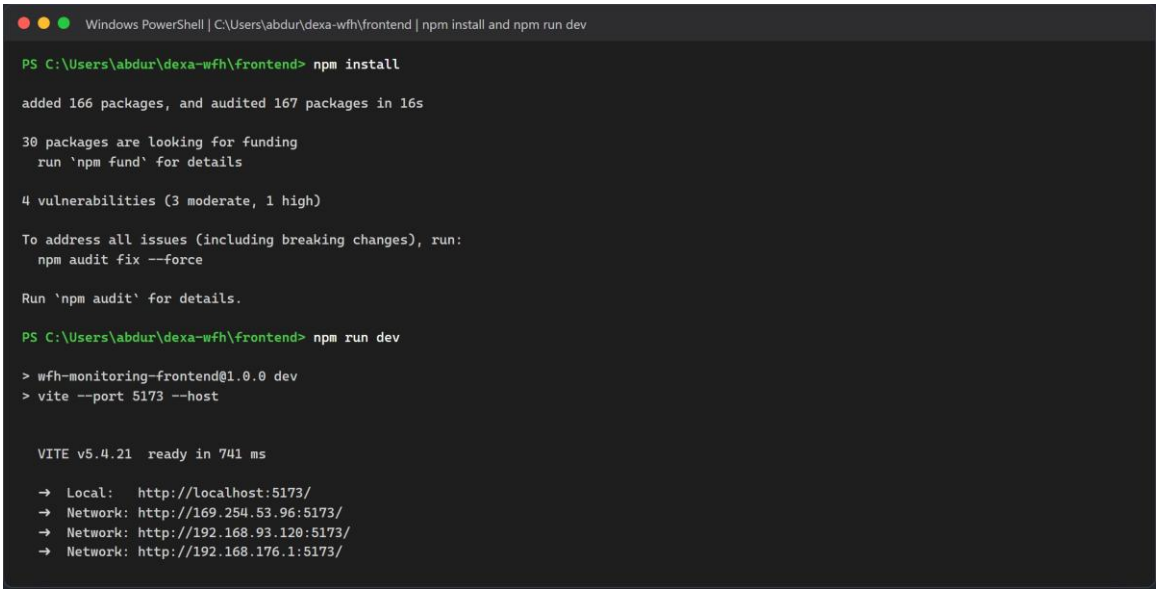


Figure 11.14: *npm install added 166 packages, and Vite reported ready at http://localhost:5173.*

Run the port check from section 11.2 again. All six ports should now be in use. In this method that means node on 3000, 3001, 3002 and 5173, python on 8000, and Docker on 3306.

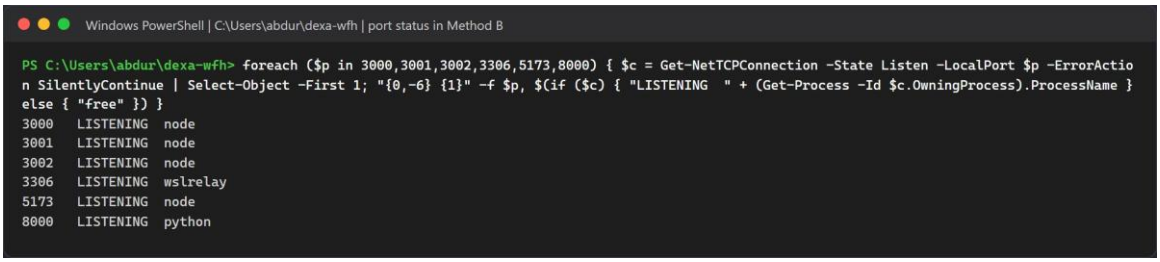


Figure 11.15: *Every port in use, with the process behind each one.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.6 Check the Installation in the Browser

The screenshots in this part were taken against the Docker stack from section 11.4. With Method B the same addresses give the same pages.

11.6.1 Step 1: Biometric Engine Swagger Page

Open http://localhost:8000/docs. You should see three endpoints: GET /health, POST /extract-embedding and POST /verify-face. The backend only calls the first two. It compares faces itself, in the attendance service, and accepts a match at a similarity of 0.45 or higher.



Figure 11.16: *The FastAPI Swagger page of the biometric engine.*

11.6.2 Step 1.5: One to One Face Check Against the Engine

This check talks to the face engine directly and writes nothing to the database. Put three photos in an empty folder: two of the same person and one of somebody else. The first call turns a photo into a 512 dimension ArcFace embedding. The next calls compare a new photo with that embedding by cosine similarity, which is the same check the attendance service runs at clock in and clock out.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

```
curl.exe -s -F "file=@person_a_1.jpg" http://localhost:8000/extract-embedding -o ref.json
$ref = (Get-Content ref.json | ConvertFrom-Json).embedding
Set-Content -Encoding ascii emb.json (ConvertTo-Json -InputObject $ref -Compress)
curl.exe -s -F "file=@person_a_2.jpg" -F "reference_embedding=<emb.json" http://localhost:8000/verify-face
curl.exe -s -F "file=@person_b.jpg" -F "reference_embedding=<emb.json" http://localhost:8000/verify-face
```

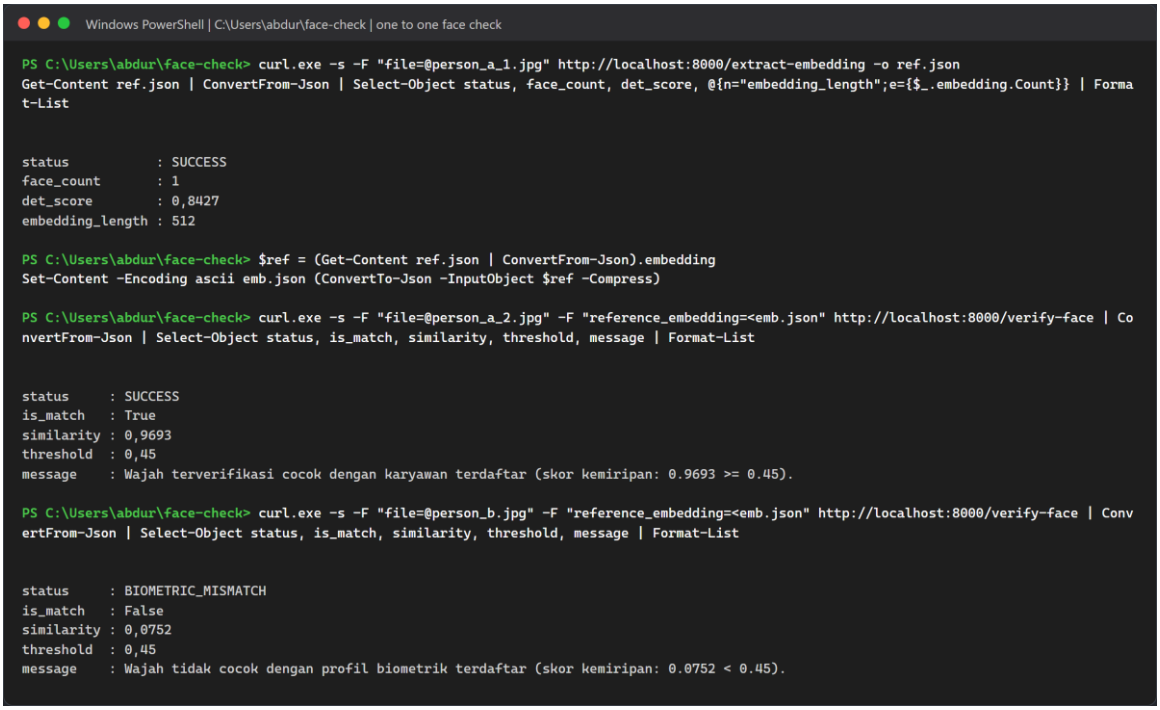


Figure 11.17: *The same person scores 0.9693 and passes the 0.45 threshold. A different person scores 0.0752 and gets BIOMETRIC_MISMATCH. PowerShell prints decimals with a comma on this machine.*

These are the numbers the system works with. The 0.55 value sometimes quoted for face matching is the detection threshold, not the match threshold:

Check	Value	Where it lives
Face detection confidence	0.55, on a 320 x 320 detector input	det_thresh in biometric-service/service.py. A face below this score is not detected at all.
Clock in and clock out match (one to one)	similarity of 0.45 or more	attendance service, and the default threshold of POST /verify-face.
Duplicate check at enrollment (one to many)	below 0.50 unique; 0.50 up to 0.90 sibling tier; 0.90 or more identical	employee service, checked against every other active employee.
Live webcam photo time	within 5 minutes of server time	verifyPhotoTimestamp in libs/common attendance-rules.ts

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

Uploaded photo time	same WIB day, no older than 12 hours	same function. A photo outside the window is saved but marked as not verified.

Photo proof works like this. The portal draws every capture or upload onto an HTML5 canvas and burns in a watermark with the time, NIP, name, department and capture source, then sends that canvas JPEG. Because a canvas export carries no EXIF data, the gateway falls back to the capture time the browser sends in photoCapturedAt (for an upload, the file's last modified time). It only reads EXIF DateTimeOriginal, then CreateDate, then ModifyDate when an original JPEG reaches the API directly. The attendance service then marks the photo as verified or not verified with the rules in the table.

11.6.3 Step 2: API Gateway and The Microservice Links

Open http://localhost:3000/api/system/health. It returns a short JSON reply with "status":"OK".



Figure 11.18: *The gateway health reply in the browser.*

The health endpoint only proves that the gateway itself is up. It does not contact the microservices. To prove both TCP links work, call one endpoint that goes through each service:

- GET /api/system/policy reads the company policy through the attendance service on port 3002.
- POST /api/auth/login checks a password through the employee service on port 3001. HTTP 201 means the sign in worked.

```
curl.exe -s http://localhost:3000/api/system/policy
curl.exe -s -o NUL -w "HTTP %{http_code}" -X POST http://localhost:3000/api/auth/login -H "Content-Type: application/json" -d "{\"email\":\"sysadmin@dexagroup.com\",\"password\":\"AdminDexa2026!\"}"
```

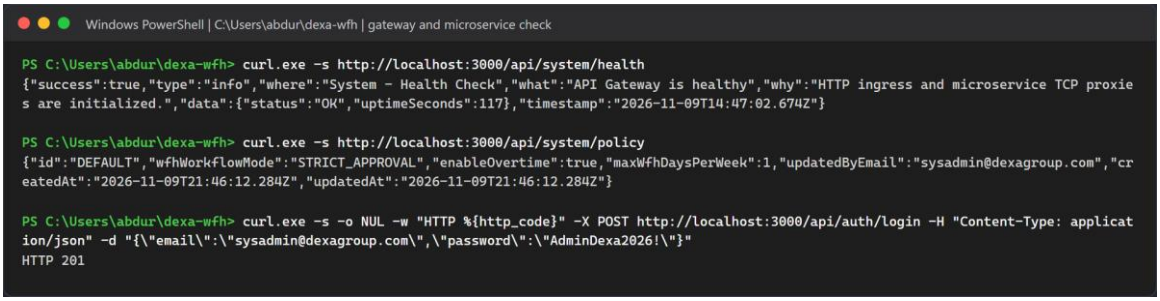


Figure 11.19: *The policy comes back from the attendance service and the login succeeds through the employee service.*

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.6.4 Step 3: Real Email Delivery

There is no local inbox to open. Every email goes through the SMTP account in .env, so open the mailbox you set in SMTP_OVERRIDE_RECIPIENT in Gmail or Outlook. Nothing arrives until the system sends something, so the next step sends a test email to prove the connection works. After that, one time codes, WFH notices, approval emails with their review links, and support tickets arrive in the same inbox, each with a yellow banner naming the demo account it was meant for.

11.6.5 Step 4: The Portal Sign In Page

Open http://localhost:5173. You land on the Dexa Group sign in page.



Figure 11.20: *The WFH Attendance Portal sign in page.*

11.6.6 Step 5: First sign in with a seeded account

These accounts come straight from the seeder in backend/apps/employee-service/src/seed/seed.service.ts:

Role	Full name	NIP	Department	Email	Password
SYSTEM_ADMIN	Abdurrahman Khairi	DEXA-SYS-001	IT & Digital Innovation	sysadmin@dexagroup.com	AdminDexa2026!
HR_ADMIN	HR Admin One	DEXA-2026-001	HRD & People Operations	admin.hrd@dexagroup.com	AdminDexa2026!

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

MANAGER	Manager One	DEXA-MGR-001	IT & Digital Innovation	manager.it@dexagroup.com	ManagerDexa2026!
MANAGER	Manager Two	DEXA-MGR-002	Finance & Accounting	manager.finance@dexagroup.com	ManagerDexa2026!
EMPLOYEE	Employee One	DEXA-2026-002	IT & Digital Innovation	employee.one@dexagroup.com	EmployeeDexa2026!
EMPLOYEE	Employee Two	DEXA-2026-003	Finance & Accounting	employee.two@dexagroup.com	EmployeeDexa2026!
EMPLOYEE	Employee Three	DEXA-2026-004	Quality Assurance & R&D	employee.three@dexagroup.com	EmployeeDexa2026!
EMPLOYEE (not verified yet)	Employee Four	DEXA-2026-005	IT & Digital Innovation	employee.four@dexagroup.com	set during verification

- The manager accounts only exist after the restart in section 11.4, Step 4.
- Employee Four signs in once, receives a fresh 6 digit code by email, and then chooses a password. The code is valid for 15 minutes. In Docker the code is not shown on screen, so the SMTP settings must work for this account.
- Every role except the System Admin is asked to register a face on the first sign in.

Sign in as the System Admin. No face step is needed for this account, and the portal opens straight on the Database Management page.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

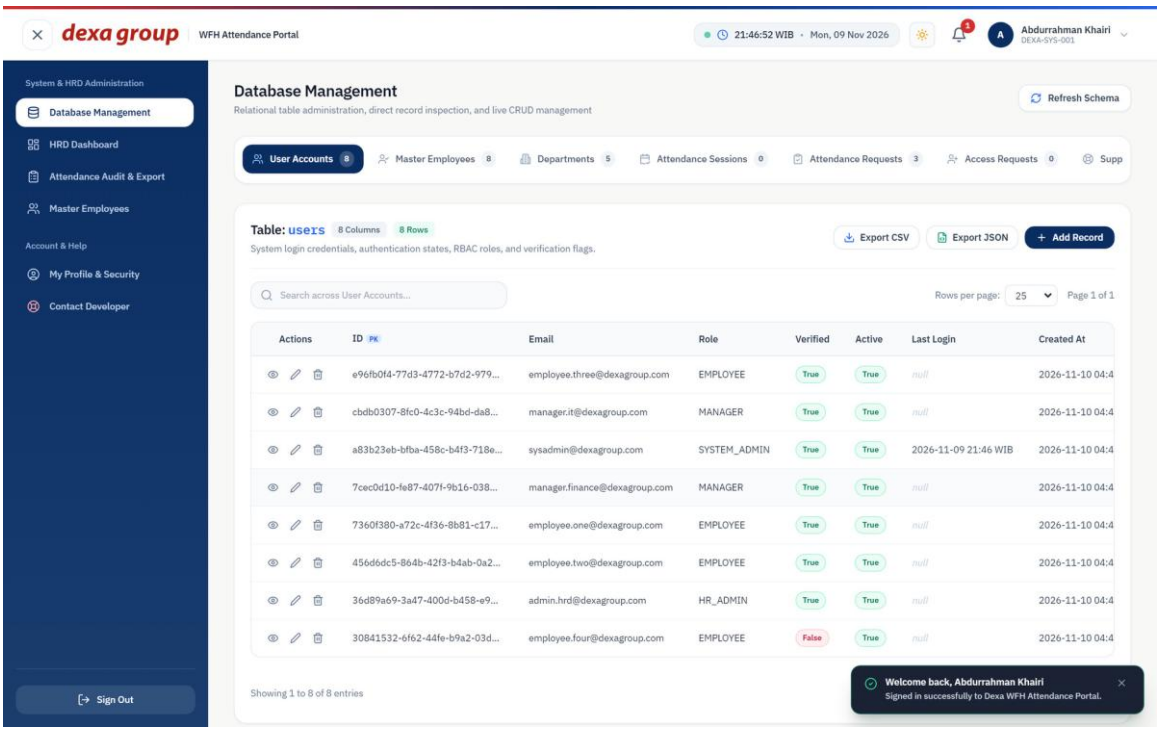


Figure 11.21: *Signed in as the System Admin right after installation. The users table holds the eight seeded accounts.*

11.6.7 Step 6: The Uploads Folder on Disk

Photos are stored in a tree: year, department, role folder, person, month. The role folder is manager for System Admins, HR Admins and managers, and employee for everyone else. File names carry a prefix, the person, the date and the time. The time in the file name is UTC, so it reads seven hours behind WIB.

To create the first file, the test run signed in as HR Admin One and registered a face. The gateway saved the enrollment photo straight away:

```
tree /F /A uploads
```



Figure 11.22: *The uploads tree after the first face enrollment.*

On macOS or Linux, use find uploads -type f. In Method B, look in backend/uploads instead.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

11.7 Troubleshooting and Maintenance

11.7.1 The Camera Does Not Open

- Use http://localhost:5173. A LAN address such as http://192.168.x.x:5173 is not treated as secure, and the browser will block the camera there.
- In Chrome or Edge, click the site settings icon left of the address, set Camera to Allow, and reload. You can also open chrome://settings/content/camera or edge://settings/content/camera.
- On Windows, open Settings, then Privacy & security, then Camera, and allow access for desktop apps and the browser.
- Close Teams, Zoom or OBS if they are holding the camera.
- No camera at all? Use the photo upload option on the attendance page and give a reason. The upload is still accepted when its time is old, but it is marked as not verified unless it was taken on the same WIB day and no more than 12 hours ago. The face must still match your enrolled face.

dexa group

11.7.2 The Face Model is Slow or Missing

- The model lives in %USERPROFILE%\.insightface\models\buffalo_l on Windows and ~/.insightface/models/buffalo_l on macOS and Linux. The zip is about 288 MB.
- If the download stalls, fetch https://github.com/deepinsight/insightface/releases/download/v0.7/buffalo_l.zip from another network or with a download manager, unpack it into that folder, and restart the engine.
- Docker mounts the folder as read only, so the container cannot download the model itself. Fix the folder on the host, then run docker compose restart biometric-service.
- The first load takes some time: about 28 seconds in Docker on the test machine. Give it a moment before the first face enrollment.
-

11.7.3 Duplicate Face Prevention and Sibling Exemption

This check needs a webcam and one real person. You enroll the same face on two accounts, watch the second attempt get refused, and then let HR allow it. Do it in this order:

- **Enroll Employee One.** Sign in as employee.one@dexagroup.com. The portal sends you to /auth/enroll-face. Capture your face and wait until the attendance page opens.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- **Switch to Employee Four.** Sign out and sign in as employee.four@dexagroup.com. This account is not activated yet, so it first asks for the 6 digit code sent by email (to your own inbox when SMTP_OVERRIDE_RECIPIENT is set) and a new password (see Step 5), and then opens the face page.
- **Capture the same face.** The system refuses the enrollment with HTTP 409 Conflict and shows this message, where X is the similarity score: Wajah sudah terdaftar! Wajah ini memiliki kemiripan biometrik X% dengan profil karyawan 'Employee One' (DEXA-2026-002). Jika Anda memiliki saudara kandung atau kembar di Dexa Group, hubungi HR Admin untuk mengaktifkan Sibling Biometric Exemption.
- **Turn on the exemption.** Sign in as admin.hrd@dexagroup.com, open Employee Management (/hrd/employees), edit Employee Four and switch Sibling Biometric Exemption on. The page calls PATCH /api/employees/:id/sibling-exemption, which only HR Admin and System Admin accounts may call.
- **Enroll again.** Sign in as employee.four@dexagroup.com and capture the face again. This time enrollment succeeds, and the employee service writes a SIBLING_EXEMPTION_APPLIED line to its log with the score and the name of the admin who approved it.

To see the result in the database:

```
docker compose exec mysql mysql -udexa_user -pdexa_password_2026 dexa_wfh_db -e "SELECT employee_code, full_name, is_sibling_exempt, face_embedding IS NOT NULL AS enrolled FROM employees WHERE email IN ('employee.one@dexagroup.com', 'employee.four@dexagroup.com');"
```

> **Note: A score of 90% or more is a different case**
>
> From 90% up, the message starts with "Wajah terdeteksi identik" instead, and the exemption does not help, because the system treats the capture as the same face registered twice. Whether two live captures of one person land below 90% depends on light, distance and pose. If you hit this block during the test, change the angle or the lighting a little and capture again.

-

11.7.4 Real Email Does Not Arrive

Start with the logs. On startup each service prints the SMTP host, port and whether it signs in, and every email ends in an [SMTP_SUCCESS] or [SMTP_ERROR] line:

```
docker compose logs employee-service | findstr /i "SMTP"
docker compose logs attendance-service | findstr /i "SMTP"
```


© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- **Gmail error 535 5.7.8 "Username and Password not accepted".** Gmail does not accept your normal Google password over SMTP. Turn on two step verification for the Google account, then open Google Account, Security, two step verification, and App passwords at the bottom of that page. Create an app password, paste the 16 characters into SMTP_PASS without the spaces, and run docker compose up -d.
- **Gmail shows a different sender.** Gmail rewrites the sender to the account in SMTP_USER unless the address is a verified alias. Set SMTP_FROM to your Gmail address.
- **Outlook or Office 365 fails during STARTTLS.** Keep SMTP_HOST=smtp.office365.com, SMTP_PORT=587 and SMTP_SECURE=false, so the connection starts in plain text and then upgrades with STARTTLS. With SMTP_SECURE=true on port 587 the handshake fails. For Microsoft hosts both services also force STARTTLS (requireTLS) and set the TLS cipher list to SSLv3. That is an OpenSSL cipher group kept for compatibility with Microsoft servers; it does not switch the connection to the old SSL 3.0 protocol.
- **Outlook refuses a correct password.** Microsoft has been turning off password sign in for SMTP on many accounts and tenants. This project signs in with a password only and has no OAuth2 support, so if your account or tenant has SMTP AUTH turned off, switch to Gmail with a 16 character App Password.
- **Bounce notices after a support ticket.** With SMTP_OVERRIDE_RECIPIENT set, the employee service changes the To address of a support ticket but keeps its CC list, which holds the HR Admin and sender addresses on @dexagroup.com. Real SMTP then reports those copies as undeliverable. The ticket itself still reaches your inbox.
- **Nothing changed after you edited .env.** docker compose restart keeps the old values. Run docker compose up -d so Docker recreates the containers with the new ones.

11.7.5 Face Enrollment Returns 409 Conflict

- **"Wajah sudah terdaftar!" with a score from 50% to 89.9%.** The new face looks like another active employee. If the two people really are siblings or twins, an HR Admin opens Employee Management, edits the employee who is enrolling and switches Sibling Biometric Exemption on. The employee then captures the face again.
- **"Wajah terdeteksi identik" with 90% or more.** The system treats this as one face on two accounts, and the exemption does not lift it. Only active employees take part in the comparison, so during testing you can deactivate the other account in Employee Management, or start again from an empty database with docker compose down -v.

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

- **A 409 on an account that never enrolled before.** Another active account already holds a similar face, often from an earlier test run. The SQL query in section 11.6, Step 2.5 shows which accounts have a face on file.
- **The exemption switch is refused with 403.** Only HR Admin and System Admin accounts may change it. Sign in with one of those roles.

11.7.6 A Port is Already Taken

```
# Windows
netstat -ano | findstr :3306
taskkill /PID <pid> /F

# macOS and Linux
lsof -i :3306
kill -9 <pid>
```

Local MySQL installs from XAMPP or Laragon often sit on 3306. You can stop them, or set DB_PORT=3307 in the root .env so Docker publishes MySQL on 3307. The containers keep talking to each other on 3306. The other host ports are fixed in docker-compose.yml. To move one, change the number on the left of its ports entry.

dexa group

11.7.7 Useful reset and maintenance commands

Goal	Command
Stop everything and keep the data	docker compose stop
Remove the containers and keep the database	docker compose down
Wipe the database volume for a clean slate	docker compose down -v
Seed again from zero	docker compose down -v, then docker compose up -d, then docker compose restart employee-service once for the managers
Rebuild after code changes	docker compose up --build -d
Rebuild one service	docker compose up --build -d api-gateway
Follow the logs of one service	docker compose logs -f attendance-service
Open a MySQL shell	docker compose exec mysql mysql -udexa_user -pdexa_password_2026 dexa_wfh_db

Warning: Wiping the volume

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited

> docker compose down -v deletes every account change, attendance record, request and enrolled face for good. It does not delete the photos in uploads/. Remove those by hand if you want a truly clean start, and keep the .gitkeep file.

dexa group

© 2026 Abdurrahman Khairi - Created strictly for Technical Assessment evaluation. Unauthorized commercial use is prohibited